NIST 特别出版物 800 NIST SP 800-57pt1r6 ipd

密钥管理建议

第 1 部分 — 总则

初始公开草案

Elaine Barker

William Barker

本出版物可免费获取：https://doi.org/10.6028/NIST.SP.800-57pt1r6.ipd

NIST 特别出版物 800

NIST SP 800-57pt1r6 ipd

密钥管理建议

第 1 部分 — 总则

初始公开草案

Elaine Barker

计算机安全部

信息技术实验室

William Barker

信息技术实验室；

Strativia LLC*

*前 Strativia 员工；本出版物的部分工作是在 Strativia 期间完成的

本出版物可免费获取：

https://doi.org/10.6028/NIST.SP.800-57pt1r6.ipd

2025 年 12 月

美国商务部

Howard Lutnick，部长

美国国家标准与技术研究院

Craig Burkhardt，代理商务部标准与技术副部长兼代理 NIST 院长

为了充分说明实验过程，本文可能识别了某些商业或非商业的设备、仪器、软件或材料。此类识别并不意味着 NIST 推荐或认可任何产品或服务，也不意味着所识别的材料或设备必然是最适合该用途的。

本出版物可能引用了 NIST 根据其法定职责正常在开发中的其他出版物。即使在这些配套出版物完成之前，本出版物中的信息（包括概念和方法论）也可供联邦机构使用。因此，在每份出版物完成之前，现有的要求、指南和程序（如存在）仍然有效。为了规划和过渡目的，联邦机构可能希望密切关注 NIST 这些新出版物的开发进展。

鼓励各组织在公众评论期间审查所有草案出版物并向 NIST 提供反馈。除上述注明外的许多 NIST 网络安全出版物可在 https://csrc.nist.gov/publications 获取。

授权

本出版物由 NIST 根据其在 2014 年《联邦信息安全现代化法案》(FISMA)（44 U.S.C. § 3551 及后续条款，公法 (P.L.) 113-283）下的法定职责开发。NIST 负责制定信息安全标准和指南，包括联邦信息系统的最低要求，但此类标准和指南未经管理此类系统的适当联邦官员明确批准，不适用于国家安全系统。本指南与管理与预算办公室 (OMB) A-130 号通告的要求一致。

本出版物中的任何内容均不得被视为与商务部长根据法定授权对联邦机构强制执行的指南和标准相矛盾。这些指南也不应被解释为改变或取代商务部长、OMB 主任或任何其他联邦官员的现有权力。本出版物可供非政府组织自愿使用，在美国不受版权保护。然而，NIST 希望得到署名。

NIST 技术系列政策

版权、使用和许可声明

NIST 技术系列出版物标识符语法

出版历史

于 YYYY-MM-DD 经 NIST 编辑审查委员会批准 [将添加到最终出版物中。] 取代 NIST 系列 XXX（年月）DOI [如适用，将添加到最终出版物中。]

如何引用本 NIST 技术系列出版物

Barker E, Barker W (2025) 密钥管理建议：第 1 部分 — 总则。(美国国家标准与技术研究院，马里兰州盖瑟斯堡), NIST 特别出版物 (SP) NIST SP 800-57pt1r6 ipd. https://doi.org/10.6028/NIST.SP.800-57pt1r6.ipd

作者 ORCID iD

Elaine Barker: 0000-0003-0454-0461

William Barker: 0000-0002-4113-8861

公众评论期

2025 年 12 月 5 日 – 2026 年 2 月 5 日

提交评论

keymanagement@nist.gov

美国国家标准与技术研究院

注意：计算机安全部，信息技术实验室

100 Bureau Drive (Mail Stop 8930) Gaithersburg, MD 20899-8930

附加信息

有关本出版物的附加信息可在 https://csrc.nist.gov/pubs/sp/800/57/pt1/r6/ipd 获取，包括相关内容、潜在更新和文档历史。

所有评论均须根据《信息自由法》(FOIA) 发布。

摘要

本建议分三部分提供加密密钥管理指南。第 1 部分提供加密密钥材料管理的通用指南和最佳实践，包括使用加密时可能提供的安全服务的定义、可能采用的算法和密钥类型、每种密钥和其他加密信息所需保护的规范以及提供此保护的方法、关于密钥管理涉及的功能的讨论，以及使用加密时要解决的各种密钥管理问题的讨论。第 2 部分为美国政府机构提供政策和安全规划要求的指南。第 3 部分提供使用当前系统加密功能的指南。

关键词

归档；身份认证；授权；可用性；备份；泄露；机密性；加密密钥；加密模块；数字签名；可扩展输出函数；哈希函数；哈希方法；密钥协商；密钥管理；密钥恢复；密钥材料；密钥传输；私钥；公钥；抗量子；密钥；安全类别；安全强度；信任锚。

计算机系统技术报告

美国国家标准与技术研究院 (NIST) 的信息技术实验室 (ITL) 通过为国家的测量和标准基础设施提供技术领导力，促进美国经济和公共福利。ITL 开发测试、测试方法、参考数据、概念验证实现和技术分析，以推进信息技术的开发和有效使用。ITL 的职责包括为联邦信息系统中非国家安全相关信息的经济高效的安全性和隐私性开发管理、行政、技术和物理标准及指南。特别出版物 800 系列报告 ITL 在信息系统安全方面的研究、指南和外部工作，以及其与行业、政府和学术组织的合作活动。

致审查者的说明

1. 已纳入 SP 800-232 中规定的 Ascon 以及 FIPS 203、204 和 205 中规定的新抗量子算法。
2. 现在分别讨论用于密钥建立和密钥存储的密钥。
3. 已纳入 PQC 竞赛中使用的安全类别以及抗量子算法。
4. 已删除算法批准状态的时间框架，替换为对 SP 800-131A 的引用。
5. 已添加一节来讨论密钥材料存储和机制。
6. 有关更完整的变更列表，请参见附录 F。

专利权利要求征集

本次公开审查包括征集基本专利权利要求的信息（其使用对于符合本信息技术实验室 (ITL) 草案出版物中的指南或要求是必需的）。此类指南和/或要求可能直接在本 ITL 出版物中说明，或通过引用另一出版物说明。此征集还包括披露（如已知）与本 ITL 草案出版物相关的待决美国或外国专利申请的存在，以及任何相关的未过期美国或外国专利。

ITL 可能要求专利持有人或代表其做出保证的授权方以书面或电子形式提供以下任一保证：

a) 一般性免责声明形式的保证，即该方不持有且目前不打算持有任何基本专利权利要求；或
b) 保证将向希望利用许可以符合本 ITL 草案出版物中的指南或要求的申请人提供此类基本专利权利要求的许可，许可条件为：

i. 根据明显无任何不公平歧视的合理条款和条件；或
ii. 在明显无任何不公平歧视的合理条款和条件下无偿提供。

此类保证应表明，专利持有人（或代表其做出保证的第三方）将在任何转让受保证约束的专利所有权的文件中包含足够条款，以确保保证中的承诺对受让人具有约束力，并且受让人将在未来转让时类似地包含适当条款，目标是约束每个利益继承人。

保证还应表明，无论相关转让文件中是否包含此类条款，其意图对利益继承人具有约束力。

此类声明应发送至：keymanagement@nist.gov。

目录

- 1. 引言
  - 1.1. 目的
  - 1.2. 受众
  - 1.3. 范围
  - 1.4. 术语初步讨论
  - 1.5. 内容和组织
- 2. 安全服务
  - 2.1. 机密性
  - 2.2. 数据完整性
  - 2.3. 身份认证
  - 2.4. 授权
  - 2.5. 不可否认性
  - 2.6. 支持服务
  - 2.7. 组合服务
- 3. 加密算法
  - 3.1. 加密哈希方法
  - 3.2. 对称密钥算法
  - 3.3. 非对称密钥算法
  - 3.4. 随机比特生成
- 4. 通用密钥管理指南
  - 4.1. 密钥类型和其他信息
    - 4.1.1. 加密密钥
    - 4.1.2. 其他相关信息
  - 4.2. 密钥使用
  - 4.3. 密码周期
    - 4.3.1. 影响密码周期的因素
    - 4.3.2. 影响密码周期的后果因素
    - 4.3.3. 影响密码周期的其他因素
      - 4.3.3.1. 通信与存储
      - 4.3.3.2. 密钥撤销和替换的成本
    - 4.3.4. 非对称密钥使用周期和密码周期
    - 4.3.5. 对称密钥使用周期和密码周期
    - 4.3.6. 特定密钥类型的密码周期建议
  - 4.4. 保证
    - 4.4.1. 完整性保证（完整性保护）
    - 4.4.2. 算法参数有效性保证
    - 4.4.3. 公钥有效性保证
    - 4.4.4. 私钥占有保证
    - 4.4.5. 密钥确认
  - 4.5. 密钥和其他密钥材料的泄露
    - 4.5.1. 影响
    - 4.5.2. 保护措施
  - 4.6. 加密算法和密钥大小选择指南

- 4.6.1. 加密算法安全强度
  - 4.6.1.1. 批准对称密钥算法的安全强度
  - 4.6.1.2. 批准经典非对称密钥算法的安全强度
  - 4.6.1.3. 批准抗量子非对称密钥算法的安全强度
  - 4.6.1.4. 哈希函数、XOF 及其应用程序的安全强度
- 4.6.2. 使用算法套件和有效安全强度
- 4.6.3. 预测算法和安全强度批准状态
- 4.6.4. 系统中向新算法和密钥大小过渡
- 4.6.5. 安全性随时间降低

- 5. 密钥信息的保护要求
  - 5.1. 保护和保证要求
    - 5.1.1. 密码密钥的保护和保证要求摘要
    - 5.1.2. 其他相关信息的保护要求摘要
  - 5.2. 保护机制
    - 5.2.1. 传输中密钥信息的保护机制
      - 5.2.1.1. 可用性
      - 5.2.1.2. 完整性
      - 5.2.1.3. 机密性
      - 5.2.1.4. 与用法或应用程序的关联
      - 5.2.1.5. 与其他实体的关联
      - 5.2.1.6. 与其他相关密钥信息的关联
    - 5.2.2. 存储中密钥信息的保护机制
      - 5.2.2.1. 可用性
      - 5.2.2.2. 完整性
      - 5.2.2.3. 机密性
      - 5.2.2.4. 与用法或应用程序的关联
      - 5.2.2.5. 与其他实体的关联
      - 5.2.2.6. 与其他相关密钥信息的关联
      - 5.2.2.7. 密钥材料存储介质和机制
    - 5.2.3. 密钥的元数据
- 6. 密钥状态和转换
  - 6.1. 预激活状态
  - 6.2. 活跃状态
  - 6.3. 暂停状态
  - 6.4. 泄露状态
  - 6.5. 销毁状态
- 7. 密钥管理阶段和功能
  - 7.1. 预操作阶段
    - 7.1.1. 实体注册功能
    - 7.1.2. 系统初始化功能
    - 7.1.3. 初始化功能
    - 7.1.4. 密钥材料安装功能
    - 7.1.5. 密钥建立功能
      - 7.1.5.1. 非对称密钥对的生成和分发
      - 7.1.5.2. 对称密钥的生成和分发
      - 7.1.5.3. 其他密钥材料的生成和分发

        - 7.1.6. 密钥注册功能
    - 7.2. 运行阶段
        - 7.2.1. 正常常运行存储功能
            - 7.2.1.1. 加密模块存储
            - 7.2.1.2. 立即可访问存储介质
        - 7.2.2. 操作连续性功能
            - 7.2.2.1. 备份存储
            - 7.2.2.2. 密钥恢复功能
        - 7.2.3. 密钥更改功能
            - 7.2.3.1. 重新密钥
            - 7.2.3.2. 密钥更新功能
        - 7.2.4. 密钥导出方法
    - 7.3. 运行后阶段
        - 7.3.1. 密钥归档和密钥恢复功能
        - 7.3.2. 实体注销功能
        - 7.3.3. 密钥注销功能
        - 7.3.4. 密钥销毁功能
        - 7.3.5. 密钥撤销功能
    - 7.4. 销毁阶段
- 8. 附加考虑因素
    - 8.1. 访问控制和身份身份认证
    - 8.2. 清单管理
        - 8.2.1. 密钥清单
        - 8.2.2. 证书清单
    - 8.3. 问责制
    - 8.4. 审计
    - 8.5. 密钥管理系统生存能力
        - 8.5.1. 备份和归档密钥
        - 8.5.2. 密钥恢复
        - 8.5.3. 系统冗余/应急计划
            - 8.5.3.1. 一般原则
            - 8.5.3.2. 加密和密钥管理特定恢复问题
        - 8.5.4. 泄露恢复
    - B.1. 一般性讨论
        - B.1.1. 从存储密钥材料恢复
        - B.1.2. 通过重建密钥材料恢复
        - B.1.3. 需要可恢复密钥材料的条件
        - B.1.4. 密钥恢复系统
        - B.1.5. 密钥恢复政策
    - B.2. 数字签名密钥对
        - B.2.1. 私签名密钥
        - B.2.2. 公签名验证密钥
    - B.3. 身份认证密钥
        - B.3.1. 对称身份认证密钥
        - B.3.2. 身份认证（非对称）密钥对

        - B.3.2.1. 私身份认证密钥
        - B.3.2.2. 公身份认证密钥
    - B.4. 随机数生成密钥
    - B.5. 密钥导出/主密钥
    - B.6. 密钥建立（自动化）
        - B.6.1. 对称密钥包装密钥
        - B.6.2. 密钥传输密钥对
            - B.6.2.1. 公密钥传输密钥
            - B.6.2.2. 私密钥传输密钥
        - B.6.3. 对称密钥协商密钥
        - B.6.4. 静态密钥协商密钥对
            - B.6.4.1. 公静态密钥协商密钥
            - B.6.4.2. 私密态密钥协商密钥
        - B.6.5. 临时密钥协商密钥对
            - B.6.5.1. 公临时密钥协商密钥
            - B.6.5.2. 私临时密钥协商密钥
        - B.6.6. 静态封装/解封密钥对
            - B.6.6.1. 公静态封装密钥
            - B.6.6.2. 私密态解封密钥
        - B.6.7. 临时封装/解封密钥对
            - B.6.7.1. 公临时封装密钥
            - B.6.7.2. 私临时解封密钥
    - B.7. 对称数据加密/解密密钥
        - B.7.1. 传输中数据的加密/解密
        - B.7.2. 静态数据的加密/解密
    - B.8. 密钥材料存储
        - B.8.1. 对称密钥包装/拆封密钥
        - B.8.2. 非对称密钥加密/解密密钥对
            - B.8.2.1. 公密钥包装密钥
            - B.8.2.2. 私密钥拆封密钥
        - B.8.3. 封装/解封密钥对
            - B.8.3.1. 公封装密钥
            - B.8.3.2. 私解封密钥
    - B.9. 授权
        - B.9.1. 对称授权密钥
        - B.9.2. 授权密钥对
            - B.9.2.1. 私授权密钥
            - B.9.2.2. 公授权密钥
    - B.10. 其他相关信息
        - B.10.1. 算法参数
        - B.10.2. 初始化向量 (IV)
        - B.10.3. 共享密钥
        - B.10.4. 种子
        - B.10.5. 其他公开和秘密信息
        - B.10.6. 中间结果
        - B.10.7. 密钥控制信息/元数据

- B.10.8. 随机数
- B.10.9. 密码
- B.10.10. 审计信息

1. 引言

使用加密机制是为通信、数据存储和其他应用提供安全服务的最强方式之一。美国国家标准与技术研究院 (NIST) 发布 FIPS 和 NIST 特别出版物 (SP)，规定用于保护受控非机密信息 (CUI) 的加密技术。[1]

自 NIST 于 1977 年发布数据加密标准 (DES) 以来，批准的标准化算法套件已经增长。已添加新类别的算法，例如安全哈希函数、密钥导出函数和非对称抗量子算法。该算法套件通过各种密钥长度提供不同级别的加密强度。这些算法可以以多种方式组合，以支持日益复杂的协议和应用。本 NIST 建议适用于使用加密来保护 CUI 的联邦机构。其他希望在其计算机系统中实施合理安全原则的组织也可以自愿遵循本建议。

加密密钥和其他密钥信息的适当管理对于有效使用加密来实现安全至关重要。加密密钥类似于保险箱的密码。如果对手知道密码，那么最坚固的保险箱也无法提供防渗透的安全性。同样，糟糕的密钥管理很容易破坏强大的算法。最终，受加密保护的信息的安全性直接取决于密钥的强度、与密钥相关的机制和协议的有效性以及对密钥的保护。加密可能因实施薄弱、算法配对不当、物理安全性差和协议薄弱（即易受攻击）而失效。

密钥管理是管理密钥在其整个生命周期内的过程，包括其安全生成、存储、分发、使用和销毁。密钥可以手动管理，但通常需要自动化系统来监督、自动化和保护密钥管理过程。执行密钥管理的自动化系统通常称为（加密）密钥管理系统（参见 [SP 800-130] 和 [SP 800-152]）。

NIST 批准的加密技术会定期重新评估其持续有效性。NIST 标准（例如 AES、SHA-2 和 ECDSA）中指定的算法及其所在的加密模块需要符合性测试。认可实验室对声称符合标准的供应商实施执行这些测试。供应商需要修改不符合的实施，以满足所有适用要求。经验证的实施用户可以高度相信经验证的实施符合标准。如果发现任何技术不足以继续保护政府信息，NIST 标准将修订或停用。自 1977 年以来，NIST 已开发了一套 NIST 标准[2] 的加密"工具包"，形成实施批准加密的基础。第 1 部分引用了这些标准中的许多标准，并提供了如何正常确使用它们来保护 CUI 的指南。NIST 标准开发过程记录在 [NIST IR 7977] 中。

1.1. 目的

组织及其开发人员在使用加密机制时面临许多新选择。不适当的选择可能导致协议或应用几乎没有或根本没有真正常的安全性。本建议提供背景信息并建立框架，以支持在选择和使用加密机制时做出适当的决策。

1.2. 受众

本建议的受众包括系统和应用所有者及管理者、加密模块开发人员、协议开发人员和系统管理员。本建议分为三部分，已针对特定受众进行调整：

1. 第 1 部分（即本文档）提供通用密钥管理指南，旨在对系统开发人员和系统管理员都有用。[3] 加密模块开发人员可以通过更深入地了解支持特定应用所需的密钥管理功能而受益。协议开发人员可以识别与特定算法套件相关的密钥管理特征，并更深入地了解这些算法提供的安全服务。系统管理员可以使用第 1 部分和第 3 部分来帮助确定最适合其系统的配置设置。
2. 第 2 部分 [SP 800-57p2] 帮助系统和应用所有者（例如组织内的信息安全组）识别适当的组织密钥管理基础设施，建立组织密钥管理策略，并指定组织密钥管理实践和计划。
3. 第 3 部分 [SP 800-57p3] 解决与当前可用加密机制相关的密钥管理问题。旨在为现有密钥管理基础设施、协议和其他应用的系统安装人员、系统管理员和最终用户以及为使用当前技术的新系统做出采购决策的人员提供指南。

虽然提供了一些背景信息和理由以供参考并支持建议，但本文档假设读者对加密有基本了解。关于背景材料，读者可以参考各种 NIST 和商业出版物，包括 [SP 800-175B]，其中提供了使用加密和 NIST 加密标准的建议。

1.3. 范围

本建议的第 1 部分讨论加密算法、基础设施、协议、实施、应用及其管理。目前 NIST 批准用于保护受控非机密信息的所有加密算法都在第 1 部分的范围内。

第 1 部分侧重于涉及加密密钥管理的问题：其生成、使用和最终销毁。还包括相关主题（例如算法选择和适当密钥长度、加密策略和加密模块选择）。

本建议不涉及可用于实现已识别安全要求的加密模块的实现细节，这些细节在 [FIPS 140-3]、CMVP 实施指南 [IGD_B] 和衍生测试要求 [SP 800-140] 中提供。此外，本建议不涉及运营密钥归档或备份能力的要求或程序，仅讨论适合备份或包含在归档中的密钥材料类型以及要为密钥材料提供的保护。

本建议经常使用"要求"术语，这些术语在本文档中有以下含义：

1. Shall（应）：此术语用于表示 FIPS 的要求或必须履行才能声称符合本建议的要求。Shall 可以与 not 结合成为 shall not（不应）。
2. Should（应该）：此术语用于表示重要的建议。忽视该建议可能导致不良结果。Should 可以与 not 结合成为 should not（不应该）。

1.4. 术语初步讨论

本建议的第 1 部分使用几个与加密密钥信息管理相关的术语。虽然这些术语中的每一个都在附录 E 中定义，但比较这些术语并显示它们的关系可能很有用，因为它们将在整个文档中使用：

加密密钥是与加密算法结合使用的参数，用于确定其操作方式，使得知道密钥的实体可以重现、反转或验证操作，而不知道密钥的实体则不能。示例包括与 AES 一起使用来加密明文数据和解密密文数据的对称密钥、与数字签名算法一起使用来生成数字签名的私签名密钥，或与数字签名算法一起使用来验证数字签名的公签名验证密钥。

密钥由与实体交互以开展业务的实体（例如个人、组织、设备或进程）拥有和使用。在非人类所有者（即组织、设备或进程）的情况下，所有者由一个或多个人类代表或赞助。例如，如果所有者是组织，则可能有几个人被授权使用密钥，并且可以说这些人类在开展业务时代表组织。设备或进程可能拥有和使用密钥，但人类赞助者负责管理密钥（例如在需要时生成或替换密钥）。

密钥材料包括加密密钥和其他材料（例如初始化向量或算法参数），在加密算法执行期间使用。
元数据是与密钥相关联的信息，描述其特定特征、约束、可接受用途、所有权和其他详细信息。元数据的部分内容可能是秘密的（例如在某些情况下密钥所有者的身份）。
密钥信息是关于特定密钥的信息，包括与该密钥相关联的所有密钥材料以及与该密钥相关的元数据。

对称密钥和非对称密钥（公钥）算法的私钥需要机密性保护，某些元数据元素也可能需要此保护。所有密钥信息都需要完整性保护。

1.5. 内容和组织

本文档组织如下：

第 1 节，引言，建立目的、范围和预期受众。
第 2 节，安全服务，定义可以使用加密机制提供的安全服务。
第 3 节，加密算法，提供关于生成和使用加密密钥材料的批准加密算法的背景信息。
第 4 节，通用密钥管理指南，根据其用途对不同类型的密钥和其他密钥信息进行分类，讨论密码周期并为每种密钥类型建议适当的密码周期，为其他密钥材料提供建议和要求，介绍算法参数和公钥有效性保证的概念，讨论密钥泄露的影响，并为加密算法和密钥大小的选择、实施和替换提供指南。

第 5 节，密钥信息的保护要求，指定每种类型的密钥信息所需的保护，并确定提供此保护的方法。这些保护要求应特别引起加密模块供应商和应用实施者的兴趣。

第 6 节，密钥状态和转换，识别加密密钥在其生命周期内可能存在的状态。
第 7 节，密钥管理阶段和功能，识别密钥管理涉及的四个阶段和众多功能。本节应特别引起加密模块供应商和加密基础设施服务开发人员的兴趣。
第 8 节，附加考虑因素，讨论访问控制、身份身份认证、清单管理、问责制、审计和生存能力。
• 参考文献列出本文档中引用的来源。
• 附录 A，加密和非加密完整性和源身份认证机制，提供有关完整性和源身份认证服务的补充信息。
• 附录 B，密钥恢复，提供有关从密钥备份和归档中恢复密钥的附加信息。
• 附录 C，后量子算法的安全强度类别，提供一系列广泛的类别，这些类别已开发用于解决估计后量子加密系统安全强度的不确定性。
• 附录 D，缩写和首字母缩写词列表，包括本文档中使用的所有缩写和首字母缩写词。
• 附录 E，术语表，提供本文档中使用的术语的定义。[4]
• 附录 F，变更日志，包含自先前发布版本（即修订版 5）以来所做的变更历史。

2. 安全服务

加密可用于提供或支持几种基本安全服务：机密性、身份身份认证、完整性身份认证、源身份认证、授权和不可否认性。这些服务也可能需要用于保护密钥和与该密钥相关的信息。此外，还有其他加密和非加密机制用于支持这些安全服务。一般来说，单个加密机制可能提供多种服务（例如，使用数字签名可以提供完整性身份认证和源身份认证），但不能提供所有服务。

2.1. 机密性

机密性是一种属性，即信息不向未经授权的方披露；保密和隐私是经常与机密性同义使用的术语。可以通过加密获得机密性，使信息对未经授权的方无法理解，但使用适当密钥解密加密信息的授权方除外。要使加密提供机密性，用于加密的加密算法及其操作模式必须设计和实施，使得未经授权的方无法确定与加密相关联的解密密钥，或在不使用密钥的情况下直接导出明文。

2.2. 数据完整性

数据完整性是一种属性，即数据自创建、传输或存储以来未以未经授权的方式被修改。修改包括数据的插入、删除和替换。加密机制（例如消息身份认证码 (MAC) 或数字签名）可用于检测（具有高概率）意外修改（例如在嘈杂传输期间或硬件内存故障时有时发生的修改）和对手的故意修改。非加密机制也经常用于检测意外修改，但不能依赖其检测故意修改。附录 A 提供了对此主题的更详细处理。

在本建议中，声明加密算法"提供数据完整性"意味着该算法可用于检测未经授权的修改。身份认证完整性在下一节中讨论。

2.3. 身份认证

可以使用加密提供三种类型的身份认证服务：

1. 身份身份认证服务用于提供与系统交互的实体身份的保证。
2. 完整性身份认证服务用于验证数据未被修改（即此服务提供完整性保护）。
3. 源身份认证服务用于验证创建和/或发送信息的实体的身份。

源身份认证和身份身份认证非常相似，但目的不同。例如，源身份认证关注谁发起了一条消息，而身份身份认证用于获得对某些服务的访问权限。

几种加密机制可用于提供身份认证服务。最常见的是，数字签名或 MAC 用于提供身份认证；一些密钥建立技术也可以提供身份认证。

当允许多个个人共享相同的身份或源身份认证信息（例如密码或加密密钥）时，有时称为基于角色的身份认证。

2.4. 授权

授权涉及提供执行功能或活动的官方许可或权限（例如访问文档或访问房间）。授权被认为是一种安全服务，通常由加密服务支持。通常，只有在成功执行身份身份认证服务后才授予授权。身份身份认证和授权之间交互的非加密类比是检查个人的凭证以建立其身份。在验证个人的身份和访问某些资源（例如上锁的房间）的授权后，通常会向个人提供密钥（例如授权密钥）或密码，以允许访问该资源。

身份身份认证也可用于授权角色（例如系统管理员或审计角色），而不是识别个人。一旦通过角色身份认证，实体即被授权享有与该角色相关的所有特权。

2.5. 不可否认性

在密钥管理中，不可否认性是与数字签名密钥和将证书主体名称绑定到公钥的数字证书相关联的术语。当为数字签名密钥指示不可否认性时，这意味着由该密钥创建的签名不仅支持数字签名的通常完整性和源身份认证服务，而且还可以（取决于签名的上下文）表明证书主体的承诺，其意义与文档上的手写签名可能表明对合同的承诺相同。

密钥管理上下文中的不可否认性与法律上下文中的不可否认性不同。加密机制可用于提供信息来源的证据，但做出不可否认性的法律判定还涉及其他要素。

2.6. 支持服务

前几小节中讨论的基本加密安全服务通常需要其他支持服务。例如，加密服务通常需要使用密钥建立和随机数生成服务。密钥建立是使用手动传输方法（例如使用密钥加载器）、自动化方法（例如密钥传输和/或密钥协商协议）或自动化和手动方法的组合在实体之间安全建立加密密钥的过程。在加密密钥、挑战值和非ces 的生成期间需要随机数 [SP 800-175B]。

当不再需要密钥材料和其他数据时，通常需要销毁[5] 密钥材料和其他信息。该信息的所有副本都需要由知晓该信息的所有实体销毁，无论是在运行、备份或归档存储中；在密钥加载器上；还是打印在纸上或其他介质上。在开发或选择密钥管理能力时，需要考虑为每种使用的介质销毁密钥材料和其他信息的方法。[SP 800-88] 提供了敏感信息清理的指南。

2.7. 组合服务

在许多应用中，需要组合安全服务（例如机密性、完整性身份认证、源身份认证和/或不可否认性）。安全系统的设计者通常首先考虑需要哪些安全服务来保护系统存储和处理的信息。在确定这些服务后，设计者然后考虑哪些机制将最好地提供这些服务。并非所有机制都是加密性质的。例如，物理安全可用于保护某些类型数据的机密性（例如通过将数据放在保险箱中），身份证明徽章或生物识别设备可用于身份身份认证。然而，由算法、密钥和其他密钥材料组成的加密机制通常提供额外的、具有成本效益的方式来保护信息的安全性。在信息否则将暴露给未经授权的实体的应用中尤其如此。

当正常确实施时，一些加密算法提供多种服务。例如：

如果对称密钥对每对实体是唯一的且仅由这些实体知晓，则 MAC 可以同时提供源和完整性身份认证（参见 [SP 800-175B]）。

数字签名算法可以提供身份、完整性和源身份认证以及不可否认性（参见 [SP 800-175B]）。
• 某些操作模式在正常确实施时可以提供机密性、完整性身份认证和源身份认证。这些模式应专门设计为提供这些服务。

然而，通常需要采用不同的算法和程序来提供所有所需的服务。例如，考虑一个需要在成对实体之间安全交换信息的系统。一些交换的信息只需要完整性保护，而其他信息需要完整性和机密性保护。参与信息交换的每个实体还必须知道其他实体的身份。此示例系统的设计者决定需要建立公钥基础设施 (PKI)，并且每个想要安全通信的个人都需要在亲自证明其身份后获得必要的公钥证书。PKI 包括一个或多个负责创建证书的证书颁发机构 (CA)，通常每个 CA 至少有一个相关的注册机构 (RA)。RA 负责确认证书请求实体的身份。身份证明过程需要出示适当的凭证，例如驾驶执照、护照或出生证明。

两种类型的公钥证书常用：用于数字签名的证书和用于密钥建立的证书。

1. 要获得数字签名证书，个人为特定数字签名算法（例如 RSA、ECDSA 或 ML-DSA）生成一对密钥；该个人是密钥对的所有者。密钥对由公钥和私钥组成，它们相互对应且只能与特定算法一起使用。密钥对的公钥与密钥对所有者使用的标识符和其他信息一起包含在证书中。证书由 CA 使用 CA 拥有的数字签名私钥进行数字签名，证书提供给密钥对所有者、存入存储库或两者兼有。私钥保持在所有者的唯一控制下（即私钥保密）。

使用数字签名证书时，一个实体（即签名者）使用私钥对数据进行签名，并将签名数据发送给预期接收者。接收者：

o 获取签名者的公钥证书（例如从接收者或存储库），
o 使用与用于签名证书的私钥相对应的 CA 公钥验证证书，然后
o 使用证书中的公钥（即与签名者使用的私钥相对应的公钥）验证接收数据上的签名。

通过使用此过程，接收者使用数字签名算法获得对接收数据的完整性和源的保证。

2. 要获得用于密钥建立的证书，需要为特定密钥建立算法（例如 RSA、Diffie-Hellman 或 ML-KEM）生成密钥对。与数字签名的情况一样，公钥放在由 CA 签名的证书中，私钥由密钥对所有者保密。

使用证书的三种密钥建立方法：密钥协商、密钥传输和密钥封装（参见 [SP 800-175B]）。

o 密钥协商要求当两个实体希望通信时，它们需要交换信息（例如包含其公钥和可能其他信息的密钥建立证书），使两个实体都能生成相同的密钥，而无需在它们之间实际传输密钥。
o 密钥传输要求一个实体（即发送者）选择一个或多个要发送给另一个实体（即预期接收者）的密钥，并使用预期接收者的认证公钥加密它们，然后将加密密钥（即密文）发送给接收者进行解密。原始生成的密钥由发送者保留。
o 密钥封装要求封装实体（即发送者）使用预期接收者的认证公钥和新生成的随机值生成共享密钥和密文。密文发送给预期接收者进行解封，共享密钥由封装发送者保留。接收者使用密文和与其认证公钥相对应的私钥恢复封装发送者保留的相同共享密钥。

密钥建立证书在使用协商、传输或解封的密钥之前通过验证证书上 CA 的签名进行检查。这些密钥可以与对称算法一起使用进行加密或消息身份认证，为传输数据提供机密性或完整性保护。受对称密钥保护的数据的接收者保证数据来自公钥证书指示的另一个实体（即已获得对称密钥的源身份认证）。

这些示例显示了加密算法如何用于支持多种安全服务。然而，此类系统的安全性取决于许多因素，包括：

个人凭证的强度（例如驾驶执照、护照或出生证明）和身份身份认证过程；
• 所用加密算法的强度；
• 对 RA 和 CA 的信任程度；
• 密钥建立协议的强度；以及
用户在生成密钥并保护其免受未经授权使用时采取的谨慎程度。

因此，设计一个利用加密算法和合理的密钥管理技术来提供所需安全服务的安全系统，还需要仔细考虑所有因素和风险。此类系统的设计和实施应由具备必要技能和专业知识以有效考虑和解决这些因素和风险的分析师执行。

3. 加密算法

每当需要加密服务时，应使用 FIPS 批准和 NIST 推荐的加密算法。这些批准的算法在批准前已经过密集的安全分析，并继续接受检查以确保它们提供足够的安全性。大多数加密算法需要加密密钥和其他密钥材料。在某些情况下，可以通过增加所用密钥大小来加强算法。第 1 部分为加密机制用户提供算法和密钥大小的适当选择建议。

重要提示：密码分析算法（例如在未来量子计算机上运行的 Shor 算法）预计将击败经典批准的非对称算法（即 RSA、ECDSA 和 ECDH）提供的安全性。正常在向抗量子算法过渡。有关此工作的状态，请参见 https://csrc.nist.gov/projects/post-quantum-cryptography。

本节描述提供安全服务（例如机密性、身份身份认证、完整性身份认证和源身份认证）的批准加密算法。这些服务可以使用几种不同的算法实现，尽管单个算法通常可用于提供多种服务（参见 [SP 800-175B]）。

有三类基本的批准加密算法：加密哈希方法（参见第 3.1 节）、对称密钥算法（参见第 3.2 节）和非对称密钥算法（参见第 3.3 节）。使用这些算法所需的任何密钥必须使用随机比特生成器 (RBG) 生成（参见第 3.4 节）。

3.1. 加密哈希方法

在加密中，哈希是使用任意长度的输入比特串生成具有给定长度的输出的过程，该输出称为"哈希值"。[6] 加密哈希方法在其基本操作中不需要密钥。已批准两类哈希方法：加密哈希函数和可扩展输出函数 (XOF)。

加密哈希函数是一种加密原语，产生固定长度的输出，是其输入的浓缩表示（例如消息或其他数据）。输出比特数由哈希函数的设计决定。批准的哈希函数定义在 [FIPS 180]、[FIPS 202] 和 [SP 800-232] 中。此外，[SP 800-175B] 提供了哈希函数如何工作的简要描述。

XOF 产生可以扩展到任何所需长度的输出（例如，在请求 XOF 执行时识别所需长度）。[FIPS 202] 和 [SP 800-232] 中规定了联邦政府使用的批准 XOF。

对于设计良好的哈希函数或 XOF，构造或找到将产生给定哈希值的输入是不可行的（即原像抗性），找到产生相同哈希值的两个输入也是不可行的（即碰撞抗性）。

许多提供安全服务的算法和方案使用哈希函数或 XOF 作为算法的组件（即使用哈希方法作为算法或方案的构建块）来：

• 使用 MAC 提供源和完整性身份认证服务（参见第 3.2 节第 2 项），
• 从预共享密钥导出密钥（参见第 3.2 节第 3 项），
压缩消息以进行数字签名生成和验证（参见第 3.3 节第 1 项），
• 使用非对称密钥建立算法导出密钥（参见第 3.3 节第 2 项），或
• 生成随机数（参见第 3.4 节）。

3.2. 对称密钥算法

对称密钥算法（有时称为密钥算法）以在不知道密钥的情况下从根本上难以撤销的方式转换数据。密钥是"对称的"，因为相同的密钥用于加密操作及其逆操作（例如用于加密和解密）。对称密钥通常由多个实体知晓。然而，密钥应使用随机过程生成，且不应向无权访问由该算法和密钥保护的数据的实体披露。

已批准三类对称密钥算法：基于分组密码算法的算法（例如 [FIPS 197] 中规定的 AES）、基于置换的算法（例如 [SP 800-232] 中规定的 Ascon-AEAD128）以及基于使用哈希函数或 XOF 的算法（例如 [SP 800-224] 中规定的密钥哈希 MAC）。[SP 800-175B] 提供了对每种算法类型的讨论以及与分组密码算法一起使用的操作模式。

对称密钥算法可用于：

提供数据机密性 — 相同的密钥用于加密和解密数据（参见 [FIPS 197]、[SP 800-38A]、[SP 800-38C]、[SP 800-38D] 和 [SP 800-232]）。
提供源和完整性身份认证服务，形式为 MAC — 相同的密钥用于生成 MAC 并验证它。MAC 通常使用对称密钥算法或加密哈希函数作为其加密原语（参见 [SP 800-38B] 中规定的 CMAC、[SP 800-224] 中使用哈希函数的 HMAC 以及 [SP 800-185] 中规定的 KMAC）。

使用密钥导出方法从预共享密钥导出密钥材料（例如参见 [SP 800-108]）
在非对称密钥建立方案使用期间从共享密钥导出密钥（参见 [SP 800-56C]）
• 使用密钥包装算法包装密钥（参见 [FIPS 197] 和 [SP 800-38F]）
• 生成随机数（参见第 3.4 节）

3.3. 非对称密钥算法

非对称密钥算法（通常称为公钥算法）使用两个相关密钥（即密钥对）来执行其功能：公钥和私钥。公钥可能为任何人所知，而私钥应由"拥有"密钥对的实体唯一控制。[7] 即使密钥对的公钥和私钥相关，也不能使用公钥的知识来确定私钥。非对称算法可用于：

以数字签名形式提供源、身份和完整性身份认证服务，或
• 使用密钥建立方案建立加密密钥材料。

数字签名由私钥所有者生成，可以由拥有相应公钥的任何方验证。批准的数字签名算法在 [FIPS 186-5]、[FIPS 204]、[FIPS 205] 和 [SP 800-208] 中规定。

使用非对称密钥算法的批准密钥建立方案在 [SP 800-56A]、[SP 800-56B] 和 [FIPS 203] 中规定。此外，[[SP 800-175B] 讨论了使用非对称密钥算法生成数字签名和建立密钥材料。

3.4. 随机比特生成

随机比特生成器 (RBG)[8] 是生成密钥材料（例如密钥和初始化向量 (IV)）所必需的。RBG 生成随机比特序列（例如 010011）；从技术上讲，RNG 将这些比特转换为数字（例如 010011 转换为数字 19）。然而，术语"随机数生成器"(RNG) 通常用于指代这两个概念。RBG 的使用在 [SP 800-175B] 中讨论，批准的 RBG 在 SP 800-90 系列文档（即 [SP 800-90A]、[SP 800-90B] 和 [SP 800-90C]）中规定。

4. 通用密钥管理指南

本节根据用途对不同类型的密钥和其他加密信息进行分类；讨论密码周期并为每种密钥类型建议适当的密码周期；为其他密钥材料提供建议和要求；介绍域参数有效性、公钥有效性和私钥占有的保证；讨论密钥材料泄露的影响；并根据其安全强度为加密算法和密钥大小的选择、实施和替换提供指南。

4.1. 密钥类型和其他信息

有几种不同类型的加密密钥，每种用于不同的目的。然而，一些算法可以用于几种不同的目的，因此下面针对每种目的单独列出密钥。此外，还有其他与加密算法和密钥具体相关的信息。这些密钥的生成在 [SP 800-133] 中讨论。

4.1.1. 加密密钥

下面定义了几种不同类型的密钥。密钥根据其分类为公钥、私钥或对称（即密钥）密钥进行标识，并指示其用途。有关每种密钥类型所需的保护，请参见第 5.1.1 节中的表 8。

• 数字签名 [FIPS 186-5][FIPS 204][FIPS 205][SP 800-208]：

1. 私签名密钥：私签名密钥是非对称密钥（公钥）对的私钥组件，由公钥算法用于生成数字签名。当适当处理时，私签名密钥可用于提供消息、文档和存储数据的源身份认证、完整性身份认证和不可否认性。

2. 公签名验证密钥：公签名验证密钥是非对称密钥（公钥）对的公钥组件，由公钥算法用于验证使用相应私签名密钥签名的数字签名。

• 身份认证密钥：

3. 对称身份认证密钥：对称身份认证密钥与对称密钥算法一起使用，为通信会话、消息、文档和存储数据提供身份身份认证和完整性身份认证。对于对称密钥算法的认证加密操作模式，单个密钥用于身份认证和加密模式。参见 [SP 800-38B]、[SP 800-38C]、[SP 800-38D]、[SP 800-185]、[SP 800-224] 和 [SP 800-232]。
4. 私身份认证密钥：私身份认证密钥是非对称密钥（公钥）对的私钥组件，与公钥算法一起使用，在建立认证通信会话或授权执行某些操作时提供实体身份的保证（即身份身份认证）。[9] 参见 [FIPS 186-5]、[FIPS 204]、[FIPS 205] 和 [SP 800-208]。
5. 公身份认证密钥：公身份认证密钥是非对称密钥（公钥）对的公钥组件，与公钥算法一起使用，在建立认证通信会话或授权执行某些操作时验证实体的身份（即身份身份认证）。[10]

• 随机比特/数生成密钥：

6. 对称随机数生成密钥：此密钥用于生成随机数或随机比特。参见 SP 800-90 系列。
密钥导出：
7. 对称密钥导出密钥：对称密钥导出密钥（在某些环境中称为主密钥）用于使用对称加密方法导出其他对称密钥（例如数据加密密钥、密钥包装密钥）。参见 [SP 800-108] 和 [SP 800-135]。
• 密钥建立（自动化）：
8. 对称密钥包装密钥：对称密钥包装密钥（有时称为密钥加密密钥）与对称密钥算法一起使用来加密（即包装）其他密钥。用于加密密钥的密钥包装密钥也用于反转加密操作（即解密/解包加密密钥）。根据与其一起使用的算法，密钥还可用于提供完整性保护。参见 [SP 800-38F]。
9. 公密钥传输密钥：公密钥传输密钥是非对称密钥（公钥）对的公钥组件，用于使用公钥算法加密密钥。公密钥传输密钥用于建立（即安全分发）对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。参见 [SP 800-56B]。
10. 私密钥传输密钥：私密钥传输密钥是非对称密钥（公钥）对的私钥组件，用于使用公钥算法解密已使用相应公密钥传输密钥加密的密钥。参见 [SP 800-56B]。
11. 对称密钥协商密钥：此对称密钥用于使用对称密钥协商算法建立对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。目前 NIST 没有批准的对称密钥协商方法。
12. 公静态密钥协商密钥：公静态密钥协商密钥是非对称密钥（公钥）对的长期公钥组件，用于建立对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。参见 [SP 800-56A] 和 [SP 800-56B]。
13. 私密态密钥协商密钥：私密态密钥协商密钥是非对称密钥（公钥）对的长期私钥组件，用于建立对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。参见 [SP 800-56A] 和 [SP 800-56B]。
14. 公临时密钥协商密钥：公临时密钥协商密钥是非对称密钥对的公钥组件，在单个密钥建立事务中用于建立一个或多个对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。参见 [SP 800-56A]。
15. 私临时密钥协商密钥：私临时密钥协商密钥是非对称密钥（公钥）对的私钥组件，在单个密钥建立事务中用于建立一个或多个对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。参见 [SP 800-56A]。
16. 公静态封装密钥：公静态封装密钥是非对称密钥（公钥）对的长期公钥组件，在多个密钥建立事务的封装过程中用于封装对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）。参见 [FIPS 203] 和 [SP 800-227]。
17. 私静态解封密钥：私静态解封密钥是非对称密钥（公钥）对的长期私钥组件，在多个密钥建立事务中用于解封使用相应公静态封装密钥封装的对称密钥。参见 [FIPS 203] 和 [SP 800-227]。
18. 公临时封装密钥：公临时封装密钥是非对称密钥对的公钥组件，在单个密钥建立事务中用于封装对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）。参见 [FIPS 203] 和 [SP 800-227]。

19. 私临时解封密钥：私临时解封密钥是非对称密钥（公钥）对的私钥组件，在单个密钥建立事务中用于解封使用相应公临时封装密钥封装的对称密钥。参见 [FIPS 203] 和 [SP 800-227]。

• 密钥存储（用于运行、备份和归档存储）：

20. 对称密钥包装密钥：对称密钥包装密钥（有时称为密钥加密密钥）与对称密钥算法一起使用来包装（即加密和保护完整性）其他密钥以进行存储（例如用于包装密钥的密钥包装密钥也用于解包被包装的密钥）。根据与其一起使用的算法，密钥还可用于提供完整性保护。参见 [SP 800-38F]。
21. 公密钥包装密钥：公密钥包装密钥是非对称密钥（公钥）对的公钥组件，用于使用公钥算法包装（即加密和保护完整性）密钥。此密钥用于存储对称密钥（例如密钥包装密钥、数据加密密钥、MAC 密钥）以及可选的其他密钥材料（例如 IV）。RSA 算法可用于此目的，但目前没有 NIST 出版物专门讨论此用途。
22. 私密钥拆封密钥：私密钥拆封密钥是非对称密钥（公钥）对的私钥组件，用于使用公钥算法拆封（即解密和验证完整性）已使用相应公密钥包装密钥包装的密钥。目前没有 NIST 出版物专门讨论此用途。
23. 公封装密钥：公封装密钥通常是非对称密钥（公钥）对的长期公钥组件，在封装过程中用于封装对称密钥以进行存储（例如密钥包装密钥、数据加密密钥、MAC 密钥）。参见 [FIPS 203]。
24. 私解封密钥：私解封密钥是非对称密钥（公钥）对的私钥组件，用于解封使用相应公封装密钥封装的对称密钥。参见 [FIPS 203]。

• 授权：

25. 对称授权密钥：对称授权密钥用于使用对称加密方法向实体提供特权。授权密钥由负责监控和授予授权实体访问特权的实体以及寻求访问资源的实体共同知晓。目前没有 NIST 出版物专门讨论此用途。
26. 私授权密钥：私授权密钥是非对称密钥（公钥）对的私钥组件，用于证明所有者的特权权利（例如使用数字签名）。参见 [FIPS 186-5]、[FIPS 204]、[FIPS 205] 和 [SP 800-208]。目前没有 NIST 出版物专门讨论此用途。
27. 公授权密钥：公授权密钥是非对称密钥（公钥）对的公钥组件，用于验证知道相关私授权密钥的实体的特权。参见 [FIPS 186-5]、[FIPS 204]、[FIPS 205] 和 [SP 800-208]。目前没有 NIST 出版物专门讨论此用途。

4.1.2. 其他相关信息

与加密算法和密钥结合使用的其他信息也需要保护。有关每种类型信息所需的保护，请参见第 5.1.2 节中的表 6。要保护的信息可能包括：

算法参数：算法参数与某些算法一起使用来生成密钥、创建数字签名或建立密钥材料。对于椭圆曲线算法，算法参数称为域参数。参见 [FIPS 186-5]、[SP 800-56A]、[FIPS 203]、[FIPS 204]、[FIPS 205]、[SP 800-208] 和 [SP 800-232]。
初始化向量：IV 由分组密码算法的几种操作模式用于加密、解密和 MAC 计算。参见第 4.2 节。
共享密钥：共享密钥[11] 在密钥协商过程中生成，不适合作为密钥使用。参见 [SP 800-56A] 和 [SP 800-56B]。
种子：

o 种子用于生成确定性随机比特（例如用于生成必须保持秘密或私有的密钥材料）。参见 SP 800-90 系列。
o 种子在根据算法规范生成密钥材料期间使用。参见 [FIPS 203]、[FIPS 204]、[FIPS 205] 和 [SP 800-208]。

其他公开信息：公开信息（例如 nonce）经常用于密钥建立和密钥确认过程。
其他秘密信息：秘密信息可能包含在 RBG 的种子或密钥材料的建立中。参见 [SP 800-56A]、[SP 800-56B]、SP 800-90 系列和 [SP 800-108]。
中间结果：加密操作中的中间结果通常需要保护。
密钥控制信息/元数据：与密钥材料相关的信息（例如密钥标识符、密钥的预期用途或计数器）必须受到

保护，以确保可以正常确使用相关的密钥材料。密钥控制信息包含在与密钥材料相关联的元数据中（参见第 5.2.3 节）。

• 随机比特（或数字）：RBG 创建的随机比特。参见 SP 800-90 系列。
密码：密码用于获取访问特权，并可用作源身份认证或身份身份认证机制中的凭证。密码还可用于导出加密密钥，用于保护和访问存储中的数据。参见 [SP 800-132]。
• 审计信息：审计信息包含密钥管理事件的记录。

4.2. 密钥使用

一般来说，单个密钥应仅用于一个目的（例如加密、完整性身份认证、密钥包装、随机比特生成或数字签名）。这样做有几个原因：

对两个不同的加密过程使用相同的密钥可能会削弱一个或两个过程提供的安全性。
限制密钥的用途可以限制密钥泄露时可能造成的损害。
密钥的某些用途会相互干扰。例如，考虑一个 RSA 密钥对同时用于密钥传输和数字签名。在这种情况下，私钥既用作私密钥传输密钥来解密加密密钥，又用作私签名密钥来生成数字签名。可能需要将用于密钥传输的私钥保留到相应公钥的密码周期之外，以解密访问加密数据所需的加密密钥。用于签名生成的私钥需要在密码周期结束时销毁以防止其泄露（参见第 4.3.6 节）。在此示例中，私密钥传输密钥和私数字签名密钥的寿命要求相互矛盾。

这一原则并不排除在相同过程可以提供多种服务时使用单个密钥。例如，当数字签名使用单个数字签名提供完整性身份认证和源身份认证时，或者当单个对称密钥可用于在单个加密操作中加密和认证数据时（例如使用认证加密操作而不是单独的加密和身份认证操作）（参见第 2.7 节）。

本建议允许使用私密钥传输或密钥协商密钥来生成数字签名，当请求根据 [FIPS 186-5] 生成的静态密钥建立密钥的（初始）证书时（参见 [SP 800-56A]、[SP 800-56B] 和第 7.1.5.1.1.2 节）。

4.3. 密码周期

密码周期是特定密钥被授权由合法实体使用的时间跨度，或给定系统的密钥将保持有效的时间。适当定义的密码周期：

限制可用于密码分析以揭示密钥的信息量（例如用密钥加密的明文和密文对的数量）；
• 限制如果单个密钥泄露时的暴露量；
• 限制特定算法的使用（例如限制为其估计的有效寿命）；
限制可用于渗透保护密钥免受未经授权披露的物理、程序和逻辑访问机制的时间；
限制信息可能因加密密钥无意中泄露给未经授权的实体而受到损害的时间段；以及
• 限制可用于计算密集型密码分析的时间。

密码周期有时由任意时间段或密钥保护的最大数据量定义。然而，与密码周期确定相关的权衡涉及暴露的风险和后果，在选择密码周期时应仔细考虑（参见第 4.3.4 节）。如果密钥泄露，其密码周期将不再被视为有效。有关处理泄露密钥的讨论，请参见第 4.5 节。

4.3.1. 影响密码周期的因素

一些影响密码周期长度的因素包括：

加密机制的强度（例如算法、密钥长度、分组大小或操作模式）
机制的体现（例如 [FIPS 140-3] 4 级实施或个人电脑上的软件实施）
• 操作环境（例如安全有限访问设施、开放办公环境或公开可访问的终端）
• 人员流动（例如系统管理员和 CA 系统人员）
• 数据流量或交易数量
• 数据的安全寿命
算法使用所需的限制（例如避免 nonce 重复使用的最大调用次数）
• 安全功能（例如数据加密、数字签名、密钥导出或密钥保护）

重新密钥方法（例如键盘输入、使用人类无法直接访问密钥的密钥加载设备重新密钥，或在 PKI 内远程重新密钥）
• 使用的重新密钥或密钥导出过程
• 网络中共享公共密钥的节点数量
• 密钥副本的数量及其分发
• 来自对手的信息威胁（例如其感知到的技术能力和发动攻击的财务资源）
• 来自新技术的信息威胁（例如量子计算机）

一般来说，短密码周期增强安全性。例如，如果对手只有有限数量的信息在单个密钥下加密，某些加密算法可能较不容易受到密码分析的攻击。然而，当手动密钥分发方法受制于人为错误和弱点时，更频繁的密钥更改实际上可能会增加密钥暴露的风险。在这些情况下，特别是在硬件中采用非常强的加密时，可能更明智的是进行较少、控制良好的手动密钥分发，而不是更频繁、控制不佳的手动密钥分发。

当采用强加密时，访问保护的物理、程序和逻辑考虑通常比算法和密钥大小因素对密码周期选择有更大影响。当使用批准的算法、操作模式和密钥大小时，对手可能能够通过渗透或破坏系统来访问密钥，所需时间和资源少于执行密码分析攻击所需的时间和资源。

4.3.2. 影响密码周期的后果因素

暴露的后果通过受加密保护的信息的敏感性、受加密保护的过程的关键性以及从信息或过程泄露中恢复的成本来衡量。敏感性是指受保护信息的寿命（例如 10 分钟、10 天或 10 年）以及该信息保护丢失的潜在后果（例如信息泄露给未经授权的实体）。一般来说，随着信息敏感性或受加密保护过程关键性的增加，相关密码周期的长度应减少，以限制每次泄露可能造成的损害。这受制于重新密钥或密钥导出过程的安全性和完整性的警告（参见第 7.2.3 和 7.2.4 节）。然而，短密码周期可能适得其反，特别是当拒绝服务是首要关注点且重新密钥或密钥导出过程中存在重大错误可能性时。

4.3.3. 影响密码周期的其他因素

4.3.3.1. 通信与存储

用于保护通信交换机密性的密钥通常可能比用于保护存储数据的密钥具有更短的密码周期。存储数据的密码周期通常更长，因为生成新密钥并重新加密所有使用旧密钥加密的数据的开销可能很繁重。

4.3.3.2. 密钥撤销和替换的成本

在某些情况下，更改密钥相关的成本高得令人痛苦。示例包括解密和随后重新加密非常大或分布式的数据库，以及撤销和替换大量密钥（例如有大量地理和组织上分布的密钥持有者）。在这种情况下，支持更长密码周期所需的安全措施的费用可能是合理的。在其他情况下，密码周期可能比否则需要的更短（例如限制密钥管理系统维护状态信息的时间段）。

4.3.4. 非对称密钥使用周期和密码周期

对于非对称密钥密钥对，密钥对的每个密钥都有自己的密码周期。密钥对的一个密钥用于应用加密保护（例如创建数字签名）。密钥对的另一个密钥用于处理受保护的信息（例如验证数字签名）。两个密码周期通常同时开始，但其中一个密码周期可能需要比另一个更长。例如：

在数字签名密钥对的情况下，私签名密钥用于签名数据（即应用加密保护），公签名验证密钥用于验证数字签名（即处理已受保护的信息）。

对于用作来源证明（即源身份认证）生成数字签名的私签名密钥，私钥的密码周期可能比相应公签名验证密钥的密码周期短。在这种情况下，私钥旨在在固定时间段内使用，之后密钥所有者应销毁[12] 私钥。公钥可能在更长时间内可用于验证签名。

用于签名挑战信息的私源身份认证密钥的密码周期基本上与相应公钥（即公源身份认证密钥）的密码周期相同。也就是说，当私钥不再用于签名挑战时，公钥不再需要。

对于密钥传输密钥，公密钥传输密钥用于应用保护（即加密密钥），私密钥传输密钥用于解密密文密钥。公密钥传输密钥可用于加密的密码周期可能比用于解密密文密钥的相应私密钥传输密钥的密码周期短。
对于密钥封装机制 (KEM)，预期接收者的公封装密钥由发送实体用于封装发送实体生成的密钥，然后将生成的密文发送给预期接收者。接收者相应的私解封密钥随后用于解封接收的密文。私解封密钥的密码周期可能需要比相应封装密钥的密码周期更长。
对于密钥协商算法，密钥对的两个密钥的密码周期通常相同，尽管有例外。例如，对于 [SP 800-56B] 中的 KAS1 方案，接收者的公钥用于加密由方案发起者发送给接收者的密钥材料。接收者随后使用相应的私钥解密接收的密文密钥材料。接收者私钥的密码周期可能需要比相应公钥的密码周期更长。

当公钥分布在公钥证书中时，证书通常包括公钥的有效期，由证书中的 notBefore 和 notAfter 日期指示。证书可以续期（例如，包含相同公钥的新证书可以颁发新的有效期）。原始证书和同一公钥的所有续期证书涵盖的时间范围不应超过公钥的密码周期。有关特定密钥类型的指南，请参见第 4.3.6 节。

4.3.5. 对称密钥使用周期和密码周期

对于对称密钥，单个密钥既用于应用保护（例如加密或计算数据的 MAC）又用于处理受保护的信息（例如解密加密数据或验证 MAC）。可以对数据应用加密保护的时间段称为发起者使用周期，处理受保护信息的时间段称为接收者使用周期。对称密钥在发起者使用周期结束后不得用于提供保护。接收者使用周期可以延伸到发起者使用周期之外（参见图 1）。这允许发起者保护的信息在应用保护后由接收者处理延长的时间段。然而，在许多情况下，发起者和接收者使用周期是相同的。对称密钥的总"密码周期"是从发起者使用周期开始到接收者使用周期结束的时间段（参见图 1），尽管发起者使用周期在历史上一直被用作密钥的密码周期。

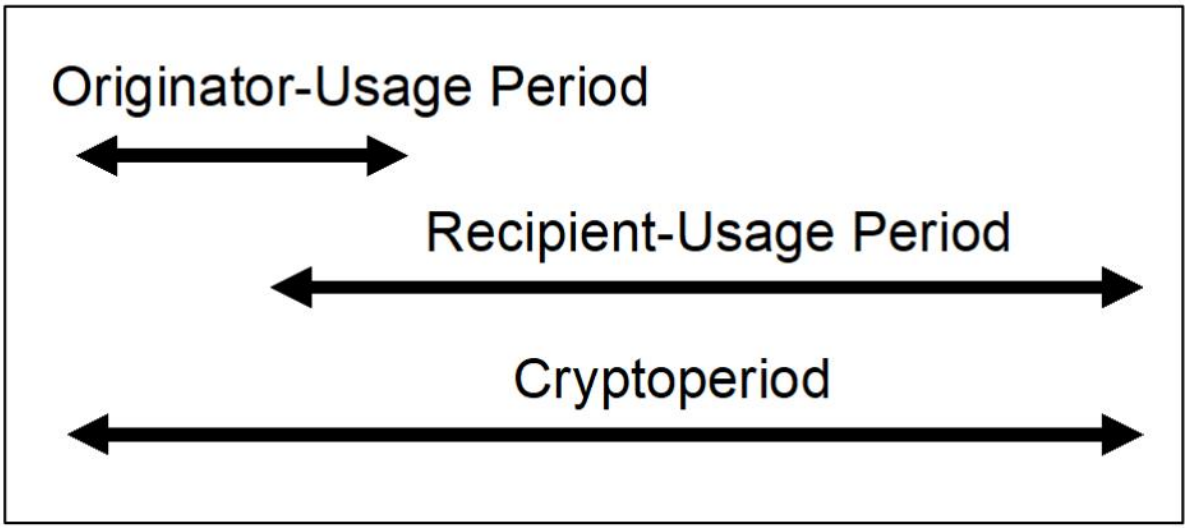

图 1. 对称密钥密码周期

在某些情况下，预定密码周期可能不足以满足受保护数据的安全寿命。如果所需的安全寿命超过密码周期，则可能需要使用新密钥重新应用保护。

对称密钥使用周期的示例包括：

当对称密钥仅用于保护通信时，从发起者应用保护到接收者处理的时间段可以忽略不计。在这种情况下，密钥在整个密码周期内被授权用于任一目的（即发起者使用周期和接收者使用周期相同）。
当对称密钥用于保护存储信息时，发起者使用周期（即发起者对存储信息应用加密保护时）可能比接收者使用周期（即处理存储信息时）早得多结束。在这种情况下，密码周期从授权用密钥应用保护的初始时间开始，到授权用该密钥处理的最新时间结束。一般来说，存储信息的接收者使用周期将继续超过发起者使用周期，以便存储信息可以在以后时间进行身份认证或解密。
当对称密钥用于保护存储信息时，接收者使用周期可能在发起者使用周期开始之后开始，如图 1 所示。例如，信息在存储在某些存储介质之前可能被加密。在稍后时间，可以分发密钥以解密和恢复信息。

4.3.6. 特定密钥类型的密码周期建议

上述密钥类型、使用环境和数据特征可能会影响给定密钥所需的密码周期。本文档为各种密钥类型建议密码周期作为时间长度。密码周期的其他度量（例如每个密钥用于给定加密算法保护信息的次数）可能需要适当调整。建议的密码周期更多地基于密钥访问机制的有效性，而不是使用密钥的加密机制的强度。例如，分配一年密码周期与两年周期的比较主要是出于这样的担忧：未经授权的物理或逻辑访问密钥在两年内比在一年内更可能发生。

建议的密码周期只是粗略的数量级指南。根据机密性或完整性泄露的后果、支持的应用以及密钥将使用的环境，可能需要更长或更短的密码周期。在分配更长密码周期时，应认真考虑与此相关的风险（参见第 4.3.1 节）。大多数建议的密码周期基于支持最大操作效率和对使用环境最低安全标准的假设（参见 [FIPS 140-3] 和 [SP 800-37]）。

第 4.3.1 至 4.3.3 节中描述的因素应用于确定特定使用环境的实际密码周期。给定批准的算法和受保护信息的适当密钥大小，每种密钥类型的建议密码周期如下：

• 数字签名

1. 私签名密钥

类型考虑：一般来说，私签名密钥的密码周期可能比相应公签名验证密钥的密码周期短。当相应公钥已由 CA 认证时，私签名密钥的密码周期不晚于为公钥颁发的最后一个证书上的 notAfter 日期结束。[13]

密码周期：鉴于预期密钥存储和使用环境的安全性将随着密钥提供完整性保护的过程的敏感性和/或关键性增加而增加，建议最大密码周期约为一到三年。私签名密钥应在其密码周期结束时销毁。

2. 签名验证密钥

类型考虑：一般来说，公签名验证密钥的密码周期可能比相应私签名密钥的密码周期长。密码周期实际上是使用相应私签名密钥计算的任何签名需要验证的时间段。公签名验证密钥比私签名密钥更长的密码周期带来的安全关注相对较小。

密码周期：密码周期可能比相应私签名密钥的密码周期长数年。然而，由于保护机制长期暴露于敌对攻击，签名验证的可靠性随着时间的推移而降低。也就是说，对于任何给定算法和密钥大小，预计对密码分析的脆弱性将随着时间的推移而增加。虽然选择可用的最强算法和大密钥大小可以最小化这种对密码分析的脆弱性，但暴露于对私钥的物理、程序和逻辑访问控制机制攻击的后果不受算法选择的影响。

某些系统使用加密时间戳功能为每个签名消息放置不可伪造的时间戳。即使私签名密钥的密码周期已过期，相应的公签名验证密钥仍可用于验证时间戳在私签名密钥密码周期内的消息上的签名。在这种情况下，人们依赖加密时间戳功能来提供消息在私签名密钥密码周期内签名的保证。

• 身份认证密钥

3. 对称身份认证密钥

类型考虑：对称身份认证密钥[14] 的密码周期取决于受保护信息类型的敏感性和密钥及相关算法提供的保护。对于非常敏感的信息，身份认证密钥可能需要对受保护信息是唯一的。对于不太敏感的信息，合适的密码周期可以超过密钥的单次使用。对称身份认证密钥的发起者使用周期适用于使用该密钥为信息应用原始加密保护（例如计算 MAC）。在发起者使用周期结束后，不得使用该密钥在信息上计算新的 MAC。然而，密钥可能需要在发起者使用周期之外可用于验证受保护数据上的 MAC（即接收者使用周期可能延伸到发起者使用周期之外）。接收者使用周期是在发起者使用周期期间生成的 MAC 需要验证的时间段。然而，如果 MAC 密钥泄露，对手可能能够修改数据然后重新计算 MAC。

密码周期：鉴于预期密钥存储和使用环境的安全性将随着密钥提供完整性保护的过程的敏感性和/或关键性增加而增加，建议发起者使用周期不超过两年。接收者使用周期不应延伸到发起者使用周期结束后的三年以上。

4. 私身份认证密钥

类型考虑：私身份认证密钥可用于多个数据完整性过程和身份身份认证事件。在大多数情况下，私身份认证密钥的密码周期与相应公钥的密码周期相同。

密码周期：私身份认证密钥的适当密码周期应不超过一到两年，具体取决于其使用环境和身份认证信息的敏感性/关键性。

5. 公身份认证密钥

类型考虑：密码周期实际上是使用相应私身份认证密钥保护的信息发起者身份需要验证（即身份需要身份认证）的时间段。[15]

密码周期：在大多数情况下，公身份认证密钥的密码周期与相应私身份认证密钥的密码周期相同。

• 随机比特/数生成密钥

6. 对称随机数生成密钥

类型考虑：对称 RBG 密钥用于确定性随机比特生成功能。SP 800-90 系列中批准的 RBG 控制密钥更改（例如在重新种子期间）。密码周期仅包括此密钥类型的发起者使用周期。

密码周期：假设使用批准的 RBG，对称 RBG 密钥的最大密码周期由 RBG 的设计决定（参见 SP 800-90 系列）。

密钥导出

7. 对称密钥导出密钥/主密钥

类型考虑：对称密钥导出密钥（在某些环境中也称为主密钥）可多次使用（单向）密钥导出函数或方法导出其他密钥（参见第 7.2.4 节）。因此，此密钥类型的密码周期仅包括发起者使用周期。合适的密码周期取决于导出密钥的性质和使用以及第 4.3 节中提供的考虑因素。从密钥导出密钥导出的密钥的密码周期可能相对较短（例如仅用于单次使用、通信会话或交易）。或者，密钥导出密钥可以在更长时间内使用来为相同或不同目的导出（或重新导出）多个密钥。导出密钥的密码周期取决于其用途（例如用于对称数据加密或完整性身份认证）。

密码周期：对称密钥导出密钥的适当密码周期可能为一年，具体取决于其使用环境、导出密钥保护的信息的敏感性/关键性以及从密钥导出密钥导出的密钥数量。

密钥建立（自动化）

8. 对称密钥包装/拆封密钥

类型考虑：用于在短时间内包装（即加密和完整性保护）大量密钥的对称密钥包装密钥应具有相对较短的发起者使用周期。如果包装的密钥数量较少，密钥包装密钥的发起者使用周期可能更长。对称密钥包装密钥的发起者使用周期适用于使用该密钥为密钥提供密钥包装保护。在密钥包装密钥的发起者使用周期已过期后，不得使用密钥包装密钥执行包装操作。然而，密钥包装密钥可能需要在发起者使用周期之外可用于拆包受保护的密钥（即解密和验证包装密钥的完整性）（即接收者使用周期可能需要延伸到发起者使用周期之外）。接收者使用周期是在密钥包装密钥的发起者使用周期期间包装的密钥可能需要拆包的时间段。

某些对称密钥包装密钥仅用于单个消息或通信会话。在这些非常短期的密钥包装密钥的情况下，适当的密码周期是单个通信会话（即包括发起者和接收者使用周期）。如果包装的密钥不以其包装形式保留，则密钥包装密钥的发起者使用周期和接收者使用周期相同。在其他情况下，可以保留（即存储）密钥包装密钥，以便以后可以恢复由包装密钥加密的文件或消息。在这种情况下，接收者使用周期可能比密钥包装密钥的发起者使用周期长得多，并且可以采用持续数年的密码周期。

密码周期：建议用于在短时间内包装大量密钥的对称密钥包装密钥的发起者使用周期约为一天或一周。如果要在密钥包装密钥下包装相对较少数量的密钥，则密钥包装密钥的发起者使用周期可能长达两年。在仅用于单个消息或通信会话的密钥包装密钥的情况下，密码周期将限制为单个通信会话。建议接收者使用周期延伸到发起者使用周期结束后不超过三年。

9. 公密钥传输密钥

类型考虑：公密钥传输密钥的密码周期是公钥可用于对将在传输期间保护的密钥应用加密操作的时间段（即通过自动化在线分发）。当公钥已由 CA 认证时，公钥的密码周期在为公钥颁发的最后一个证书达到 notAfter 日期时结束。

公密钥传输密钥可以公开知晓。由于可能需要在密钥加密传输后解密密钥，公密钥传输密钥的密码周期可能比相应私密钥传输密钥的密码周期短。

密码周期：基于相应私密钥的密码周期假设，建议公密钥传输密钥的密码周期不超过一到两年。

10. 私密钥传输密钥

类型考虑：私密钥传输密钥可多次使用来解密密钥。由于可能需要在密钥加密传输后解密密钥，私密钥传输密钥的密码周期可能比相应公密钥传输密钥的密码周期长。私钥的密码周期是需要解密由相应公密钥传输密钥加密的任何密钥的时间长度。

密码周期：鉴于 1) 可能由相应公密钥传输密钥加密的密钥保护的信息量和 2) 预期密钥存储和使用环境的安全性将随着密钥提供保护的过程的敏感性和/或关键性增加而增加，建议私密钥传输密钥的密码周期不超过两年。在某些应用（例如电子邮件）中，接收的消息被存储并在稍后时间解密，私密钥传输密钥的密码周期可能超过公密钥传输密钥的密码周期。

11. 对称密钥协商密钥

类型考虑：对称密钥协商密钥可用于多个密钥协商事务。对称密钥协商密钥的密码周期取决于 1) 环境安全因素；2) 建立的密钥的类型、格式和数量；以及 3) 所用密钥协商算法和协议的细节。对称密钥协商密钥可用于建立对称密钥（例如对称数据加密密钥和 IV）。

密码周期：假设 1) 加密设备满足 [FIPS 140-3] 要求且 2) 风险级别已根据 [FIPS 199] 确定，对称密钥协商密钥的适当密码周期应不超过一到两年。在某些应用（例如电子邮件）中，接收的消息被存储以供稍后解密，密钥的接收者使用周期可能超过发起者使用周期。

12. 公静态密钥协商密钥

类型考虑：公静态密钥协商密钥可用于多个密钥协商事务。公静态密钥协商密钥的密码周期通常与相应私密态密钥协商密钥的密码周期相同。当公钥已由 CA 认证时，公钥的密码周期在为公钥颁发的最后一个证书达到 notAfter 日期时结束。

密码周期：公静态密钥协商密钥的密码周期可能为一到两年。

13. 私密态密钥协商密钥

类型考虑：私密态密钥协商密钥可用于多个密钥协商事务。

密码周期：此密钥的密码周期取决于 1) 环境安全因素；2) 建立的密钥的类型、格式和数量；以及 3) 密钥协商算法和协议的细节。私密态密钥协商密钥可用于建立对称密钥（例如密钥包装密钥）或其他秘密密钥材料。

假设 1) 加密设备满足 [FIPS 140-3] 要求且 2) 风险级别已根据 [FIPS 199] 确定，密钥的适当密码周期应不超过一到两年。虽然私密态和公静态密钥协商密钥的密码周期通常相同，但在某些应用（例如电子邮件）中，接收的消息被存储并在稍后时间解密，私密态密钥协商密钥的密码周期可能超过相应公静态密钥协商密钥的密码周期。

14. 公临时密钥协商密钥

类型考虑：公临时密钥协商密钥是非对称密钥对的公钥组件，在单个密钥协商事务中使用。

密码周期：公临时密钥协商密钥的密码周期在其用于生成用于导出密钥材料的共享密钥后立即结束。在某些情况下，公临时密钥协商密钥的密码周期对于密钥协商事务的参与者可能不同。例如，考虑一个加密电子邮件应用，其中电子邮件发送者生成临时密钥协商密钥对，然后使用密钥对生成用于加密内容加密密钥的密钥加密密钥。对于发送者，公钥的密码周期在生成共享密钥并导出密钥加密密钥时结束。然

而，对于电子邮件接收者，发送者临时公钥的密码周期直到电子邮件被删除才结束，因为每次读取电子邮件时都必须生成共享密钥并确定密钥加密密钥。

15. 私临时密钥协商密钥

类型考虑：私临时密钥协商密钥是非对称密钥对的私钥组件，在单个事务中用于建立一个或多个对称密钥（例如密钥包装密钥）或其他秘密密钥材料。

密码周期：私临时密钥协商密钥的密码周期用于生成共享密钥，之后私临时密钥应销毁。

16. 公静态封装密钥

类型考虑：公静态封装密钥的密码周期是公钥用于在多个密钥建立事务中生成和封装对称密钥以提供给静态封装/解封密钥对所有者的时间段。当公钥已由 CA 认证时，公钥的密码周期在为公静态封装密钥颁发的最后一个证书达到 notAfter 日期时结束。

密码周期：公静态封装密钥的密码周期取决于 1) 环境安全因素；2) 建立的密钥的类型、格式和数量；以及 3) 所用算法和协议的细节。假设 1) 加密设备满足 [FIPS 140-3] 要求且 2) 风险级别已根据 [FIPS 199] 确定，公静态封装密钥的适当密码周期应不超过一到两年。

17. 私静态解封密钥

类型考虑：私静态解封密钥由静态密钥对的所有者用于解封使用相应公静态封装密钥生成和封装的对称密钥。

密码周期：由于可能需要在执行收到密钥的建立事务后解封密钥，私静态解封密钥的密码周期可能需要比相应公静态封装密钥的密码周期更长。私静态解封密钥的密码周期是需要解封任何使用相应公钥生成和封装的密钥的时间长度。建议私静态解封密钥的密码周期不超过两年。

18. 公临时封装密钥

类型考虑：临时封装/解封密钥对由将执行解封的实体生成，公封装密钥提供给将执行封装的实体。封装实体在单个密钥建立事务中使用封装密钥来封装对称密钥以作为密文提供给解封实体（即临时密钥对的所有者）。

密码周期：公临时封装密钥的密码周期在其用于封装要发送给临时密钥对所有者的密钥后立即结束。

19. 私临时解封密钥

类型考虑：私临时解封密钥由临时封装/解封密钥对的所有者在单个密钥建立事务中用于解封在该事务期间接收的（密文）对称密钥。

密码周期：由于可能在使用相应公临时封装密钥的密钥建立事务后解封密钥，解封密钥的密码周期可能比相应公临时封装密钥的密码周期（即密钥建立事务的持续时间）更长。私临时解封密钥的密码周期是需要解封由相应公临时封装密钥封装的密钥的时间长度。私临时解封密钥应在使用后尽快销毁。

• 数据加密/解密密钥

20. 对称数据加密/解密密钥（用于传输中的数据）

类型考虑：对称数据加密密钥用于在通信会话期间保护传输中的数据和消息。主要基于泄露的后果，用于在短时间内加密大量数据的数据加密密钥（例如用于链路加密）应具有相对较短的发起者使用周期。用于随时间加密较少数据的加密密钥可能具有更长的发起者使用周期。对称数据加密密钥的发起者使用周期适用于使用该密钥加密信息（参见第 4.3.5 节）。

在发起者使用周期期间，可以使用数据加密密钥执行数据加密。在此周期之后，密钥不得用于对数据执行加密操作。然而，密钥可能需要在发起者使用周期之外可用于解密受保护的数据（即接收者使用周期可能需要延伸到发起者使用周期之外）。

密码周期：建议用于在短时间内加密大量数据（例如用于链路加密）的发起者使用周期约为一天或一周。用于加密较少数据量的加密密钥的发起者使用周期可能长达两年。建议接收者使用周期不超过发起者使用周期结束后的三年。

21. 对称数据加密/解密密钥（用于静态数据）

类型考虑：对称数据加密密钥可用于保护存储中的数据。对称数据加密密钥的发起者使用周期适用于使用该密钥加密信息以进行存储。接收者使用周期适用于在需要时检索和解密数据。此周期可能延长多年。

使用单个数据加密密钥加密的信息量应受到限制，以便密钥泄露不会暴露大量信息（例如限制为加密不超过单个文件或磁盘扇区；参见第 4.3 节）。

在建立接收者使用周期时，需要考虑数据需要可用和机密的时间长度。如果接收者使用周期非常长，则可能需要使用不同的数据加密密钥和/或更强的算法重新加密数据（参见第 4.6.5 节）。

密码周期：建议用于数据加密的发起者使用周期应以使用单个密钥加密的数据量来衡量，而接收者使用周期需要根据数据需要机密和/或可用的时间长度来设置。

• 密钥存储（用于运行、备份和归档存储）

22. 对称密钥包装/拆封密钥

类型考虑：对称密钥包装/拆封密钥用于保护存储中的一个或多个密钥（例如其他对称密钥或用于保护存储或通信的私非对称密钥）。对称密钥包装密钥的发起者使用周期适用于使用该密钥包装密钥。接收者使用周期适用于在需要时检索和拆包包装的密钥。此周期可能延长多年。

使用单个密钥包装密钥包装的密钥数量应受到限制，以便密钥泄露不会暴露大量包装的密钥（参见第 4.3 节）。

在建立接收者使用周期时，需要考虑包装密钥需要可用的时间长度（例如解密数据、拆包其他密钥、保护通信）。

密码周期：建议用于对称密钥包装/拆封密钥的发起者使用周期应以使用密钥包装密钥包装的密钥数量来衡量，而接收者使用周期需要根据包装密钥需要可用的时间长度来设置。

23. 公密钥包装密钥

类型考虑：公密钥包装密钥用于保护存储中的一个或多个密钥（例如对称密钥或用于保护存储或通信的私非对称密钥）。公密钥包装密钥的密码周期适用于使用该密钥包装密钥。使用单个密钥包装密钥包装的密钥数量应受到限制，以便密钥泄露不会暴露大量包装的密钥（参见第 4.3 节）。

密码周期：建议用于公密钥包装密钥的密码周期应以使用单个密钥包装密钥包装的密钥数量来衡量。

24. 私密钥拆封密钥

类型考虑：私密钥拆封密钥用于拆包存储中由相应公密钥包装密钥包装的密钥。此密钥的密码周期适用于在需要时检索和拆包包装的密钥。此周期可能延长多年。

在建立密码周期时，需要考虑包装密钥需要可用的时间长度（例如解密数据、拆包其他密钥、保护通信）。

密码周期：私密钥拆封密钥的密码周期需要根据包装密钥需要可用的时间长度来设置。

25. 公封装密钥

类型考虑：公封装密钥可用于为存储应用封装对称密钥（例如用于保护存储数据的数据加密/解密密钥或用于保护其他密钥的密钥包装密钥）。公封装密钥的密码周期适用于使用该密钥封装对称密钥。使用单个封装密钥封装的密钥数量应受到限制，以便密钥泄露不会暴露大量封装的密钥（参见第 4.3 节）。

密码周期：建议用于公封装密钥的密码周期应以使用该密钥封装的密钥数量来衡量。

26. 私解封密钥

类型考虑：私解封密钥由封装/解封密钥对的所有者用于解封使用相应公封装密钥封装的对称密钥。

密码周期：私解封密钥的密码周期可能需要比相应公封装密钥的密码周期更长。私解封密钥的密码周期是需要解封任何使用相应公钥封装的密钥的时间长度。

• 授权密钥

27. 对称授权密钥

类型考虑：对称授权密钥可根据受保护的资源和授权访问实体的角色在延长时间内使用。对于此密钥类型，发起者使用周期和接收者使用周期相同。建立对称授权密钥密码周期的主要考虑因素包括密钥的强度、加密方法的充分性以及密钥保护机制和程序的充分性。

密码周期：对称授权密钥的密码周期应不超过两年。

28. 私授权密钥

类型考虑：私授权密钥可根据受保护的资源和授权访问实体的角色在延长时间内使用。建立私授权密钥密码周期的主要考虑因素包括密钥的强度、加密方法的充分性以及密钥保护机制和程序的充分性。私授权密钥及其相应公钥的密码周期应相同。

密码周期：鉴于预期密钥存储和使用环境的安全性将随着授权过程的敏感性和关键性增加而增加，私授权密钥的密码周期应不超过两年。

29. 公授权密钥

类型考虑：公授权密钥是非对称密钥对的公钥元素，用于验证拥有相应私钥的实体的特权。

密码周期：公授权密钥的密码周期应不超过两年。

表 1 为每种密钥类型提供了建议的密码周期。根据密钥将使用的应用和环境，可能需要更长或更短的密码周期。然而，在分配更长密码周期时，应认真考虑与此相关的风险（参见第 4.3.1 节）。

表 1. 密钥类型的建议密码周期

密钥类型	密码周期	
	发起者使用周期 (OUP)	接收者使用周期
数字签名		
1. 私签名密钥	1 至 3 年	-
2. 公签名验证密钥	数年（取决于密钥大小）	
身份认证		
3. 对称身份认证密钥	≤ 2 年	≤ OUP + 3 年
4. 私身份认证密钥	1 至 2 年	
5. 公身份认证密钥	1 至 2 年	
随机比特生成		
6. 对称 RBG 密钥	参见 SP 800-90A	-
密钥导出		
7. 对称密钥导出密钥	约 1 年	-
密钥建立（自动化）		
8. 对称密钥包装/拆封密钥	≤ 2 年	≤ OUP + 3 年
9. 公密钥传输密钥	1 至 2 年	
10. 私密钥传输密钥	≤ 2 年[16]	
11. 对称密钥协商密钥	1 至 2 年[17]	
12. 公静态密钥协商密钥	1 至 2 年	
13. 私密态密钥协商密钥	1 至 2 年[18]	
14. 公临时密钥协商密钥	一次密钥协商事务	
15. 私临时密钥协商密钥	一次密钥协商事务	
16. 公静态封装密钥	1-2 年	
17. 私静态解封密钥	≤ 2 年[19]	
18. 公临时封装密钥	一次密钥建立事务	
19. 私临时解封密钥	一次密钥建立事务	
数据加密/解密		
20. 对称数据加密/解密密钥（传输中的数据）	≤ 2 年	≤ OUP + 3 年
21. 对称数据加密/解密密钥（静态数据）	限制为要加密的数据量	直到数据不再需要可用和/或机密

密钥存储（用于运行、备份和归档存储）		
22. 对称密钥包装/拆封密钥	限制为要包装的密钥数量	直到包装的密钥不再需要
23. 公密钥包装密钥	限制为要包装的密钥数量	
24. 私密钥拆封密钥	直到包装的密钥不再需要	
25. 公封装密钥	限制为要封装的密钥数量	
26. 私解封密钥	直到封装的密钥不再需要	
授权		
27. 对称授权密钥	≤ 2 年	
28. 私授权密钥	< 2 年	
29. 公授权密钥	< 2 年	

4.4. 保证

当密钥材料（例如密钥、IV 和算法参数）被存储或分发时，它可能通过未受保护的环境。在这种情况下，在使用密钥材料执行正常常加密操作之前需要特定的保证。

4.4.1. 完整性保证（完整性保护）

在使用所有密钥材料之前应获得完整性保证。

至少，应通过验证密钥材料具有适当的格式并来自授权来源来获得完整性保证。应通过正常确使用错误检测码、MAC 和数字签名来获得额外的完整性保证，以提供密钥材料自生成以来未发生变化的保证。例如，可以在存储的密钥信息上生成 MAC，以提供密钥信息在存储期间未发生变化的保证，并且 MAC 可以与密钥信息一起存储以便于访问。

4.4.2. 算法参数有效性保证

算法参数与某些算法一起使用来生成密钥、创建数字签名和建立密钥材料。无效的算法参数可能使使用算法的所有实体的所有预期安全性失效。[SP 800-89] 中提供了获得数字签名算

法参数有效性保证。[SP 800-89] 中提供了获得数字签名算法参数有效性保证的方法。[SP 800-56A] 中提供了获得有限域和椭圆曲线离散对数密钥协商算法参数有效性保证的方法。密钥封装的批准算法参数在相关算法规范中规定（例如 [FIPS 203] 用于 ML-KEM，[FIPS 204] 用于 ML-DSA）。如果公钥已由 CA 为这些算法认证，CA 可以在认证过程中获得此保证，用户可以通过验证证书来获得保证。

否则，密钥对所有者和任何依赖方负责获得保证。

4.4.3. 公钥有效性保证

在使用所有公钥之前应获得公钥有效性保证。

公钥有效性保证使用户相信公钥是正常确的。这减少了使用弱或损坏密钥的概率。无效的公钥可能导致预期安全性失效，包括操作的安全性（例如数字签名生成或密钥建立）、泄露所有者私钥的部分或全部信息，以及泄露与无效公钥组合的私钥的部分或全部信息（例如在执行密钥协商或公钥加密时）。获得公钥有效性保证的几种方法之一是实体验证公钥应具有某些数学属性。另一种方法是从受信任的第三方（例如 CA）获得保证，即受信任方已验证这些属性。

[SP 800-89] 中提供了获得 [FIPS 186-5]、[FIPS 204]、[FIPS 205] 和 [SP 800-208] 中规定的数字签名算法公钥有效性保证的方法。[SP 800-56A] 中提供了获得有限域和椭圆曲线离散对数密钥建立方案此保证的方法。[SP 800-56B] 中提供了获得 RSA 密钥建立方案（部分）公钥有效性保证的方法。KEM 公钥有效性的获得方法在相关算法规范中讨论（例如 [FIPS 203] 用于 ML-KEM）。

4.4.4. 私钥占有保证

在使用相应静态公钥之前应获得静态（即长期）私钥占有保证。在获得私钥占有保证之前或同时应始终获得公钥有效性保证。密钥对所有者应获得正常确私钥占有的保证（例如确保其可用且在使用前未被修改）。接收公钥的实体应获得密钥对所有者拥有与接收公钥相对应的私钥的保证。

有关私密钥建立密钥占有保证的具体细节，请参见 [SP 800-56A]、[SP 800-56B] 和 [SP 800-227]。有关私数字签名密钥占有保证的具体细节，请参见 [SP 800-89]。对于由 CA 认证的公钥，CA 可以在认证过程中获得此保证。否则，所有者和依赖方负责获得保证。

4.4.5. 密钥确认

密钥建立是密钥材料在实体之间安全建立以供后续使用的过程，通常在成对实体之间。密钥确认是用于提供这些实体实际共享相同密钥材料的保证的过程。强烈建议此过程，可以在密钥建立过程中或密钥建立过程之外执行。有关在自动化密钥建立期间执行密钥确认的讨论，请参见 [SP 800-56A]、[SP 800-56B] 和 [SP 800-227]。

4.5. 密钥和其他密钥材料的泄露

受加密机制保护的信息仅在算法保持强大且密钥未泄露时才是安全的。私非对称密钥或秘密对称密钥的所有者有责任保护该密钥的机密性。当密钥的保护机制失效时（例如密钥的机密性、完整性或与其所有者的关联失效；参见第 5 节），密钥不再可信以提供所需的安全性，就会发生密钥泄露。任何怀疑密钥已泄露的人都有责任报告可能的密钥泄露（例如密钥所有者观察到由该密钥保护的数据已泄露）。

当密钥泄露时，应停止使用该密钥对信息应用加密保护（例如计算数字签名或加密信息）的所有使用，并应撤销泄露的密钥（参见第 7.3.5 节）。然而，在受控情况下继续使用该密钥来移除或验证保护（例如解密或验证数字签名）可能是合理的，具体取决于继续使用的风险和组织密钥管理策略（参见 [SP 800-57p2]）。泄露密钥的继续使用应限于处理已受保护的信息。在这种情况下，使用信息的实体必须充分了解所涉及的风险。限制密钥的密码周期可以限制如果密钥泄露将被泄露（即暴露）的材料量。对不同目的使用不同的密钥（例如不同的应用或加密机制）并限制单个密钥保护的信息量也可以实现此目的（参见第 4.3 节）。

4.5.1. 影响

密钥泄露有以下影响：

1. 用于提供机密性保护（即通过加密）的密钥的未经授权泄露意味着由该密钥加密的所有信息都可能被未经授权的实体确定。例如，如果对称数据加密密钥泄露，未经授权的实体可以使用该密钥解密过去或未来的加密信息（即信息在授权实体之间不再机密）。此外，泄露的密钥可被对手用于加密对手选择的信息，从而提供虚假信息。

私签名密钥的未经授权泄露意味着由该密钥签名的所有数据的完整性和不可否认性品质可疑。拥有私钥的未经授权的方可以签名虚假信息并使其看起来有效。如果可以证明签名数据在泄露前一段时间由其他机制（例如物理安全）保护，则签名可能仍有一些价值。例如，如果在第 1 天收到签名消息，后来确定私签名密钥在第 15 天泄露，接收者可能仍然相信消息有效，因为它在第 15 天之前保持在接收者占有中。加密时间戳也可以为私签名密钥泄露前签名的消息提供保护。然而，这些其他机制提供的安全性现在对签名的安全性至关重要。此外，签名消息的真实性可能受到质疑，因为私签名密钥可能已泄露给消息接收者或某些其他实体，然后以某种方式篡改了消息。CA 私签名密钥的泄露意味着对手可以创建欺诈性证书和证书撤销列表 (CRL)。

2. 密钥完整性的泄露意味着密钥已被意外或故意修改，或已替换另一个密钥。这包括密钥的删除（即不可用）。用于提供完整性保护的密钥的替换或修改使由该密钥保护的所有信息的完整性受到质疑。
3. 密钥用途或应用关联的泄露意味着密钥可能用于错误的目的（例如用于密钥建立而不是数字签名）或错误的应用，并可能导致由该密钥保护的信息泄露。
4. 密钥与所有者或其他实体关联的泄露意味着实体的身份无法保证（即不知道实体真正常是谁）。
5. 密钥与其他信息关联的泄露意味着根本没有关联或关联与错误的信息。这可能导致加密服务失败、信息丢失或信息安全性受损。

4.5.2. 保护措施

某些保护措施可用于最小化密钥泄露的可能性或后果。建议如下：

1. 限制秘密对称密钥或非对称私钥以明文形式存在的时间；
2. 防止人类查看明文秘密对称密钥和非对称私钥；
3. 将明文秘密密钥和私钥限制在物理保护的"容器"中，包括密钥生成器、密钥传输设备、密钥加载器、加密模块、硬件安全模块 (HSM) 和密钥存储设备；
4. 使用完整性检查以确保密钥或其与其他数据的关联未被泄露（例如密钥可以以某种方式包装，使得对包装密钥或密钥元数据的未经授权修改将被检测到）；
5. 采用密钥确认以帮助确保建立了正常确的密钥（参见 [SP 800-56A]、[SP 800-56B]、[SP 800-175B] 和 [SP 800-227]）；
6. 建立问责系统，跟踪对明文形式的秘密对称密钥和非对称私钥的每次访问；
7. 对密钥提供加密完整性检查（例如使用 MAC 或数字签名）；
8. 对签名数据使用受信任的时间戳；
9. 一旦不再需要密钥就销毁它们；以及
10. 创建泄露恢复计划，特别是在 CA 密钥泄露的情况下。

最糟糕的密钥泄露形式是未被检测到的泄露。然而，即使在这种情况下，也可以采取某些保护措施。密钥管理系统应设计为减轻密钥泄露的负面影响；系统应设计为单个密钥的泄露尽可能少地泄露数据（参见 [SP 800-152]）。例如，单个加密密钥可用于仅保护单个人类实体或有限数量此类实体的数据。系统通常有替代方法来身份认证通信实体，不完全依赖密钥的占有。目的是避免构建具有灾难性弱点的系统。

泄露恢复计划对于在密钥泄露事件中恢复加密安全服务至关重要。泄露恢复计划应记录在案且易于访问。该计划可包含在密钥管理实践声明中（参见 [SP 800-57p2]）。如果不包含，密钥管理实践声明应引用泄露恢复计划。

虽然泄露恢复主要是本地操作，但使用系统或设备的整个社区都受到影响。因此，泄露恢复程序应包括整个社区。例如，从根 CA 私签名密钥泄露中恢复需要所有使用基础设施的实体获取并安装新的信任锚证书。通常，这涉及实施成本高昂的物理程序，因此采取精心设计的预防措施来避免泄露可能是合理的。

泄露恢复计划应解决以下主题：

识别要通知的人员以及通知应包含的内容（例如是否特定密钥或证书生成过程被泄露）；
• 识别执行恢复操作的人员；
• 获取新密钥的方法（即重新密钥）；

• 所有加密密钥的清单（例如系统中所有密钥和证书的位置）；
• 对所有适当人员进行泄露恢复程序的教育；
• 要求执行密钥撤销检查以最小化泄露影响的政策；
• 监控重新密钥操作以确保对所有受影响密钥执行所有必需操作；以及
• 其他泄露恢复程序，例如：

o 设备的物理检查，
o 识别可能因事件而泄露的所有信息，
o 识别可能因签名密钥泄露而无效的所有签名，以及
o 如有需要，分发新的密钥材料。

4.6. 加密算法和密钥大小选择指南

本节讨论选择适当的算法和密钥大小，以便为 1) 系统的预期寿命和 2) 在数据预期寿命期间由该系统保护的任何敏感数据提供足够的保护。提供第 2 节中确定的安全服务的加密算法在 FIPS 和 NIST 建议中规定或采用。其中一些算法规定使用几种密钥大小。

4.6.1. 加密算法安全强度

加密算法可以提供不同的安全强度，具体取决于所用算法和密钥大小（只要算法需要密钥）。在本文档的先前版本中，算法或系统可以提供的估计（经典）安全强度 (s) 根据破解算法或系统所需的工作量（即操作次数）来定义（即破解算法所需的工作量需要某种类型的 2^s 次操作，其中 $s = 112、128、192$ 或 256 比特）。然而，密码分析进展（例如在分解算法、通用离散对数攻击和椭圆曲线离散对数攻击方面）以及量子计算的潜在出现使人们对使用单个数字来表示为不同算法类型指定相同安全强度所提供的安全性产生了质疑。2016 年，NIST 征集后量子算法提交，根据攻击者破解分组密码算法或哈希函数所需的计算资源来分类安全强度，基本上同时考虑经典计算机和量子计算机。按强度递增顺序列出，这些安全类别[20] 是：

1. 安全抵御被认为缺乏对具有 128 比特密钥的分组密码算法（例如 AES-128）进行密钥搜索所需资源的攻击者。
2. 安全抵御被认为缺乏对 256 比特哈希函数（例如 SHA-256、SHA3-256）进行碰撞搜索所需资源的攻击者。
3. 安全抵御被认为缺乏对具有 192 比特密钥的分组密码算法（例如 AES-192）进行密钥搜索所需资源的攻击者。
4. 安全抵御被认为缺乏对 384 比特哈希函数（例如 SHA-384、SHA3-384）进行碰撞搜索所需资源的攻击者。
5. 安全抵御被认为缺乏对具有 256 比特密钥的分组密码算法（例如 AES-256）进行密钥搜索所需资源的攻击者。

表 2. 后量子算法的安全强度类别

安全类别	最小攻击成本	示例
1	与对具有 128 比特密钥的分组密码进行密钥搜索相同	AES-128
2	与对 256 比特哈希函数进行碰撞搜索相同	SHA-256
3	与对具有 192 比特密钥的分组密码进行密钥搜索相同	AES-192
4	与对 384 比特哈希函数进行碰撞搜索相同	SHA3-384
5	与对具有 256 比特密钥的分组密码进行密钥搜索相同	AES-256

使用强加密算法对于加密安全至关重要。然而，它们的实施和使用也至关重要，因为算法可能无意中以致露密钥信息的方式实施。

批准的对称密钥加密算法（例如 AES 和 Ascon-AEAD128）和公钥（即非对称密钥）算法需要使用加密密钥。安全强度估计是在假设密钥是指定长度并根据特定规则生成和处理的（例如密钥使用具有足够熵种子并满足某些标准的 RBG 生成）情况下进行的。然而，这些规则通常未被遵循，由这些密钥保护的数据提供的安全性可能略低于提供的安全强度估计（参见第 4.6.2 节）。

第 4.6.1.1 节讨论批准的对称密钥算法（例如用于加密和消息身份认证）可以提供的最大安全强度。第 4.6.1.2 节讨论经典非对称密钥算法可以提供的最大安全强度，而第 4.6.1.3 节解决批准的抗量子非对称密钥算法的安全强度。第 4.6.1.4 节讨论哈希函数、XOF 及其应用程序的安全强度。

4.6.1.1. 批准对称密钥算法的安全强度

表 3 提供对称密钥算法及其密钥长度的估计最大安全强度。

1. 第 1 列指示安全类别（参见表 2）。
2. 第 2 列指示特定行中列出的算法和密钥长度提供的估计最大经典安全强度（以比特为单位）。由于对提供计算优势的算法的攻击，安全强度不一定与密钥长度相同。
3. 第 3 列标识可以提供第 1 列或第 2 列中指示的安全强度的对称密钥算法。

表 3. 对称算法的安全强度

安全强度（按类别）	经典安全强度（按比特数）	对称密钥算法
	≤ 80	2TDEA
	112	3TDEA[21]
1	128	AES-128 和 Ascon-AEAD128
3	192	AES-192
5	256	AES-256

三重数据加密算法 (TDEA) 在 [SP 800-67] 中规定，使用三个密钥。2TDEA 是 TDEA，其中三个密钥中的两个相同，3TDEA 是 TDEA，其中三个密钥不同。如表 2 中橙色背景所示，2TDEA 和 3TDEA 不允许用于应用加密保护（例如使用加密），但可用于处理已受保护的信息（例如使用解密）。有关更详细的信息，请参见 [SP 800-131A]。

AES 在 [FIPS 197] 中规定，具有三种密钥大小：128、192 和 256 比特。AES 与 [SP 800-38] 系列出版物中规定的操作模式一起使用。

Ascon-AEAD128 在 [SP 800-232] 中为受限设备规定，具有单个 128 比特密钥大小。

4.6.1.2. 批准经典非对称密钥算法的安全强度

表 4 提供批准的经典（即非抗量子）非对称密钥算法及其密钥长度的估计最大安全强度。本节中列出的算法不满足类别 1 的要求（参见表 2），因为它们可以使用量子计算机破解，与对 128 比特分组密码进行密钥搜索所需的资源相比，所需资源相对较少。

1. 第 1 列指示特定行中列出的算法和密钥长度提供的估计最大经典安全强度（以比特为单位）。
2. 第 2 列指示与 [FIPS 186-4] 中规定的 DSA 相关联的参数的最小大小。
3. 第 3 列指示与使用有限域密码 (FFC) 进行密钥协商的标准相关联的参数的最小大小。此类算法的示例包括 [SP 800-56A] 中定义的 Diffie-Hellman (DH) 和 MQV 密钥协商，其中 L 是公钥的大小，N 是私钥的大小。
4. 第 4 列指示 k（模数 n 的大小）的值，用于基于整数分解密码 (IFC) 的算法。此类算法的主要算法是 RSA 算法，[FIPS 186-5] 批准用于数字签名，[SP 800-56B] 批准用于密钥建立。k 的值通常被视为密钥大小。
5. 第 5 列指示 f（n 的大小，其中 n 是基点 G 的阶）的范围，用于 [FIPS 186-5] 中规定用于数字签名和 [SP 800-56A] 中规定用于密钥建立的基于椭圆曲线密码 (ECC) 的算法。f 的值通常被视为密钥大小。

表 4. 经典（非抗量子）非对称密钥算法的安全强度

经典安全强度（按比特数）	FFC DSA	FFC (DH, MQV)	IFC (RSA)	ECC (ECDSA, EdDSA, DH, MQV)
≤ 80	L = 1024 N = 160	L = 1024 N = 160	k = 1024	f = 160-223
112	L = 2048 N = 224	L = 2048 N = 224	k = 2048	f = 224-255
128	L = 3072 N = 256	L = 3072 N = 256	k = 3072	f = 256-383
192	L = 7680 N = 384	L = 7680 N = 384	k = 7680	f = 384-511
256	L = 15360 N = 512	L = 15360 N = 512	k = 15360	f = 512+

对于 FFC 和 IFC 算法，列出的密钥大小不一定与源文档（即 [FIPS 186-5]、[SP 800-56A] 和 [SP 800-56B]）中批准的密钥大小匹配。也就是说，某些密钥大小可能未列出，或者可能提供额外的密钥大小及其相关安全强度。然而，FFC、IFC 和 ECC 算法的估计安全强度也可以使用 [IGD_B] 中的公式计算。

表 4 中以橙色显示的算法/密钥大小组合不再批准用于对联邦政府信息应用加密保护（例如生成数字签名）。然而，如果接收实体接受与此相关的风险，则在以这些安全强度保护的信息处理方面允许一些灵活性（例如验证数字签名）。有关更详细的信息，请参见 [SP 800-131A]。

4.6.1.3. 批准抗量子非对称密钥算法的安全强度

表 5 提供批准抗量子非对称密钥算法及其参数集的安全类别。

1. 第 1 列指示特定行中列出的算法和参数集相关的安全类别。
2. 第 2 列指示 [FIPS 203] 中规定的 ML-KEM 密钥封装机制的参数集。
3. 第 3 列指示 [FIPS 204] 中规定的 ML-DSA 数字签名算法的参数集。
4. 第 4 列指示 [FIPS 205] 中规定的 SLH-DSA 数字签名算法的参数集。
5. 第 5 列指示 [SP 800-208] 中 LMS、HSS、XMSS 和 XMSSMT 数字签名算法的参数集。

表 5. 抗量子非对称密钥算法的安全类别

安全类别	ML-KEM	ML-DSA	SLH-DSA	LMS, HSS, XMSS, 和 XMSSMT
1	ML-KEM-512		SLH-DSA-SHA2-128s	
			SLH-DSA-SHAKE-128s	
			SLH-DSA-SHA2-128f	
			SLH-DSA-SHAKE-128f	
2		ML-DSA-44		
3	ML-KEM-768	ML-DSA-65	SLH-DSA-SHA2-192s	LMOTS_SHA256_N24
			SLH-DSA-SHAKE-192s	LMS_SHA256_M24
			SLH-DSA-SHA2-192f	LMOTS_SHAKE_N24
			SLH-DSA-SHAKE-192f	LMS_SHAKE_M24
			SLH-DSA-SHAKE-192f	WOTSP with n=24
				XMSS with n=24
				XMSSMT with n=24
5	ML-KEM-1024	ML-DSA-87	SLH-DSA-SHA2-256s	LMOTS_SHA256_N32
			SLH-DSA-SHAKE-256s	LMS_SHA256_M32
			SLH-DSA-SHA2-256f	LMOTS_SHAKE_N32
			SLH-DSA-SHAKE-256f	LMS_SHAKE_M32
				WOTSP with n=32
				XMSS with n=32
				XMSSMT with n=32

4.6.1.4. 哈希函数、XOF 及其应用程序的安全强度

加密哈希是将任意长度的输入比特串转换为输出哈希值的过程。哈希函数产生固定长度的哈希值，XOF 产生可变长度的输出（参见第 3.1 节）。这些批准的哈希方法满足以下属性：

1. （原像抗性）在计算上不可行找到映射到任何预指定输出的输入。
2. （碰撞抗性）在计算上不可行找到映射到相同输出的任何两个不同输入。

哈希函数和 XOF 的安全强度由其使用的应用所需的属性决定。适当的哈希方法应由使用哈希的算法、方案或应用以及要提供的最小安全强度确定。对于这些应用，加密密钥与应用相关联，在确定应用提供的安全强度时需要考虑。[22] 例如，生成数字签名时，给定安全强度的密钥的最小密钥长度在第 4.6.1.2 节表 4 的 FFC、IFC 和 ECC 列中提供，而对于 HMAC，密钥长度在 https://csrc.nist.gov/projects/hash-functions 讨论。

表 6 列出 [FIPS 180]、[FIPS 202] 和 [SP 800-232] 中规定的批准哈希函数和 XOF，以及需要碰撞抗性的各种应用（例如数字签名）、HMAC、KMAC、密钥导出和随机比特生成。

1. 第 1 列指示特定行算法和（如适用）密钥长度提供的估计最大经典安全强度（以比特为单位）。
2. 第 2 列指示安全类别（参见表 2）。
3. 第 3 列列出 [FIPS 180]、[FIPS 202] 和 [SP 800-232] 中为需要碰撞抗性的应用（例如数字签名）提供第 1 列和/或第 2 列中识别的安全强度的哈希函数和 XOF。
4. 第 4 列列出可用于满足第 1 列和/或第 2 列中识别的安全强度的基于哈希的应用的哈希函数和 XOF。这些应用需要原像抗性。

表条目的注释在表下方提供，并在表中以上标指示。对于这些应用，加密密钥与应用相关联，在确定应用提供的安全强度时应考虑。例如，对于数字签名的生成，给定安全强度的密钥的最小密钥长度在第 4.6.1.2 节表 4 的 FFC、IFC 和 ECC 列中提供，而对于 HMAC，密钥长度在 https://csrc.nist.gov/projects/hash-functions 讨论。

表 6. 哈希函数、XOF 及其应用程序的最大安全强度

经典安全强度（按比特数）	安全强度（按类别）	需要碰撞抗性的应用（例如数字签名）	HMAC,[1] KMAC,[2] 密钥导出函数，[3] 随机比特生成[4]
≤80[5]		SHA-1[6]	
112		SHA-224,[7] SHA-512/224,[7] SHA3-224[7]	
128	1		SHA-1[7]
	2	SHA-256, SHA-512/256, SHA3-256, SHAKE128[8], Ascon-cache256, Ascon-XOF128,[9] Ascon-CXOF128[9]	SHAKE128[8], Ascon-cache256, Ascon-XOF128,[10] Ascon-CXOF128[10]
192-224	3		SHA-224,[7] SHA-512/224,[7] SHA3-224[7]
	4	SHA-384, SHA3-384	
≥256	5	SHA-512, SHA3-512, SHAKE256[11]	(SHA-256, SHA-512/256, SHA-384, SHA-512, SHA3-256, SHA3-384, SHA3-512),[12] SHAKE256[11]

表 6 注释：

1. HMAC 使用哈希函数和密钥。HMAC 提供的安全强度取决于所用哈希函数和密钥长度。估计安全强度假设密钥长度和密钥生成过程提供的安全强度至少等于所需 HMAC 安全强度（以比特为单位）。HMAC 规范 [SP 800-224] 要求密钥长度至少为 128 比特。
2. KMAC 基于 [FIPS 202] 中规定的 KECCAK 函数并使用密钥。KMAC 提供的估计安全强度假设密钥长度和密钥生成过程提供的安全强度至少等于所需安全强度（以比特为单位）。
3. 密钥导出的安全强度假设在密钥协商过程中计算的共享密钥或现有密钥导出密钥可以支持所需安全强度。
4. 随机比特生成的安全强度假设 RBG 已实例化足够的随机性以支持所需安全强度。
5. 提供低于 112 比特安全强度的应用（即 ≤ 80，如表 6 中橙色所示）不批准用于对联邦政府信息应用加密保护（例如生成数字签名或 MAC 值）。然而，如果接收实体接受与此相关的风险，则在以该安全强度保护的信息处理方面允许一些灵活性（例如验证数字签名或 MAC 值）。有关更详细的信息，请参见 [SP 800-131A]。
6. SHA-1 已被证明为数字签名提供低于 80 比特的安全性。
7. SHA-1 和 224 比特哈希函数（在表 6 中以黄色突出显示）在 2030 年之前不推荐使用，此后不允许用于应用加密保护（参见 [SP 800-131A]）。
8. SHAKE128 提供的安全性取决于输出大小（output_length）。要获得 128 比特碰撞抗性（参见表 6 第 3 列），至少需要 256 比特输出。对于小于 256 比特的输出，提供的安全强度为 output_length/2。要获得 128 比特原像抗性（参见表 6 第 4 列），至少需要 128 比特输出。对于小于 128 比特的输出，提供的安全强度为 output_length。
9. 仅当输出长度至少为 256 比特时，Ascon-XOF128 和 Ascon-CXOF128 才提供 128 比特碰撞抗性安全强度。
10. 仅当输出长度至少为 128 比特时，Ascon-XOF128 和 Ascon-CXOF128 才提供 128 比特原像安全强度。
11. SHAKE256 提供的安全性也取决于输出大小（output_length）。要获得 256 比特碰撞抗性（参见表 6 第 3 列），至少需要 512 比特输出。对于小于 512 比特的输出，提供的安全强度为 output_length/2。要获得 256 比特原像抗性（参见表 6 第 4 列），至少需要 256 比特输出。对于小于 256 比特的输出，提供的安全强度为 output_length。
12. 如果密钥长度至少为 256 比特且以至少 256 比特的安全强度生成，则 SHA-256、SHA-512/256、SHA-384、SHA-512、SHA3-256、SHA3-384 和 SHA3-512 为类别 5。

4.6.2. 使用算法套件和有效安全强度

许多应用需要多种加密服务（例如密钥建立、机密性保护、完整性保护和/或源身份认证）。可以使用不同的算法和密钥来提供每种服务（例如 AES 可用于数据加密，ML-DSA 可用于生成数字签名以进行完整性保护），或者可以使用相同算法使用相同或不同密钥提供多种服务（例如可以使用 ML-DSA 生成数字签名来执行源身份认证和完整性保护）。

许多服务也可以由多种算法提供（例如密钥建立可以由 RSA、DH 或 ML-KEM 提供）。当几种算法可用于执行相同服务时，某些算法由于其设计而本质上更高效（例如使用 HMAC 和数字签名都可以提供完整性保护，但 HMAC 设计为更高效）。

在许多情况下，算法可能有各种密钥大小可用。对于某些算法（例如公钥算法，如 RSA），使用比所需更大的密钥大小可能会影响操作（例如更大的密钥可能需要更长时间生成、需要更多内存和传输带宽，并且需要更长时间处理数据）。然而，使用太小的密钥大小可能无法提供足够的安全性。

在选择分组密码加密算法（例如 AES）时，分组大小也可能是要考虑的因素，因为 [SP 800-38] 系列中定义的几种模式提供的安全性取决于分组大小。如果为要保护的数据提供足够的保护，不同强度和密钥大小的算法可以一起使用以实现性能、可用性或互操作性。一般来说，加密保护的强度由用于提供保护的最弱算法和密钥大小决定。确定数据提供的实际保护强度的分析不仅包括用于对信息应用加密保护的算法和密钥大小，还包括密钥及其前身如何生成的细节（例如在密钥生成期间使用的 RBG 支持的安全强度）以及密钥生成后如何处理的细节。

密钥的处理包括对密钥进行操作的任何过程（例如密钥用作某些加密操作的输入）。如果生成以提供 s 比特安全强度的密钥由安全强度低于 s 比特的过程操作，则密钥降低到该过程的安全强度。例如，如果密钥由提供 256 比特安全强度输出的 RBG 生成，则当密钥与 AES-256 一起使用时，密钥和算法组合可以提供 256 比特安全强度。然而，如果密钥使用 AES-128 包装（最多只能提供 128 比特安全强度），则 256 比特密钥可以提供的安全强度降低到 128 比特，即使它仍与 AES-256 一起使用。

以下是几种算法组合的列表以及算法/密钥大小组合的安全影响讨论：

1. 当使用密钥建立方案来建立用于一个或多个对称密钥算法（例如 AES 或 HMAC）的密钥材料时，密钥材料可以支持的安全强度由所用最弱算法和密钥大小决定。例如，如果使用 ML-KEM 512 建立 256 比特 AES 密钥，则由该 AES 密钥保护的任何信息最多只能提供 128 比特安全性，因为 ML-KEM 512 密钥最多只能提供 128 比特安全强度（参见第 4.6.1.3 节表 5）。
2. 当哈希函数和数字签名算法组合用于计算数字签名时，签名的安全强度由两种算法中较弱者决定。例如，如果 SHA-256 与 ML-DSA 87（可以支持 256 比特安全强度）一起使用，则组合最多只能提供 128 比特安全性，因为 SHA-256 针对碰撞只能提供 128 比特安全强度（参见第 4.6.1.4 节表 6）。
3. 当使用 RBG 为旨在提供 X 比特安全性的加密算法生成密钥时，应使用支持至少 X 比特安全性的批准 RBG。例如，如果 AES-128 及其密钥旨在提供 128 比特安全强度，则 RBG 需要支持至少 128 比特安全性。

为了支持给定安全强度，必须仔细选择算法和密钥大小的组合。例如，如果需要 128 比特安全强度来保护要通信并提供机密性保护、完整性保护和源身份认证的数据，则以下算法和密钥大小选择可能合适：

a. 选择支持至少 128 比特安全强度的 RBG 来生成密钥。
b. 机密性：使用 AES-128 和由项目 a 中的 RBG 生成的密钥加密信息。其他 AES 密钥大小也合适，但性能可能稍慢，生成超过 128 比特的密钥不会增加提供的安全性。
c. 完整性保护和源身份认证：如果只偏好一种加密操作，请使用数字签名。从应用可用的选项中选择数字签名算法（例如具有至少 256 比特密钥的 ECDSA）。SHA-256 或更大的哈希函数可用于在使用密钥生成签名之前哈希数据。如果多种算法和密钥大小可用，选择可以基于算法性能、内存要求或其他因素，只要满足最低要求。
d. 密钥建立：根据应用和环境选择密钥建立方案（参见 [SP 800-56A]、[SP 800-56B] 和 [FIPS 203]）、算法在实施中的可用性及其性能。从表 4 或表 5 中选择算法和密钥大小的密钥大小，可以提供至少 128 比特安全性。例如，如果可用，ML-KEM 512 可能是一个好的选择。

采购系统的机构应考虑系统的潜在运行寿命。机构应选择预计在整个系统寿命期间安全的算法和密钥大小，或应确保算法和密钥大小可以轻松更新。

4.6.3. 预测算法和安全强度批准状态

随着时间的推移，加密算法及其相关算法参数（例如密钥长度）可能变得更容易受到成功攻击，需要过渡到更强的算法或更长的密钥长度。[SP 800-131A] 提供 NIST 批准加密算法及其密钥长度的批准状态。

在必须保护特定数据期间所需的最小安全强度和要使用的算法应如下获得：

确定在整个保护期间保护数据所需的安全强度。
使用 [SP 800-131A] 和第 4.6.1 节中的表，选择与所需强度相同或更大强度的算法和密钥大小。安全强度不仅由所用算法决定，还由算法参数以及密钥如何生成和处理决定（参见第 4.6.2 节）。
当为给定算法由 RBG 生成密钥时，应使用支持算法所需安全强度的 RBG 生成它们（例如 RBG 的设计和种子 RBG 时提供的熵）。

4.6.4. 系统中向新算法和密钥大小过渡

计算能力、加密研究和密码分析技术的进步定期产生替换算法或增加不再为其用例提供足够安全性的密钥大小的需求。例如，未来密码相关量子计算机对公钥密码构成的威胁需要紧急迁移到抗量子密码。此类过渡成本高昂、需要时间、引发互操作性问题并扰乱操作。

建议采用灵活方法进行过渡的系统设计。这通常称为"加密敏捷性"，描述替换和调整加密算法以实现协议、应用、软件、硬件和基础设施弹性而无需中断运行系统流程所需的能力。需要适当设计的 Incorporating 加密敏捷性考虑的操作机制，以促进快速、平稳地过渡到更新算法，而不会引入安全漏洞或操作中断。有关加密敏捷性的更彻底讨论可在 https://csrc.nist.gov/Projects/crypto-agility 获取。

本文档本节讨论特定算法和密钥大小问题。过渡到新加密算法和/或密钥大小通常直接影响企业密钥管理。影响范围从适应更大密钥大小的最小更改到密钥类型及其支持密钥建立协议的大规模修改。

第 4.6.1 节提供当前批准的经典和抗量子加密算法与推荐密钥大小可以支持的安全强度估计，[SP 800-131A] 提供当前算法批准状态信息和美国联邦政府过渡建议。这些资源可用于帮助规划从现有加密实施到满足不断发展的加密保护要求的实施的过渡。强烈建议使用可以轻松适应满足不断演变要求的新加密安全产品的实施和应用的灵活过渡方法。本节讨论与加密过渡规划相关的一些问题。

受特定加密算法（和密钥大小）保护的数据保持安全的估计时间段称为算法安全寿命。在此期间，算法可用于应用加密保护（例如加密和/或签名数据）和处理受保护信息（例如解密和/或验证签名数据），尽管允许应用保护的周期可能比算法安全寿命短（参见图 2）。

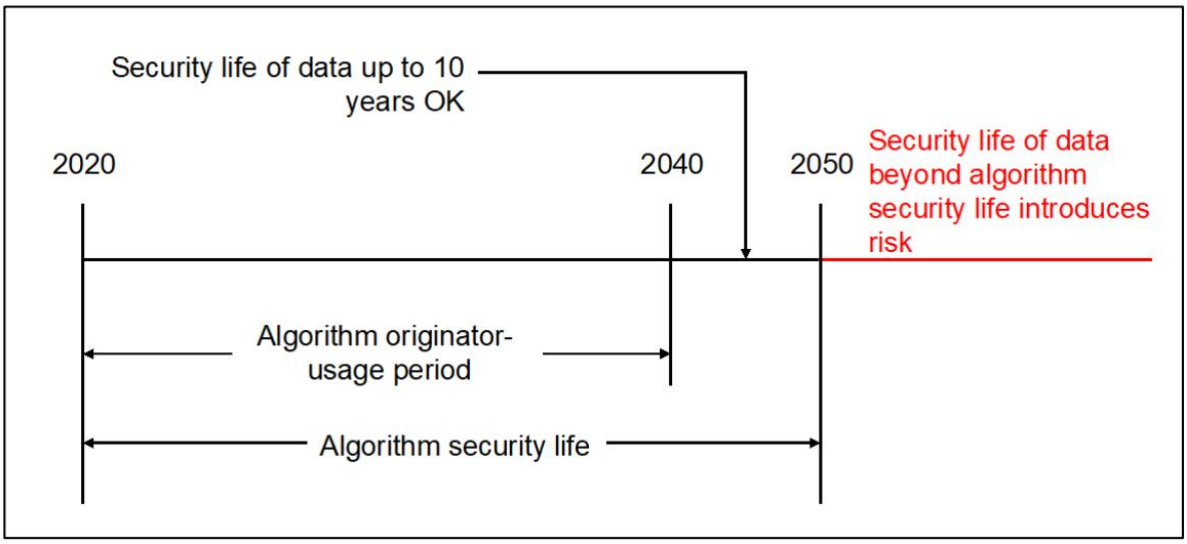

图 2. 对称密钥算法发起者使用周期示例

密钥材料安装的安全性对系统的安全性至关重要，无论密钥材料是在系统内生成（例如在系统的加密模块中）还是在另一个系统内生成随后安装在目标系统中。对于此功能，密钥材料使用各种技术安装在实体的软件、硬件、系统、应用、加密模块或设备内以供运行使用。在初始设置期间安装密钥材料，当新密钥材料添加到现有密钥材料时，以及当现有密钥材料被替换时（例如通过重新密钥或密钥导出；参见第 7.2.3 和 7.2.4 节）。

密钥材料初始安装的过程（例如通过手动输入、使用电子密钥加载器或制造商在制造期间）应包括在进入软件、硬件、系统、应用、设备或加密模块期间保护密钥材料，并包括可能需要的任何附加程序。该过程应考虑 [FIPS 140-3] 的要求及其对不同保护级别的不同要求。

许多制造商提供带有密钥材料的应用或系统，用于测试新安装的应用/系统是否正常常运行。此测试密钥材料不得用于运行。

4.6.5. 安全性随时间降低

最终，算法或密钥所提供的安全性可能会被削弱或完全丧失。例如，由于计算能力或密码分析技术的进步，所使用的算法或密钥长度可能不再提供足够的安全性。在这种情况下，对"新"信息应用保护应使用更强的算法或密钥。

[SP 800-131A] 将 NIST 密码算法的批准状态分类为可接受 (acceptable)、已弃用 (deprecated)、不允许 (disallowed) 或遗留使用 (legacy use)。可接受和已弃用意味着特定类型、长度或强度的算法、方案、参数选择和/或密钥被批准使用。然而，已弃用状态意味着这样做存在一些安全风险（例如，密码服务可能提供的安全性保证较少）。

当使用特定类型、长度或强度的密码算法、方案、参数选择和/或密钥的密码服务被禁止时（即，使用一个或多个这些密码元素的密码服务被禁止），分配给密钥的密码周期会受到影响。

由于一个或多个这些密码元素而被禁止的非对称密钥对的私钥所分配的密码周期应终止（例如，不应使用任何被禁止的密码元素生成数字签名）。相应的公钥可继续用于处理在其应用保护时该密码元素未被禁止的密码保护信息（例如，可以验证签名）。然而，公钥的使用继续被允许用于遗留使用。

由于一个或多个这些密码元素而被禁止的对称密钥所分配的起始使用期限 (originator-usage period) 应终止[23]（例如，不应使用任何被禁止的密码元素加密数据）。然而，处理受保护信息（例如，使用密钥解密密文）被允许用于遗留使用。

在任何一种情况下，都应提供关于被撤销密钥或密钥对的撤销通知。撤销通知应包括时间戳以指示撤销时间。

使用仅允许遗留使用的密码服务存在风险。算法或密钥预期提供的安全性降低（即，如 [SP 800-131A] 中所述的已弃用或不允许的批准状态）具有以下影响：

加密信息： 在其加密形式下任何时间对未经授权实体可用的加密信息的安全性应被视为可疑。例如，以加密形式传输的密钥（例如，使用密钥包装密钥或密钥传输密钥以及后来被破解的算法或密钥长度）可能需要被视为已泄露，因为对手可能已保存密钥的加密形式以备日后解密，以防最终找到破解算法的方法（关于密钥泄露的讨论见第 4.5 节）。即使传输的加密信息随后使用不同的密钥或算法重新加密进行存储，由于传输算法或密钥的弱点，信息可能已经被泄露。

未以这种方式"暴露"的加密信息（例如，未传输）即使加密算法或密钥长度不再提供最初所需的安全量，仍可能是安全的。例如，如果密钥的加密形式和由这些密钥保护的信息从未被传输，则信息可能仍然是机密的。

需要吸取的教训是，用于将以加密形式提供给未经授权实体的信息（例如，通过传输）的加密机制应提供高级别的安全保护，并且每个密钥的使用应受到限制（即，密码周期应较短），以便泄露的密钥不能用于泄露大量信息。如果算法本身被破解[24]，当每个密钥用于加密非常有限的信息量时，对手被迫执行更多工作来解密信息。第 4.3.6 节讨论了密码周期。

最初传输的存储数据上的数字签名：[25] 数字签名可以在数据传输之前和后续存储之前计算。在这种情况下，签名数据和数字签名都将被存储。如果签名提供的安全性后来被降低（例如，由于算法被破解或因为对手确定了密钥），如果存储的数据及其关联的数字签名自强度降低之前的时间起已得到充分保护以防修改（例如，通过使用更强的算法或密钥应用数字签名），则签名可能仍然有效[26]。正常在开发使用密码时间戳的存储功能，以在原始签名机制或其密钥的正常常安全生命周期之外存储数字签名数据（例如，参见 [X995] 和 [ISO/IEC18014]）。

最初传输的存储数据上的对称认证码：[27] 与数字签名类似，对称认证码（即 MAC）可以在数据传输之前和/或后续存储之前计算。如果接收的数据和认证码按接收时的状态存储，并且认证算法或密钥的安全性被禁止用于应用密码保护（例如，由于算法的弱点），如果存储的数据及其关联的认证码自禁止之前的时间起已得到充分保护以防修改（例如，通过使用更强的算法或密钥应用另一个认证码），则认证码可能仍然有效[28]。正常在开发使用密码时间戳的存储功能，以在原始认证机制或其密钥的正常常安全生命周期之外存储认证数据（例如，参见 [X995] 和 [ISO/IEC18014]）。

5. 密钥信息的保护要求

本节提供了关于密钥信息所需保护类型的指南，其中包括密钥材料和相关元数据，并因密钥类型而异。密钥信息必须受到保护，安全服务才有意义。[FIPS 140-3] 验证的密码模块可以提供所需的大部分保护，具体取决于其安全级别。然而，当密钥信息存在于 FIPS 140 密码模块外部时，需要额外的保护（例如，通过操作系统中的访问控制机制或通过外部数据库中密钥信息的加密和完整性保护）。所需保护的类型取决于密钥的类型和密钥用于的安全服务。[SP 800-152] 为联邦密码密钥管理系统 (FCKMS) 提供了关于密钥信息在 FIPS 140 验证的密码模块外部时的保护建议，以及其他需要解决的密钥管理因素。

5.1. 保护和保证要求

密钥材料应在需要相关密码服务的整个期间（在操作上）可用。密钥可以在积极使用时保存在密码模块内，也可以存储在外部（前提是提供适当的保护）并在需要时召回。如果需要在密钥的密码周期之外使用某些密钥，则可能需要归档（关于非对称和对称密钥的密码周期讨论见第 4.3.4 和 4.3.5 节）。

密钥信息可能需要以下保护和保证：

机密性保护 应为所有秘密密钥信息提供（例如，对称秘密密钥、非对称私钥、密钥共享、秘密元数据）。公钥、算法参数和大部分元数据通常不需要机密性保护。当秘密密钥信息存在于符合 [FIPS 140-3] 的验证密码模块内，且安全级别与密钥要保护的数据相关的 [FIPS 199] 影响级别一致时，即提供了适当的机密性保护（见 [SP 800-152]）。当秘密或私钥信息在密码模块外部可用时，应通过适当安全强度的加密提供机密性保护（见 [SP 800-152]）或通过物理手段控制对秘密密钥信息的访问[29]。特定机密性机制的安全和操作影响各不相同。第 5.2.1.3 和 5.2.2.3 节讨论了适当机密性机制的选择。

完整性保护 应为所有密钥信息提供。完整性保护始终需要检查接收或检索的密钥信息的来源和格式（见第 4.4.1 节）。当密钥信息存在于符合 [FIPS 140-3] 的验证密码模块内，且安全级别与密钥要保护的数据相关的 [FIPS 199] 影响级别一致时，即提供了适当的完整性保护（见 [SP 800-152]）。当密钥信息在密码模块外部可用时，应通过适当的密码完整性机制（例如，密码校验和、密码哈希函数、MAC 或数字签名）、非密码完整性机制（例如，CRC 或奇偶校验）（见附录 A）或物理保护机制提供完整性保护。第 5.2.1.2 和 5.2.2.2 节讨论了适当完整性机制的选择。

关联性保护 应通过确保使用正常确的密钥材料来保护正常确应用程序或设备中的正常确数据，为密码安全服务提供。第 5.2.1.4 和 5.2.2.4 节讨论了适当关联性保护方法的选择。

算法参数和公钥有效性的保证 提供对与密码算法一起使用的参数和密钥正常确性的信心（见第 4.4.2 和 4.4.3 节）。适当保证机制的选择在 [SP 800-56A]、[FIPS 203]、[FIPS 204]、[FIPS 205]、[SP 800-89]、[SP 800-208]、[SP 800-227] 和本文件中讨论。

私钥持有保证 提供对公钥所有者实际持有相应私钥的保证（见第 4.4.4 节）。

可用性保护 应为所有需要在立即使用之外可用的密钥信息提供（例如，解密或验证密钥信息的持续完整性）。这是通过备份或归档信息来实现的（见第 7.2.2.1 和 7.3.1 节）。

密钥信息的保护期限取决于密钥类型、相关密码服务以及需要密码服务的时间长度。保护期限包括密钥的密码周期（见第 4.3 节）。完整性和机密性的保护期限不一定相同。完整性保护可能只需要持续到密钥不再使用（但尚未销毁），但机密性保护可能需要持续到密钥实际销毁。

5.1.1. 密码密钥的保护和保证要求摘要

表 7 提供了密钥在分发、密钥建立和存储期间的保护要求摘要。提供必要保护的方法在第 5.2 节中讨论。

1. 第 1 列（密钥类型）标识密钥类型。
2. 第 2 列（安全服务）指示密钥与密码技术结合提供的安全服务类型。在此列中，"支持"(support) 一词表示相关密钥用于支持主要的密码服务：机密性、完整性认证和源认证。例如，密钥协商密钥可以通过建立用于提供机密性的密钥来支持机密性服务；RBG 密钥支持密码的使用，因为它用于提供随机值以生成用于密码保护信息的密钥。
3. 第 3 列（安全保护）指示密钥所需的保护类型（即，机密性、完整性和/或可用性）。
4. 第 4 列（关联性保护）指示需要为该密钥保护的关联性类型，例如将密钥与用法、应用程序、授权的通信参与者或其他指示的信息（例如，其他密钥）关联。与算法参数的关联仅适用于使用它们的算法。
5. 第 5 列（所需保证）指示是否需要获得公钥有效性和/或私钥持有的保证，如 [SP 800-56A]、[SP 800-56B]、[FIPS 203]、[SP 800-89][30]、[SP 800-227] 和本建议中所定义。公钥有效性保证提供对密钥正常确性的一定程度的信心（见第 4.4.3 节）。私钥持有保证提供对提供公钥的实体在某个时间实际持有相关私钥的一定程度的信心（见第 4.4.4 节）。

6. 第 6 列（保护期限）指示需要维护密钥的机密性、完整性和/或可用性的时间长度（见第 4.3 节）。对称密钥和私钥应在其保护期结束时销毁（见第 7.3.4 和 8.4 节）。

表 7. 密码密钥的保护要求

密钥类型	安全服务	安全保护	关联性保护	所需保证	保护期限
数字签名					
1. 私用签名密钥	源认证 完整性认证 不可否认性	机密性 完整性[31]	用法或应用程序 算法参数（使用时） 公用签名验证密钥	私钥持有	从生成到密码周期结束
2. 公用签名验证密钥	源认证 完整性认证 不可否认性	完整性 可用性	用法或应用程序 密钥对所有者 算法参数（使用时） 私用签名密钥 签名数据	公钥有效性	从生成到不再需要验证签名
认证					
3. 对称认证密钥	身份认证 完整性认证	机密性 完整性 可用性	用法或应用程序 其他授权实体 授权数据		从生成到身份或任何受保护数据不再需要认证

4. 私用认证密钥	身份认证 完整性认证	机密性 完整性	用法或应用程序 公用认证密钥 算法参数（使用时）	私钥持有	从生成到密码周期结束
5. 公用认证密钥	身份认证 完整性认证	完整性 可用性	用法或应用程序 密钥对所有者 认证数据 私用认证密钥 算法参数（使用时）	公钥有效性	从生成到身份或任何受保护数据不再需要认证
随机比特生成					
6. 对称 RBG 密钥	支持	机密性 完整性	用法或应用程序		从生成到替换
密钥派生					
7. 对称密钥派生/主密钥	支持	机密性 完整性	用法或应用程序 其他授权实体 派生密钥		从生成到密码周期结束或派生密钥生命周期结束，以较晚者为准
密钥建立（自动化）					
8. 对称密钥包装/解包密钥	支持	机密性 完整性 可用性	用法或应用程序 其他授权实体 被包装的密钥		从生成到密码周期结束或不再需要解包被包装的密钥，以较晚者为准
9. 公用密钥传输密钥	支持	完整性	用法或应用程序 密钥对所有者 私用密钥传输密钥	公钥有效性	从生成到密码周期结束

10. 私用密钥传输密钥	支持	机密性 完整性 可用性	用法或应用程序 加密密钥 公用密钥传输密钥	私钥持有	从生成到不再需要解密密钥
11. 对称密钥协商密钥	支持	机密性 完整性 可用性	用法或应用程序 其他授权实体		从生成到密码周期结束或不再需要确定密钥，以较晚者为准
12. 公用静态密钥协商密钥	支持	完整性	用法或应用程序 密钥对所有者 算法参数（使用时） 私用静态密钥协商密钥	公钥有效性	从生成到密码周期结束或不再需要确定密钥，以较晚者为准
13. 私用静态密钥协商密钥	支持	机密性 完整性	用法或应用程序 算法参数（使用时） 公用静态密钥协商密钥	私钥持有	从生成到密码周期结束或不再需要确定密钥，以较晚者为准
14. 公用临时密钥协商密钥	支持	完整性[32]	密钥对所有者 私用临时密钥协商密钥 用法或应用程序 算法参数（使用时）	公钥有效性	从生成到密钥协商过程完成
15. 私用临时密钥协商密钥	支持	机密性 完整性	用法或应用程序 公用临时密钥协商密钥 算法参数（使用时）		从生成到密钥协商过程结束 过程结束后，密钥应销毁

16. 公用静态封装密钥	支持	完整性	用法或应用程序 密钥对所有者 私用静态解封装密钥 算法参数	公钥有效性	从生成到密码周期结束
17. 私用静态解封装密钥	支持	机密性 完整性 可用性	用法或应用程序 被封装的密钥 公用静态封装密钥 算法参数	私钥持有	从生成到不再需要解封装被封装的密钥
18. 公用临时封装密钥	支持	完整性	密钥对所有者 私用临时解封装密钥 用法或应用程序 算法参数	公钥有效性	从生成到单次交易的封装过程完成
19. 私用临时解封装密钥	支持	机密性 完整性 可用性	用法或应用程序 公用临时封装密钥 算法参数	私钥持有	从生成到解封装过程结束 过程结束后，密钥应销毁
数据加密/解密					
20. 对称数据加密/解密密钥（传输中的数据）	机密性	机密性 完整性 可用性	用法或应用程序		从生成到数据生命周期结束或
21. 对称数据加密/解密密钥：（静态数据）			其他授权实体 明文/加密数据		密码周期结束，以较晚者为准
密钥存储（用于操作、备份和归档存储）					

22. 对称密钥包装/解包密钥	支持	机密性 完整性 可用性	用法或应用程序 其他授权实体 被包装的密钥		从生成到密码周期结束或不再需要解包被包装的密钥，以较晚者为准
23. 公用密钥包装密钥	支持	完整性	用法或应用程序 密钥对所有者 私用密钥解包密钥	公钥有效性	从生成到密码周期结束
24. 私用密钥解包密钥	支持	机密性 完整性 可用性	用法或应用程序 被包装的密钥 公用密钥包装密钥	私钥持有	从生成到包装密钥的密码周期结束或不再需要解包密钥，以较晚者为准
25. 公用封装密钥	支持	完整性	用法或应用程序 密钥对所有者 私用解封装密钥 算法参数	公钥有效性	从生成到密码周期结束
26. 私用解封装密钥	支持	机密性 完整性 可用性	用法或应用程序 被封装的密钥 公用封装密钥 算法参数	私钥持有	从生成到不再需要解封装密钥
授权					
27. 对称授权密钥	授权	机密性 完整性	用法或应用程序 其他授权实体		从生成到密钥的密码周期结束
28. 私用授权密钥	授权	机密性 完整性	用法或应用程序 公用授权密钥 算法参数（使用时）	私钥持有	从生成到密钥对的密码周期结束

29. 公用授权密钥	授权	完整性	用法或应用程序 密钥对所有者 私用授权密钥 算法参数（使用时）	公钥有效性	从生成到密钥对的密码周期结束

5.1.2. 其他相关信息的保护要求摘要

表 8 总结了分发和存储期间其他相关信息的保护要求。提供必要保护的机制在第 5.2 节中讨论。

1. 第 1 列（信息类型）标识信息的类型。
2. 第 2 列（安全服务）指示信息提供的安全服务类型。
3. 第 3 列（安全保护）指示信息所需的安全保护类型。
4. 第 4 列（关联性保护）指示每种信息类型的相关关联性类型。
5. 第 5 列（算法参数有效性保证）指示应获得保证的信息，如 [SP 800-56A]、[SP 800-56B]、[FIPS 203]、[FIPS 204]、[FIPS 205]、[SP 800-208]、[SP 800-227] 和本文件第 4.4 节中所定义。算法参数有效性保证提供对算法参数正常确性的信心。
6. 第 6 列（保护期限）指示需要维护信息的完整性和/或机密性的时间长度。信息应在保护期结束时销毁（见第 7.3.4 节）。

表 8. 其他相关信息的保护要求

信息类型	安全服务	安全保护	关联性保护	算法参数有效性保证	保护期限
算法参数	取决于与参数关联的密钥	完整性 可用性	用法或应用程序 私钥和公钥	是	从生成到不再需要
初始化向量	取决于算法	完整性 33 可用性	受保护的数据		从生成到不再需要处理受保护的数据
共享秘密（在密钥协商期间生成）	支持	机密性 完整性			从生成到交易结束
种子	支持	机密性 完整性	用法或应用程序		用于随机数生成时，使用后立即销毁 用于重新生成密钥材料时，不再需要时销毁（例如，在密钥的密码周期结束时）
其他公开信息	支持	完整性	用法或应用程序 其他授权实体使用nonce处理的数据		从生成到不再需要使用公开信息处理数据
其他秘密信息	支持	机密性 完整性	用法或应用程序 其他授权实体使用秘密信息处理的数据		从生成到不再需要使用秘密信息处理数据
中间结果	支持	机密性 完整性	用法或应用程序		从生成到不再需要且中间结果被销毁
密钥控制信息（例如，ID、用途）	支持	完整性 可用性	密钥		从生成到关联密钥被销毁

随机数	支持	机密性（取决于用途） 完整性			从生成到不再需要，且随机数被销毁
密码	身份认证 密钥派生	机密性 完整性 可用性	用法或应用程序 拥有实体		从生成到被替换或不再需要验证实体或派生密钥
审计信息	支持	完整性 访问授权 可用性	已审计事件 密钥控制信息/元数据		从生成到不再需要

5.2. 保护机制

在密钥信息的生命周期内，密钥信息要么"在传输中"（例如，正常在通过手动或使用自动化协议分发给授权的通信参与者以供这些实体使用），"静态"（例如，密钥信息在存储中），或"使用中"。在所有情况下，密钥信息应按照第 5.1 节进行保护。

使用中的密钥应驻留（并使用）在适当的密码模块内。密钥处于使用状态并不排除该密钥同时也处于传输中和/或存储中。

在传输中或存储中时，保护机制的选择可能有所不同。虽然以下小节提供了多种保护方法，但并非所有方法都提供同等的安全性。应仔细选择方法。此外，规定的机制本身并不能保证保护。实现和相关密钥管理需要提供足够的安全性，以防止任何可行的攻击成功。

5.2.1. 传输中密钥信息的保护机制

传输中的密钥信息可能包括正常在分发的密钥材料，用于：

- 获取密码服务（例如，建立将用于提供机密性的密钥）（见第 7.1.5 节），或
- 备份或归档密钥信息以供将来可能使用或恢复（见第 7.2.2 和 7.3.1 节），或
- 恢复备份或归档的密钥信息（见第 7.2.2.2、7.3.1 节和附录 B）。

这可以通过手动（即，通过可信信使）、自动化方式（即，使用自动化通信协议）或手动和自动化方法的某种组合来完成。对于某些协议，保护由协议提供；在其他情况下，密钥信息的保护直接提供给密钥信息（例如，密钥材料在传输前被加密，仅由接收方解密）。应用保护机制是发起方的责任，撤销或检查所用机制是接收方的责任。

5.2.1.1. 可用性

由于通信可能被破坏、故意更改或销毁，仅使用密码方法无法保证传输后密钥信息的可用性。然而，可用性可以通过冗余或多通道、存储转发系统（即，仅在确认预期接收方收到后由发送方删除）、纠错码和其他非密码机制来支持。

通信系统应结合非密码机制，以确保密钥信息在传输后的可用性，而不是依赖原始发送方的重传。

5.2.1.2. 完整性

完整性保护涉及防止和检测对信息的修改。绝对防止修改是不可能的，但存在一些机制（例如，密钥确认机制）可以高概率检测修改。当检测到修改时，可以采取措施将信息恢复为其未更改的形式。密码机制通常用于此目的。应使用以下一种或多种方法获得接收密钥信息的完整性保证：

1. 手动方法（提供物理保护）：

a. 使用完整性机制在要分发的密钥信息上生成"代码"（例如，CRC、MAC 或数字签名），并将生成的代码与密钥信息一起提供给接收方。如果接收方成功验证接收的代码，则接收方保证已正常确接收密钥材料。否则，密钥信息被视为已损坏。当使用使用密钥生成代码的密码算法（例如，MAC 或数字签名）时，发送方和接收方必须知道用于生成和验证代码的适当密钥。可以使用 CRC 代替 MAC 或数字签名来生成代码，因为物理保护仅旨在防止故意修改。

-或-

b. 分发的密钥信息中的密钥用于对相互已知的数据执行预期的密码操作（例如，加密发送方和接收方都已知的明文数据）。密钥信息和密码保护的数据都发送给接收方。如果接收方可以使用接收的密钥成功逆转或验证发送方执行的密码操作（例如，使用密钥解密接收的密文数据并成功将生成的明文数据与相互已知的明文数据进行比较），则接收方保证已正常确接收密钥信息。否则，密钥信息被视为已损坏。

2. 通过通信协议自动分发（由发送实体或通信协议提供保护）：

a. 在要分发的密钥信息上使用批准的密码完整性机制（例如，MAC 或数字签名），并将生成的代码与密钥信息一起提供给接收方以进行后续验证以获得完整性保证。CRC 未获批准用于此目的。完整性机制可以仅应用于密钥信息或整个消息。

-或-

b. 密钥信息中的密钥由发送方用于对数据执行预期的密码操作（例如，在数据上计算 MAC）。密钥信息和密码保护的数据都发送给接收方。如果接收方可以成功使用密钥逆转或验证密码操作（例如，使用接收的密钥验证接收数据上的 MAC），则接收方保证已正常确接收密钥信息。否则，密钥信息被视为已损坏。

对检测到完整性失败的响应将因具体环境而异。不当的错误处理可能允许攻击（例如，侧信道攻击）。安全策略（见 [SP 800-57p2]）应定义对此类事件的响应。例如，如果在接收的密钥信息中检测到错误，并且接收方要求密钥信息完全正常确（例如，当密钥信息出错时接收方无法继续），则：

- 不应使用密钥信息，
- 接收方可以请求重新发送密钥信息（重传次数应限制为预定的最大次数），并且
- 与事件相关的信息应保存在审计日志中，以便日后识别错误来源。

5.2.1.3. 机密性

在传输期间，应使用以下一种或多种方法为秘密对称密钥、非对称私钥、密钥共享和其他秘密信息（例如，种子或秘密元数据）提供机密性保护：

1. 手动方法：

a. 使用提供安全强度达到或超过密钥材料所需安全强度（即，保护密钥要保护的数据所需的安全强度）的批准技术加密（例如，包装或封装）秘密密钥信息。

-或-

b. 将密钥分离为密钥共享，每个密钥共享的生成安全强度达到或超过密钥材料所需的安全强度（即，保护密钥要保护的数据所需的安全强度）。每个密钥共享使用分割知识程序处理（见第 7.1.5.2.1 和 7.1.5.2.2.1 节），以便任何个人都无法访问所有密钥共享。任何需要保密的元数据都应加密。

-或-

c. 提供适当的物理和程序保护（例如，通过使用可信信使）。

2. 通过通信协议自动分发： 使用提供安全强度达到或超过密钥材料所需安全强度（即，保护密钥要保护的数据所需的安全强度）的批准技术加密（例如，包装或封装）秘密密钥信息。

5.2.1.4. 与用法或应用程序的关联

密钥材料与其用法或应用程序的关联应在分发过程中明确标识（例如，包含在传输的元数据中）或由应用程序的使用隐式定义。见第 5.2.3 节讨论与密钥关联的元数据。

5.2.1.5. 与其他实体的关联

密钥材料与所有适当实体（例如，共享密钥材料的任何实体）的关联应在分发过程中明确标识（例如，使用公钥证书）或由应用程序的使用隐式定义。见第 5.2.3 节讨论与密钥关联的元数据。

5.2.1.6. 与其他相关密钥信息的关联

与任何其他相关密钥信息（例如，算法参数、加密/解密密钥、IV）的关联应在分发过程中明确标识或由应用程序的使用隐式定义。见第 5.2.3 节讨论与其他相关密钥信息关联的元数据。

5.2.2. 存储中密钥信息的保护机制

密钥信息可以存储在某些设备或存储介质上。这可能包括也在传输中或使用中的密钥信息的副本。存储的密钥信息应按照第 5.1 节进行保护。

密钥信息可以存储以便应用程序立即可用（例如，在本地硬盘或服务器上）。这对于存储在密码模块内或立即可访问的存储（例如，在本地硬盘驱动器上）中的密钥信息是典型的。密钥信息也可以以电子形式存储在可移动介质（例如，CD-ROM 或闪存驱动器）上，位于可远程访问的位置，或以硬拷贝形式放置在保险箱中。这对于备份或归档存储是典型的。

第 5.2.2.1 至 5.2.2.3 节讨论密钥信息的可用性、完整性和机密性。第 5.2.2.4 至 5.2.2.6 节讨论密钥信息与其用法、应用程序、其他实体和其他相关密钥信息的关联。第 5.2.2.7 节讨论存储介质和机制。

5.2.2.1. 可用性

只要数据受密钥保护，密钥信息就可能需要随时可用。提供这种保护的一种常见方法是制作密钥信息的一个或多个副本并将它们存储在不同的位置。在密钥的密码周期内，需要长期可用性的密钥信息应存储在正常常操作存储（见第 7.2.1 节）和备份存储（见第 7.2.2.1 节）中。在密钥的密码周期结束后保留的密钥信息应放入归档存储（见第 7.3.1 节）。本建议不排除对备份和归档存储使用相同的存储介质。

第 7.2.2.1 节（备份存储）和第 7.3.1 节（归档存储）分别讨论了每种密钥类型的长期可用性要求的具体内容。某些算法对密钥备份有严格要求（例如，[SP 800-208] 中指定的基于状态哈希的签名）。

第 7.2.2.2 节（正常常操作期间的恢复）、第 7.3.1 节（从归档存储恢复）和附录 B 讨论了恢复此密钥信息以替换丢失的密钥信息（例如，从正常常存储）或在密钥的密码周期结束后执行密码操作。

尽管本节的主要重点是提供密钥信息可用性的保证，但至少有一个示例中可能需要拒绝此密钥信息的可用性——即，在清理大量已加密的密钥信息时。在这种情况下，建议进行密码清理（即，销毁用于解密或解包密钥信息的密钥）（见 [SP 800-88]）。

5.2.2.2. 完整性

完整性保护关注确保从存储中检索的密钥信息是正常确的。虽然不可能绝对防止修改，但合理的措施可以帮助防止未经授权的修改，以非常高的概率检测发生的任何修改，并将密钥信息恢复为其原始内容。

所有密钥信息都需要完整性保护。完整性保护应通过物理机制、密码机制或两者提供。

物理机制包括使用：

- 限制对存储密钥信息访问的验证密码模块或操作系统
- 未连接到其他系统的计算机系统或介质
- 具有适当访问控制的物理安全环境，位于计算机系统外部（例如，在访问受限的保险箱中）

密码机制包括使用：

- 在将密钥信息放入存储之前计算在密钥信息上的批准的密码完整性机制（例如，MAC 或数字签名），并稍后用于验证存储密钥信息的完整性，以及
- 执行预期的密码操作。

如果检索的密钥信息不正常确，密钥材料可能已损坏。为了在检测到错误时恢复密钥信息，应在物理上分开的位置维护密钥信息的一个或多个副本（即，在备份或归档存储中；见第 7.2.2.1 和 7.3.1 节）。应定期检查每个副本的完整性。

5.2.2.3. 机密性

应使用以下机制之一为需要在存储期间保持秘密的密钥信息提供机密性：

- 在 [FIPS 140-3] 验证的密码模块中使用批准的算法进行加密（或密钥包装或封装）。加密应使用提供安全强度达到或超过密钥信息所需安全强度的批准技术。

-或-

- 由 [FIPS 140-3] 验证的密码模块在安全级别上提供的物理保护，该安全级别与密钥要保护的数据相关的 [FIPS 199] 影响级别一致（见 [SP 800-152]）。

-或-

- 由具有受控访问的安全存储（例如，保险箱或保护区）提供的物理保护。

5.2.2.4. 与用法或应用程序的关联

密钥材料与给定的密码机制（例如，生成数字签名或建立密钥）或特定应用程序一起使用。应提供保护以确保密钥材料不被错误使用（例如，不仅必须将用法或应用程序与密钥材料关联，而且必须维护此关联的完整性）。这种保护可以通过将密钥材料与其他机制或应用程序的密钥材料分开，或使用与密钥材料关联的适当元数据来提供。第 5.2.3 节讨论与密钥关联的元数据。

5.2.2.5. 与其他实体的关联

某些密钥信息需要正常确地与另一个实体（例如，密钥源或拥有或使用密钥的实体）关联，并且必须维护此关联的完整性。例如，用于加密密钥信息或计算 MAC 的秘密对称密钥需要与其他共享密钥的实体关联。公钥需要正常确地与密钥对的所有者关联（例如，使用公钥证书进行密码绑定）。

密钥信息应通过按实体、应用程序分离密钥信息，或在需要时使用密钥信息的适当元数据，在存储期间保持其关联。第 5.2.3 节讨论元数据的使用。

5.2.2.6. 与其他相关密钥信息的关联

可能需要在受保护的密钥信息和用于保护该密钥信息的密钥材料之间保持关联。此外，密钥可能需要与其他密钥材料关联（见第 5.2.1.6 节）。

将密钥信息存储在一起或在信息之间提供某种链接或指针有助于满足关联要求。通常，密钥与其保护的信息之间的链接是通过为密钥提供标识符、将标识符存储在密钥的元数据中、并将密钥的标识符与密钥保护的数据一起存储来实现的。只要需要处理受保护的数据，就应维护关联。

5.2.2.7. 密钥材料存储介质和机制

密码算法和相关密钥材料可以存储在各种地方，包括在运行算法的软件或硬件内、在 [FIPS 140-3] 验证的密码模块中、在 HSM 中、在可信平台模块 (TPM) 中、在随机存取存储器 (RAM) 中、在外部数字介质上以及在纸上。

5.2.2.7.1. 密码模块

密码模块是实现安全功能并包含在密码边界内的一组硬件、软件和/或固件。模块可以在硬件、软件、固件或混合中实现。强烈建议使用 [FIPS 140-3] 验证的密码模块。FIPS 140 引用了 [ISO/IEC 19790] 中指定的要求。指定了四个实现安全级别，按提供的保护量递增：

1. 安全级别 1 提供最低级别的安全性。软件或固件模块可以在不可修改、有限或可修改的操作环境中运行，例如通用计算系统。如果模块在硬件中实现，除了生产级组件的基本要求外，不需要特定的物理安全机制。

安全级别 1 密码模块通常依赖于其所在系统的物理安全、网络安全和管理程序。例如，密钥材料的保护可能需要由主机系统而不是密码模块处理。

主机系统和密码模块所在的物理环境可能在保护密钥材料方面发挥主要作用（例如，未经授权方对系统的可访问性）以及访问主机系统的任何安全程序。

2. 安全级别 2 增加了对密码模块或其所在设备的篡改证据要求。使用防篡改密封或防撬锁来防止未经授权的物理访问。安全级别 2 还需要基于角色的身份验证，其中密码模块验证操作员承担特定角色并执行相应服务集的授权。软件密码模块可以在可修改环境（例如，通用计算机）中执行，该环境实现基于角色的访问控制，或者至少具有用于定义组和分配限制性权限的稳健机制的自主访问控制。

除了安全级别 1 控制外，安全级别 2 密码模块依赖于基于角色的操作员身份验证和篡改证据来保护存储在模块或设备内的密钥材料。

密钥材料的安全性还取决于系统操作人员的警觉性和可信度、环境的物理安全以及访问密码模块的安全程序。

3. 安全级别 3 增加了物理安全保护，旨在高概率检测和响应试图物理访问、未经授权使用或修改密码模块的行为。安全级别 3 还：

- 要求基于身份的身份验证机制来验证操作员是否有权承担特定角色并执行相应的服务集；
- 要求使用加密、可信通道或分割知识程序输入或输出安全相关信息（例如，秘密和私密密钥）；以及
- 保护密码模块免受由于环境条件或电压和温度波动超出模块正常常操作范围而导致的安全泄露。

除了安全级别 2 控制外，安全级别 3 密码硬件模块依赖于基于身份的操作员身份验证、篡改响应和环境波动检测来保护存储在模块内的密钥材料。安全级别 3 模块还保护输入或输出模块的秘密密钥材料的机密性和完整性。

只有授权人员可以访问其内容，并且其输入和输出的机密性受到保护。

4. 安全级别 4 增加了对所有未经授权物理访问尝试的响应要求。从任何方向穿透密码模块外壳都有很高的概率被检测到，导致所有明文安全参数立即归零[34]。安全级别 4 引入了操作员身份验证的多因素身份验证要求。至少，这需要以下三个属性中的两个：

- 已知的内容，例如秘密密码
- 拥有的内容，例如物理密钥或令牌
- 物理属性，例如生物特征

安全级别 4 包括特殊的环境保护功能，旨在检测电压和温度边界并将敏感信息归零，以提供合理的保证，即模块在正常常操作范围之外受到影响时不会以可能危及模块安全的方式受到影响。

除了安全级别 3 控制外，安全级别 4 密码硬件模块依赖于多因素身份验证和增强的物理机制来保护存储在模块内的密钥材料。安全级别 4 密码模块旨在在尝试未经授权访问模块时销毁敏感信息（例如，密钥材料）。

5.2.2.7.2. 硬件安全模块

HSM 是专用硬件设备，可安全地管理密码密钥并使用这些密钥执行密码操作。HSM 构建有防篡改和防篡改外壳，并具有检测机制，如果尝试使用检测电压、温度和其他可能表明篡改的环境变化的传感器进行入侵，则将敏感数据归零。HSM 安全地管理密钥的生命周期，包括其生成、存储、分发、撤销和销毁。使用基于角色的访问控制来确保只有授权人员才能执行敏感操作。

HSM 用于公钥基础设施 (PKI) 和数字签名系统内，用作安全数字钱包，促进交易签名，用于安全代码签名，并提供对云中敏感数据的安全控制。管理易受量子攻击密码的当前 HSM 将或正常在更新以支持新的抗量子算法。

获得 [FIPS 140-3] 密码模块合规性认证的 HSM 在适当的安全级别上提供保证，即 HSM 可以有效保护敏感数据并安全地执行密码功能。此外，根据通用标准 (Common Criteria) 获得高评估保证级别 (EAL) 认证的 HSM 已证明能够满足额外的严格安全要求。

为了适当保护密钥材料，HSM 需要支持其支持的应用程序所需的密码算法范围。随着量子计算的出现，建议支持批准的抗量子算法。大多数批准的算法需要随机数输入，因此 HSM 中应包含批准的 RBG。还应提供安全备份、归档和密钥恢复的方法，以及详细的基于角色的访问控制策略和密码敏捷性，以便轻松更改密码组件。

如果将 HSM 与云服务结合使用，建议使用支持自带密钥 (BYOK)、双密钥加密 (DKE) 和自持密钥 (HYOK) 集成的 HSM，以提供利用云服务的灵活性，同时保留拥有和控制加密密钥的能力和/或降低未经授权的数据访问或数据丢失的风险。对于每个功能，密钥材料在云服务提供商拥有的 HSM 中生成并进行密码保护。使用 BYOK 功能时，客户将密钥材料发送到云端进行存储，密钥材料在传输和存储期间受到密码保护（例如，由客户的密钥包装密钥保护）。使用 DKE 时，客户将密钥材料发送给云提供商，云提供商在存储双重加密的密钥材料之前第二次加密密钥材料。需要两个密钥才能解密并随后使用原始明文密钥材料。使用 HYOK 时，客户保留密码保护的密钥材料，但将由该密钥材料保护的数据发送到云端进行存储。

虽然密钥材料在保留在 HSM 内时受到保护，但在离开 HSM 时必须以适当的安全强度进行密码保护。

5.2.2.7.3. 可信平台模块

TPM 最初被指定为专用微处理器，旨在使用集成密码密钥保护硬件。TPM 提供随机数生成器以及生成密码密钥的能力，用于有限数量的用途，包括验证设备内的硬件和软件是否未更改、生成和加密只能由 TPM 解密的密码密钥、磁盘加密以保护计算机的存储设备以及数字版权管理。这些芯片存储密钥并执行依赖于密钥的密码操作。敏感明文密钥材料在任何时候都不会离开 TPM。

最新的 TPM 版本 (TPM 2.0) 指定了五种类型的 TPM 实现：

1. 离散 TPM 是实现 TPM 功能并提供一定级别防篡改能力的专用芯片。离散 TPM 可以保护其中密钥材料的机密性和完整性。根据防篡改功能的质量，此保护可能相当于安全级别 2 或 3 密码模块（见第 5.2.2.7.1 节）。

2. 集成 TPM 仅是芯片的一部分，可能不提供防篡改能力。芯片内可提供篡改检测的集成 TPM 可以保护其中密钥材料的机密性和完整性。否则，保护（如果可用）需要由外部手段提供。这可能相当于安全级别 1 密码模块。

3. 固件 TPM 是基于固件的实现，在 CPU 的可信执行环境中运行，这是计算机主处理器的安全区域。

4. 虚拟 TPM 使用隔离执行环境中的管理程序，这些环境对虚拟机内运行的软件隐藏，以保护其代码免受虚拟机中软件的影响。

5. 软件 TPM 是模拟器 TPM，但运行时的保护不超过操作系统内常规程序获得的保护。

TPM 2.0 包括几种经典密码算法：SHA-256、RSA、带曲线 P-256 的 ECC、HMAC 和 AES-128。还定义了其他算法，但可能是可选的。通过替换 TPM 实现来完成算法更改。

TPM 通常在许多计算机系统上可用。要使用 TPM，需要使用软件库与 TPM 通信。

为密钥材料提供的保护量取决于所使用的 TPM。然而，在所有情况下，密钥材料在离开 TPM 时必须以适当的安全强度进行密码保护。

5.2.2.7.4. 随机存取存储器

随机存取存储器 (RAM) 是一种可以按任何顺序读取和更改的计算机内存形式，通常用于存储工作数据和机器代码。RAM 中的数据可以几乎以相同的时间量读取或写入，无论数据在内存内的物理位置如何。然而，RAM 通常是易失性内存（即，如果断电，存储的信息会丢失）。非易失性 RAM 也已开发出来，其他类型的非易失性内存允许随机访问读取操作，但不允许写入操作或有其他类型的限制。

存储在 RAM 中的密钥材料需要由适当的密码模块应用密码保护。如果内存是易失性的，并且数据要在断电后保留，则需要备份或归档（例如，使用外部介质；见第 5.2.2.7.5 节）。

5.2.2.7.5. 外部数字介质

密钥材料可以存储在外部数字介质上，例如 CD-ROM、DVD、闪存驱动器、外部硬盘驱动器、磁带或其他可移动存储设备。存储在外部介质上的密钥材料应加密，并且介质应物理安全地存储。

智能卡的寿命有限。密码保护的长期密钥材料和数据必须备份或归档在更可靠、长期的介质上。

密钥材料可以打印或打孔到纸或其他物理介质上。密钥材料可以加密、分割成多个密钥组件，或使用双重控制程序处理。打印或打孔的密钥材料可以是明文形式，尽管不建议这样做。不使用时，打印或打孔的密钥材料应存储在物理保险箱中。

只要需要移除或验证应用于信息的任何密码保护，就应备份或归档密钥材料。

5.2.3. 密钥的元数据

元数据用于提供有关密钥的信息，包括其属性和预期用途。不同的应用程序可能需要相同密钥类型的不同元数据元素，不同的密钥类型可能需要不同的元数据元素。实施者负责为密钥选择合适的元数据元素。使用元数据时，元数据应伴随密钥（即，元数据通常与密钥一起存储或传输）。但是，根据应用程序和实现，某些元数据可能是明确已知的（例如，所有信息具有相同的敏感性，或所有密钥由单个应用程序使用）。

元数据元素的一些示例包括：

- 用于（重新）生成密钥或密钥对的种子（如果适用）
- 密钥标识符
- 要与密钥一起使用的算法
- 标识关联密钥的信息（例如，公钥和私钥之间的关联）
- 密钥所有者的身份或共享实体的标识符
- 如果所有者是非人类实体，则所有者的赞助商或代表的身份
- 如果所有者是设备或进程，则设备或进程的位置
- 密钥的密码周期（例如，使用密钥保护或处理信息的开始和结束日期）
- 密钥类型（例如，签名私钥、加密密钥或解封装密钥）
- 密钥材料的来源（即，提供密钥的实体）
- 要使用密钥的应用程序（例如，采购或电子邮件）
- 密钥保护信息的敏感性
- 计数器，用于检测先前传输的密钥的重放
- 当前密钥状态（即，预激活、活跃、暂停、泄露或销毁）
- 密钥的状态和/或历史（即，已分发、暂停或撤销，并附有撤销原因）
- 用于封装/解封装密钥的密钥封装密钥或解封装密钥的身份以及用于封装或解封装的算法
- 使用的完整性保护机制（例如，用于为密钥信息和保护代码提供密码保护的密钥和算法）

- 其他信息（例如，密钥的长度、任何保护要求、谁有权访问密钥，或使用的附加条件）

[SP 800-152] 提供了有关元数据使用的附加信息，包括保护其完整性和与相关密钥关联的指南。

6. 密钥状态和转换

密钥在其生成和销毁之间可能经过多个状态。图 3 描述了密钥可能采用的密钥状态示例以及它们之间的转换。

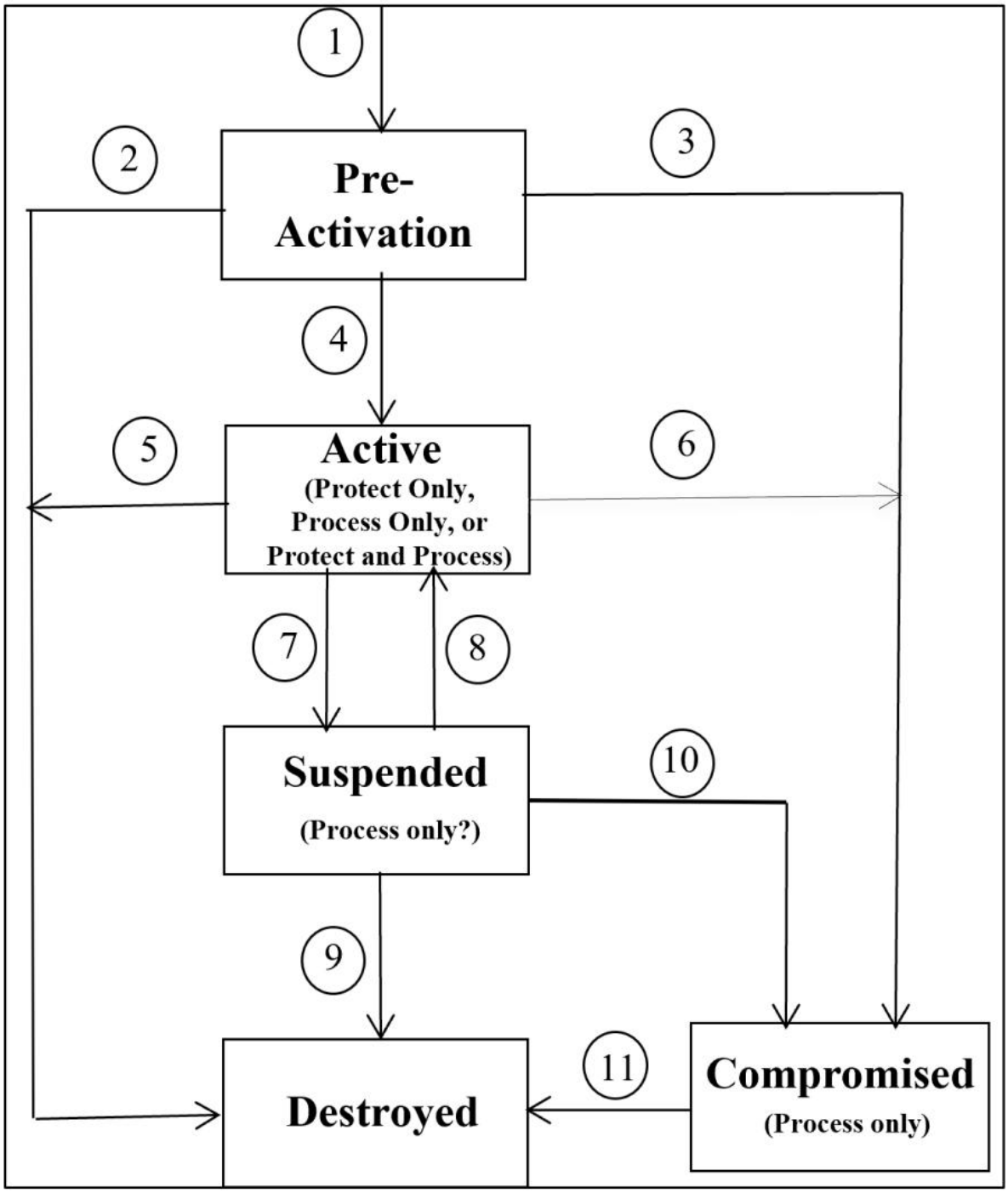

图 3. 密钥状态和转换示例

密钥的使用可能因其密钥生命周期中的状态而异。密钥状态是从系统角度定义的，而不是从单个密码模块的角度定义。以下各节讨论操作或备份密钥可能采用的状态以及向其他状态的转换，如图 3 所示。某些系统可能适用附加状态（例如，停用和销毁泄露状态，这些状态在此建议的先前版本中提供的示例中描述），某些已识别的状态可能不需要用于系统（例如，可以决定不使用暂停状态）。

应记录状态之间的转换。此类记录的合适位置是审计日志和密钥的元数据（见第 5.2.3 节）。[SP 800-152] 讨论了这些事件的日志记录，包括应为每个事件记录的最少信息。

以下各节讨论图 3 中提供的示例状态和转换。

6.1. 预激活状态

密钥已生成但尚未授权使用。要清点的密钥（例如，长期密钥）应在生成时进行清点（见第 8.2 节）。

在此状态下，密钥只能用于执行所有权证明（第 7.1.5.1.1.2 节）或密钥确认（见 [SP 800-175B]）。否则，密钥在此状态下不得用于对信息应用密码保护（例如，加密或签署要传输或存储的信息）或处理密码保护的信息（例如，解密密文或验证数字签名）。

状态转换 1（进入预激活状态）：密钥在生成后立即进入预激活状态。

应记录有关密钥生成的信息。

- 状态转换 2（预激活状态到销毁状态）：如果密钥处于预激活状态且将来不需要，则密钥应直接从预激活状态转换到销毁状态（第 6.5 节）。对于非对称密钥，密钥对的两个密钥都应转换到销毁状态。
- 状态转换 3（预激活状态到泄露状态）：当密钥处于预激活状态，并且密钥的完整性或需要机密性保护的密钥的机密性变得可疑时，则密钥应从预激活状态转换到泄露状态（第 6.4 节）。对于非对称密钥，密钥对的两个密钥都应转换到泄露状态。

  如果多个实体知道该密钥，则应生成撤销通知。
- 状态转换 4（预激活状态到活跃状态）：当密钥可用于操作使用时，密钥应从预激活状态转换到活跃状态（第 6.2 节）。此转换可能在达到激活日期时发生，或因外部事件而发生。如果密钥是即时生成的，则转换在进入预激活状态后立即发生。

  对于与证书关联的非对称密钥，密钥对的两个密钥在首次为密钥对的公钥颁发的证书中的 notBefore 日期（如果使用）时变为活跃。

  此转换标志着对称密钥的密码周期或非对称密钥对的两个密钥的密码周期的开始（见第 4.3 节）。

6.2. 活跃状态

在活跃状态下，密钥可用于密码保护信息（例如，加密明文或生成数字签名）、密码处理先前受保护的信息（例如，解密密文或验证数字签名），或两者兼有。当密钥活跃时，根据其类型，可以指定仅用于保护、仅用于处理，或同时用于保护和处理。例如，非对称私签名密钥、公钥传输密钥和公静态/临时封装密钥隐式指定仅用于应用保护。公签名验证密钥、私钥传输密钥和私静态/临时解封装密钥指定仅用于处理。对称数据加密密钥可在其发起者使用期间加密数据，并在其接收者使用期间解密加密数据（见第 4.3.5 节）。不允许的密钥应仅用于处理（见 [SP 800-131A]）。

应记录活跃状态下每个密钥的使用（见 [SP 800-152]）。

状态转换 5（活跃状态到销毁状态）：如果密钥不再需要或达到其密码周期结束，则密钥从活跃状态转换到销毁状态，如表 9 所示。

表 9. 从活跃状态到销毁状态的转换

密钥类型	转换 5：活跃到销毁状态
数字签名	
1. 私签名密钥	在密码周期结束时（例如，当为公钥颁发的最后一个证书达到 notAfter 日期时）
2. 公签名验证密钥	当不再需要时
身份验证	
3. 对称身份验证密钥	在接收者使用期结束时或当不再需要时
4. 私身份验证密钥	在密码周期结束时（例如，当为公钥颁发的最后一个证书达到 notAfter 日期时）
5. 公身份验证密钥	当不再需要时
随机位生成	
6. 对称 RBG 密钥	当被新密钥替换时或当 RBG 不再使用时
密钥派生	
7. 对称密钥派生密钥	在发起者使用期结束时或当不再需要时
密钥建立（自动化）	
8. 对称密钥封装/解封密钥	在接收者使用期结束时或当不再需要时
9. 公钥传输密钥	在密码周期结束时（例如，当为公钥颁发的最后一个证书达到 notAfter 日期时）
10. 私钥传输密钥	当不再需要时
11. 对称密钥协商密钥	在接收者使用期结束时或当不再需要时
12. 公静态密钥协商密钥	在密码周期结束时（例如，当为公钥颁发的最后一个证书达到 notAfter 日期时）
13. 私静态密钥协商密钥	通常应在公钥的密码周期结束时转换（见 [SP 800-131A] 了解例外情况）
14. 公临时密钥协商密钥	使用后立即
15. 私临时密钥协商密钥	
16. 公静态封装密钥	在密码周期结束时（例如，当为公钥颁发的最后一个证书达到 notAfter 日期时）
17. 私静态解封装密钥	当不再需要时
18. 公临时封装密钥	使用后立即
19. 私临时解封装密钥	
数据加密/解密	
20. 传输中数据的对称数据加密/解密密钥	在接收者使用期结束时或当不再需要时

21. 静态数据的对称数据加密/解密密钥	
密钥存储（用于操作、备份和归档存储）	
22. 对称密钥封装/解封密钥	在接收者使用期结束时或当不再需要时
23. 公密钥封装密钥	在其密码周期结束时
24. 私密钥解封密钥	当不再需要时
25. 公封装密钥	在其密码周期结束时
26. 私解封装密钥	当不再需要时
授权	
27. 对称授权密钥	在发起者使用期结束时
28. 私授权密钥	在其密码周期结束时（例如，当为相应公钥颁发的最后一个证书达到 notAfter 日期时）
29. 公授权密钥	

状态转换 6（活跃状态到泄露状态）：当对称密钥或对称密钥的机密性或完整性，或非对称私钥的机密性变得可疑时，对称密钥或非对称密钥对应从活跃状态转换到泄露状态（见第 6.4 节）。在这种情况下，密钥或密钥对应被撤销。对于非对称密钥对，泄露明确涉及密钥对的私钥，但两个密钥应同时转换到泄露状态。例如，当私签名密钥、私钥传输密钥或私静态/临时解封装密钥被泄露或涉嫌泄露时，相应的公钥也需要转换到泄露状态。

如果多个实体知道该密钥，则应生成撤销通知。

状态转换 7（活跃状态到暂停状态）：当应用程序使用暂停状态时（见第 6.3 节），并且密钥或密钥对在一段时间内（即，暂停期）不使用，对称密钥或密钥对的两个密钥应从活跃状态转换到暂停状态。例如，私签名密钥可能被暂停，因为与密钥关联的实体正常在休假，或者怀疑密钥可能已被泄露。在后一种情况下，暂停将允许在启动成本高昂的撤销和替换过程之前调查密钥的状态。

对称 RBG 密钥应转换到泄露状态并被替换，而不是保留在暂停状态。

如果多个实体知道该密钥或密钥对，则应生成指示暂停和原因的通知。

6.3. 暂停状态

非临时密钥或密钥对的使用可能因多种原因被暂停[36]。一个原因可能是可能的密钥泄露，在这种情况下，可能会发出暂停以允许时间调查情况。另一个原因可能是拥有数字签名密钥对的实体不可用（例如，该实体正常在长期休假）。在暂停期间据称签名的签名将无效。根据暂停的原因，暂停的密钥或密钥对可以恢复到活跃或销毁状态，或可能转换到泄露状态。

暂停的密钥不得用于应用密码保护（例如，加密明文或生成数字签名）。但是，根据暂停的原因，暂停的密钥可用于处理已知在暂停期之前应用了密码保护的信息。这包括使用公验证密钥验证数字签名、使用对称数据加密密钥解密加密信息、使用对称密钥封装密钥解封密钥材料，以及使用私解封装密钥解封装封装的密钥。如果暂停的原因是涉嫌泄露，则可能不谨慎使用公钥验证任何签名，除非且直到密钥对随后被重新激活（即，密钥未泄露），即使风险是可接受的。但是，如果原因是所有者正常在休假，则可能有必要验证已知在暂停期开始之前生成的签名。

已知在暂停期间应用了保护的信息不得处理。

状态转换 8（暂停状态到活跃状态）：当暂停的原因不再存在且密码周期结束时未达到时，处于暂停状态的密钥或密钥对应转换到活跃状态。对于对称密钥，转换需要在密钥的接收者使用期结束之前进行。
状态转换 9（暂停状态到销毁状态）：如果未确定泄露且密钥不再需要或已达到密码周期结束，则密钥可以从暂停状态转换到销毁状态（第 6.5 节）。有关每种密钥类型到销毁状态的转换，见第 6.2 节中的表 9。
状态转换 10（暂停状态到泄露状态）：当密钥的完整性或需要机密性保护的密钥的机密性变得可疑或被确认时，处于暂停状态的密钥或密钥对应转换到泄露状态。在这种情况下，密钥或密钥对应被撤销。

对于非对称密钥对，公钥和私钥应同时转换。

如果多个实体知道该密钥，则应生成撤销通知。

6.4. 泄露状态

通常，当密钥被提供给未经授权的实体或由未经授权的实体确定时，密钥就会被泄露。泄露的密钥[37]不得用于对信息应用密码保护。但是，泄露的对称密钥或对应于密钥对的泄露私钥的公钥有时可用于处理密码保护的信息。例如，可以验证签名以确定签名数据的完整性，如果其签名自泄露发生之前就已经受到物理保护，或者签名数据中包含了可靠的时间戳。此处理只能在高度受控的条件下进行，并且信息用户完全了解可能的后果。

状态转换 11：当怀疑泄露时，以下密钥应立即转换到销毁状态：

1. 私签名密钥
2. 私身份验证密钥
3. 对称 RBG 密钥
4. 对称密钥派生
5. 公钥传输密钥
   12-15. 私钥和公钥协商密钥（静态和临时）
   16, 18. 用于密钥存储的公封装密钥（静态和临时）
6. 对称密钥封装/解封密钥
7. 用于密钥存储的公密钥封装密钥
8. 用于密钥存储的公封装密钥
9. 对称授权密钥
   28, 29. 公和私授权密钥

以下密钥在需要时可以继续使用来处理受保护的信息，除非接受处理的信息携带太大风险，此时它们应转换到销毁状态：

2. 公签名验证密钥（用于验证使用相应私签名密钥生成的签名）
3. 对称身份验证密钥（用于验证使用此密钥生成的 MAC）
4. 公身份验证密钥（用于验证使用相应私身份验证密钥生成的签名）
5. 对称密钥封装/解封密钥（用于解封使用此对称密钥封装密钥封装的密钥）
6. 私钥传输密钥（用于解密使用相应公钥传输密钥加密的密钥）
7. 对称密钥协商密钥（用于确定商定的密钥）
   17, 19. 私解封装密钥（用于解封装为密钥建立封装的密钥，静态和临时）
   20, 21. 对称数据加密/解密密钥（用于解密使用此密钥加密的数据）
8. 用于存储的私密钥解封密钥（用于解封存储的密钥）
9. 私解封装密钥（用于解封装存储的密钥）

密钥在不再需要时应转换到销毁状态。

6.5. 销毁状态

转换到此状态会导致密钥的销毁。即使密钥在此状态下不再存在，某些元数据（例如，所有者的身份、密钥状态转换历史、密钥名称、类型和/或密码周期）可以保留用于审计目的（见第 7.4 节）。
在密钥已被销毁后可能会确定密钥的泄露。在这种情况下，应记录该事件（见 [SP 800-152]）。

7. 密钥管理阶段和功能

密码密钥管理生命周期可以分为四个阶段。在每个阶段，密钥处于第 6 节中讨论的某些特定密钥状态。此外，在每个阶段内，通常会执行某些密钥管理功能。这些功能对于管理密钥及其关联的元数据是必要的。

密钥管理信息称为元数据，可能包括与该密钥关联的人员或系统的身份，或该人员被授权访问的信息类型。元数据由应用程序用于为特定服务选择适当的密码密钥。虽然元数据不出现在密码算法中，但它对于应用程序和应用程序协议的实现至关重要。有关元数据的附加讨论，见第 5.2.3 节。

在密码密钥管理生命周期的各个阶段，密钥处于特定密钥状态（见第 6 节），通常会执行某些密钥管理功能。这些功能对于管理密钥及其关联的元数据是必要的。

密钥管理的四个阶段是：

1. 预操作阶段：密钥材料尚不可用于正常常密码操作。密钥可能尚未生成或处于预激活状态。系统或企业属性也在此阶段建立。
2. 操作阶段：密钥材料可用并正常常使用。密钥处于活跃或暂停状态。活跃状态的密钥可以指定为仅保护、仅处理，或允许同时用于保护和处理。暂停状态的密钥有时可以仅用于处理（见第 6.3 节）。
3. 后操作阶段：密钥材料不再正常常使用，但可以访问密钥材料，并且密钥材料可用于处理受保护的信息。密钥处于泄露状态或已从归档临时重新激活（见第 7.3.1 节）。
4. 销毁阶段：密钥处于销毁状态且不再可用。其存在的记录可能已被销毁或未被销毁，但密钥的元数据（例如，密钥名称、类型、密码周期、使用期）可以保留（见第 7.4 节）。

密钥管理阶段的流程图如图 4 所示。

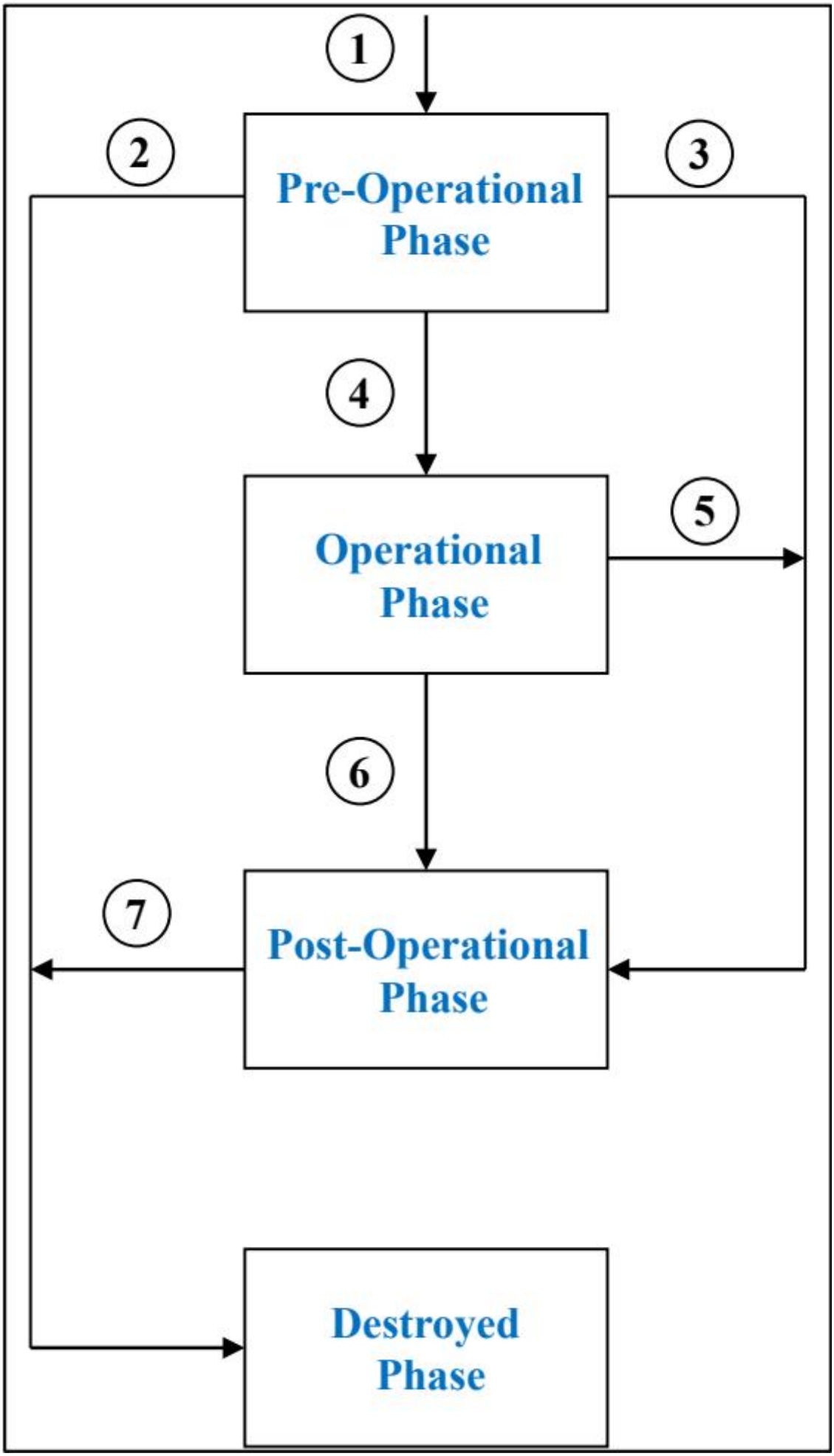

图 4. 密钥管理阶段

有七个阶段转换，密钥不得能够转移回任何先前的阶段：

1. 阶段转换 1：密钥在生成时处于预操作阶段（预激活状态）。
2. 阶段转换 2：如果生成了密钥但从未使用，则可以通过从预操作阶段直接转换到销毁阶段来销毁它们。
3. 阶段转换 3：当预操作阶段中的密钥被泄露时，它转换到后操作阶段（泄露状态）。
4. 阶段转换 4：在预操作阶段建立了所需的元数据、生成了密钥材料并将元数据与密钥关联后，密钥已准备好供应用程序使用，并在适当时转换到操作阶段。
5. 阶段转换 5：当操作阶段中的密钥被泄露时，它转换到后操作阶段（泄露状态）。
6. 阶段转换 6：当密钥不再需要正常常使用时（例如，已达到密码周期结束且密钥不再"活跃"），但需要保持对这些密钥的访问，密钥转换到后操作阶段。
7. 阶段转换 7：某些应用程序将要求访问保留一段时间，然后可以销毁密钥材料。当明确后操作阶段中的密钥不再需要时，它可以转换到销毁阶段。

密钥状态和密钥阶段的组合如图 5 所示。

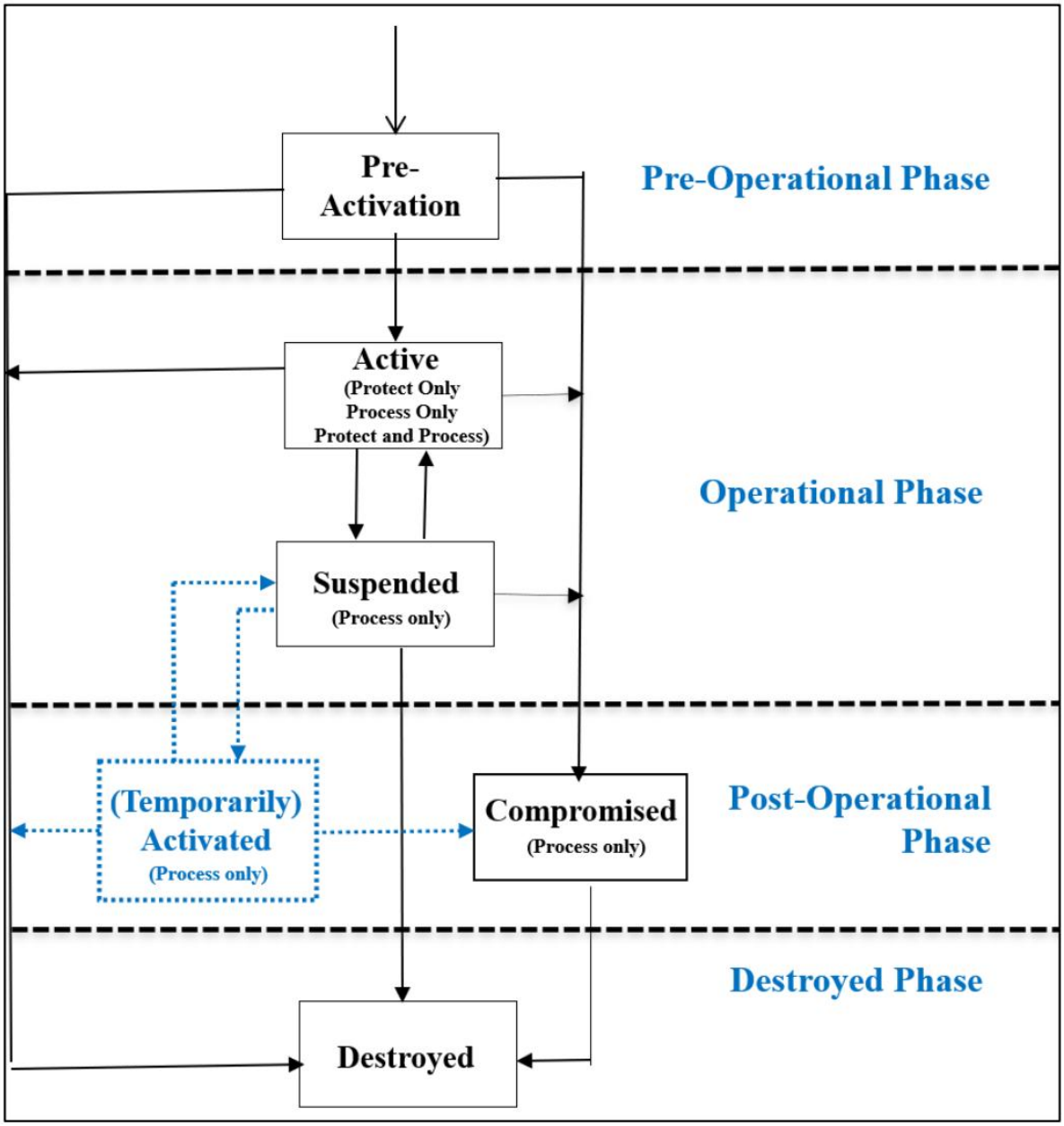

图 5. 密钥管理状态和阶段

以下小节讨论在密钥管理的每个阶段执行的功能。对"系统"的引用是指处理密钥的系统，无论系统是使用某些协议的客户端还是整个密钥管理系统。密钥管理系统可能执行许多功能，但并非具有所有已识别的功能，因为某些功能可能不合适。在某些情况下，一个或多个功能可以合并，或者功能可以按不同的顺序执行。例如，如果密钥在不再用于应用密码保护或被泄露时立即销毁，则系统可以省略后操作阶段的功能。在这种情况下，密钥将从操作阶段直接移动到销毁阶段。

7.1. 预操作阶段

在密钥管理的预操作阶段，密钥材料尚不可用于正常常密码操作。

7.1.1. 实体注册功能

在注册到密钥管理系统期间，实体与注册机构交互以成为安全域的授权成员。在此阶段，可以建立实体标识符以在未来的交易中识别成员。特别是，安全基础设施可以将身份信息与实体的密钥关联（见第 7.1.5 节和 7.1.6 节）。实体可以提供各种信息，例如电子邮件地址和实体的角色，并且系统管理员可以建立授权信息。与身份信息一样，基础设施可以将此信息与实体的密钥关联，以支持安全的应用程序级安全服务。

由于应用程序将依赖于此过程中建立的身份，因此至关重要的是建立和使用适当的身份验证程序（即，身份验证）。身份验证通常由组织执行（例如，由组织的安全办公室执行），但也可以由密钥管理系统的注册机构执行。安全基础设施的强度（或弱点）通常取决于身份识别过程。[FIPS 201-3] 和 [SP 800-63] 解决了建立身份的要求。

实体和密钥注册（见第 7.1.6 节）可以分别执行或同时执行。如果分别执行，实体注册过程通常会建立一个秘密值（例如，密码或 PIN、MAC 密钥），该值可用于在密钥注册步骤中验证实体的身份。如果实体和密钥注册同时执行，则实体在同一过程中建立身份并执行密钥注册，因此不需要秘密值。

7.1.2. 系统初始化功能

系统初始化涉及设置或配置系统以进行安全操作。对于处理密钥的系统，这可能包括算法首选项、可信方的识别，以及算法参数策略和任何可信参数（例如，公认的证书策略）的定义。

7.1.3. 初始化功能

初始化由实体初始化其密码应用程序组成（例如，安装和初始化软件或硬件）。这涉及使用或安装可能在实体注册期间获得的任何初始密钥材料（见第 7.1.4 节）。示例包括在 CA 安装密钥、信任参数、策略、可信方和算法首选项。

7.1.4. 密钥材料安装功能

密钥材料安装的安全性对于系统的安全性至关重要，无论密钥材料是在系统内生成（例如，在系统的密码模块中）还是在另一个系统内生成并随后安装在目标系统中。对于此功能，使用各种技术在实体的软件、硬件、系统、应用程序、密码模块或设备内安装密钥材料以供操作使用。在初始设置期间、当将新密钥材料添加到现有密钥材料时，以及当替换现有密钥材料时（例如，通过重新密钥或密钥派生；见第 7.2.3 节和 7.2.4 节），安装密钥材料。

初始安装密钥材料的过程（例如，通过手动输入、使用电子密钥加载器，或制造商在制造期间）应包括在输入到软件、硬件、系统、应用程序、设备或密码模块期间保护密钥材料，并包括可能需要的任何附加程序。该过程应考虑到 [FIPS 140-3] 的要求及其对不同保护级别的不同要求。

许多制造商提供带有密钥材料的应用程序或系统，用于测试新安装的应用程序/系统是否正常常运行。此测试密钥材料不得用于操作。

密钥建立涉及密钥材料的生成和分发，或实体之间通信的密钥材料协议。所有密钥应在 [FIPS 140-3] 验证的密码模块内生成，或从另一个获准保护国家安全信息的来源获取。长期密钥应进行清点（见第 8.2 节）。在密钥建立过程中，某些密钥材料可能在传输中（即，密钥材料正常在手动或使用自动化协议分发）。其他密钥材料可能本地保留而不是分发。无论哪种情况，都应根据第 5 节保护密钥材料。

实体可以是个人（人类）、组织、设备或进程。当实体为其自己的使用生成密钥材料时，应使用第 5.2.2 节中存储信息的一个或多个适当保护机制。密钥的"所有者"是被授权使用密钥的实体。当所有者不是人类时（即，所有者是组织、设备或进程），所有者通常由授权人类代表或赞助商协助获取和管理密钥材料（例如，获取和安装密钥和证书）。

在实体之间或实体与其子实体（例如，组织内的各个个人、设备或进程）之间分发的密钥材料应在分发期间使用第 5.2.1 节中指定的一个或多个适当保护机制进行保护。任何未分发的密钥材料（例如，密钥对的私钥或对称密钥自己的副本）或接收并随后存储的密钥材料应使用第 5.2.2 节中指定的一个或多个适当保护机制进行保护。

第 7.1.5.1 节和 7.1.5.2 节分别讨论非对称和对称密钥的生成和分发。[SP 800-133] 讨论密钥材料的生成。

7.1.5. 密钥建立功能

7.1.5.1. 非对称密钥对的生成和分发

密钥对应根据适当的批准 FIPS 或 NIST SP 的数学规范生成。

静态密钥对应由 1) 拥有密钥对的实体（即，在密码计算中使用私钥的实体）或 2) 根据第 7.1.5.1.3 节分发密钥对的可信设施，或 3) 所有者和设施在合作过程中生成。

对于数字签名密钥对（即，公签名验证密钥及其关联的私签名密钥），密钥对的预期所有者应生成密钥材料，而不是任何其他实体为该所有者生成密钥材料。这将有助于支持不可否认性。当由拥有密钥对的实体生成时，私签名密钥不得分发给其他实体。但是，当所有者是组织时，可以将密钥材料分发给组织的子实体（例如，员工或设备）。在这种情况下，组织是真正常的所有者，子实体代表所有者。

临时密钥通常用于密钥建立，代替或与静态密钥一起使用（见 [SP 800-56A] 和 [SP 800-227]）。临时密钥对由所有者为每个新密钥建立事务生成（例如，每个消息或会话唯一）。

生成的密钥对应根据第 5.1.1 节进行保护。

7.1.5.1.1. 公钥的分发

静态公钥的寿命相对较长，通常用于算法的多次执行。临时公钥仅使用一次。静态或临时公钥的分发应向公钥的接收者提供保证，即密钥的真正常所有者是已知的（即，声称的所有者是实际所有者）。如果匿名性是可接受的，则可以忽略此要求。但是，整体架构的强度和对受保护数据有效性的信任在很大程度上取决于对公钥所有者身份的保证。

此外，公钥的分发应向接收者提供以下保证：

1. 密钥的用途/使用是已知的（例如，用于 RSA 数字签名、椭圆曲线密钥协商、密钥封装）；
2. 与公钥关联的任何参数是已知的；
3. 公钥是有效的（例如，公钥满足所需的算术属性）；以及
4. 所有者实际拥有相应的私钥。

7.1.5.1.1.1. PKI 中信任锚公钥的分发

可信认证机构 (CA) 的公钥是所有基于 PKI 的安全服务的基础；可信 CA 被视为信任锚[38]。信任锚的公钥不是秘密，但该公钥的真实性是 PKI 的关键假设。信任锚公钥可以通过许多不同的机制获得，并提供不同级别的保证。机制的类型可能取决于实体在基础设施中的角色。仅作为"依赖方"（即，可能没有在基础设施中注册密钥的实体）的实体可能使用与拥有基础设施注册密钥的实体不同的机制。信任锚公钥经常作为根 CA 证书分发，这是由证书中公钥对应的私钥签名的"自签名"X.509 证书。

信任锚证书通常嵌入在应用程序中并随应用程序分发。例如，新网络浏览器的安装通常包括安装或替换实体的信任锚证书列表。操作系统通常附带信任锚证书，用于各种目的，包括验证其他证书。实体依赖软件分发机制的真实性，以确保在安装或替换期间仅安装有效的信任锚证书。

其他应用程序有时会在网络浏览器中安装信任锚证书，用于多种目的，包括验证 TLS 协议中显示的 TLS 证书。访问具有不是由信任锚 CA 颁发的证书的"安全"网站的实体可能会有机会接受该证书，无论是单次会话还是永久接受。

漫游用户应意识到，他们隐式信任他们使用的主机系统上的所有软件。当他们使用信息亭、图书馆、网吧或酒店中的系统，以及会议组织者提供的访问"安全网站"的系统时，他们应该对网络浏览器使用的信任锚证书感到担忧。用户无法控制主机系统中安装的信任锚证书，因此，用户依赖主机系统管理员对允许哪些信任锚证书做出良好、明智的决定。

依赖方应谨慎接受来自未知 CA 的证书，以免无意中添加不可信的新永久信任锚证书。当信任锚证书在软件分发之前预安装时，依赖方不是信任锚证书选择的参与者，并且此后可能对安装哪些信任锚证书没有任何决定权。用户应意识到，他们信任软件分发机制不会导致安装恶意代码。将此信任扩展到涵盖给定应用程序的信任锚证书可能是合理的，并允许依赖方无需任何附加程序即可获得信任锚证书。

实体（或实体的代表）与基础设施安全交互以注册其密钥（例如，获取证书），这些交互可以扩展为以信任锚证书的形式提供信任锚信息。这允许建立信任锚证书，其保证程度与基础设施对实体密钥的保证程度大致相同。在 PKI 的情况下：

1. 信任锚证书的初始分发应与在证书请求过程中向注册机构 (RA) 或 CA 呈现请求实体的公钥结合执行。通常，信任锚的公钥、关联参数、密钥使用和拥有保证作为自签名 X.509 公钥证书（也称为根 CA 证书）传达。在这种情况下，证书已由证书内公钥对应的私钥数字签名。虽然参数和拥有保证可以在自签名证书中传达，但与信任锚证书关联的身份和其他信息无法从自签名证书本身验证（见下面第 2 项）。
2. 用于向 RA 或 CA 传达请求实体的公钥和保证的可信过程也应保护传达给请求实体的信任锚证书。如果请求实体（或实体的代表）亲自出现，则可以当时提供信任锚证书。如果在实体注册期间建立了秘密值（见第 7.1.1 节），则可以随请求实体的证书一起提供信任锚证书。

7.1.5.1.1.2. 提交给注册机构或认证机构

公钥可以提供给 CA 或 RA 以进行后续认证。在此过程中，RA 或 CA 应从提交密钥的实体（即，密钥的所有者或授权代表）获得第 7.1.5.1.1 节中列出的保证和所有者的身份。

通常，密钥的所有者根据实体注册期间建立的标识符进行识别（见第 7.1.1 节）。在实体注册期间，确定密钥的适当用途以及任何所需参数。如果公钥的匿名所有权是可接受的，则提交者或注册机构确定用作标识符的假名。标识符对于命名机构应是唯一的[39]。

所有权证明 (POP) 是 CA 在密钥注册期间获得私钥拥有保证的常用机制。在这种情况下，证明应由密钥对的声称所有者提供。如果没有拥有保证，CA 可能会将公钥绑定到错误的实体。

（声称的）所有者应通过使用私钥执行满足指示密钥用途的操作来提供 POP。例如：

- 如果密钥对用于 ML-DSA 数字签名生成，CA 可以提供要使用所有者的私钥签名的信息。如果 CA 可以使用相应的公钥正常确验证签名，则所有者已建立 POP。
- 如果密钥对用于密钥传输（如 [SP 800-56B] 中指定）或密钥封装（如 [SP 800-227] 中指定），CA 可以使用所有者的公钥提供密文。如果所有者可以正常确解密密文，则所有者已建立 POP。
- 当密钥对用于支持密钥建立（即，密钥协商或密钥传输），并且密钥对是按照 [FIPS 186-5][40] 生成时（见 [SP 800-56A] 和 [SP 800-56B]），POP 可以通过使用私钥数字签名证书请求来提供，尽管这不是首选方法。私钥建立密钥（即，私钥协商或私钥传输密钥）在证书颁发后不得用于执行签名操作。

与实体注册一样，安全基础设施的强度取决于将密钥分发到 RA 或 CA 所使用的方法。有许多不同的方法，每种方法都适用于某些范围的应用程序。例如：

- 公钥和第 7.1.5.1.1 节中确定的信息由公钥所有者或公钥所有者的授权代表（例如，组织、设备、进程）亲自提供。
- 公钥所有者或公钥所有者的授权代表的身份在实体注册期间由 RA 或 CA 亲自建立并验证其授权。此时，RA 或 CA 向所有者或授权代表提供唯一、不可预测的信息（例如，认证器、密码密钥）作为秘密值。第 7.1.5.1.1 节中确定的信息和公钥使用受秘密值保护的通信协议提供给 RA 或 CA。如第 7.3.4 节所指定，密钥所有者或所有者的代表在收到证书已成功生成的确认后应销毁秘密值。RA 或 CA 可以维护此秘密值用于审计目的，但 RA 或 CA 不应接受进一步使用秘密值来证明身份。

- 当特定公钥所有者列表被预先授权注册密钥时，可以在所有者不在场的情况下分配标识符。在这种情况下，保护秘密值不被泄露至关重要，并且程序应证明保持了监管链。秘密值的生命周期应有限，但应允许公钥所有者或所有者的代表出现在 RA 或 CA，生成密钥，并将公钥（在秘密值的保护下）提供给 RA 或 CA。由于公钥所有者或所有者的代表可能需要一些时间才能出现在 RA 或 CA，因此秘密值的两到三周生命周期是合理的。
- 当公钥所有者未被预先授权时，RA 或 CA 应在所有者或代表在场的情况下确定标识符。在这种情况下，如果密钥对是现场生成的，并且公钥提供给 CA 或 RA，则时间限制可能更加严格。在这种情况下，秘密值的 24 小时生命周期是合理的。
- 公钥所有者的身份在 RA 或 CA 使用先前确定的公钥所有者身份建立。还验证继续接收证书的授权。重新认证涉及将新的公钥证书请求"链接"到先前认证的数字签名密钥对。例如，新的公钥证书请求由要认证的新公钥的所有者签名。用于签名请求的私签名密钥应对应于由将认证新公钥的同一 CA 认证的公签名验证密钥。请求包含新公钥和任何密钥相关信息（例如，密钥用途和参数）。此外，CA 应获得公钥有效性保证和保证所有者拥有相应私钥。
- 公钥、密钥用途、参数、有效性保证信息和拥有保证与所有者的声称身份和接收证书的授权一起提供给 RA 或 CA。RA 或 CA 将公钥所有者身份和授权的验证委托给另一个可信过程（例如，美国邮政服务在递送包含请求证书的挂号邮件时检查公钥所有者的身份）。收到认证请求后，RA 或 CA 使用可信过程（例如，通过美国邮政服务发送的挂号邮件）生成并向请求者发送唯一、不可预测的信息（例如，认证器或密码密钥）。可信过程确保在递送 RA 或 CA 提供的信息之前验证请求者的身份。所有者或所有者的代表使用此信息证明可信过程成功，RA 或 CA 随后将证书递送给所有者或所有者的代表。如第 7.3.4 节所指定，密钥所有者或代表在收到证书已成功生成的确认后应销毁唯一、不可预测的信息。RA 或 CA 可以维护此信息用于审计目的，但不应接受进一步使用唯一标识符来证明身份。
- 公钥和要包含在证书的通用名称或主题备用名称中的域名系统 (DNS) 地址通过网络安全连接提供给 RA。RA 通过执行 DNS 记录的地址挑战、通过 HTTP 对 DNS 地址执行挑战，或获得某种其他形式的验证来确认请求者有权为 DNS 地址请求证书，以确认 DNS 地址的授权。

在涉及 RA 的情况下，收到来自请求实体的所有信息（例如，新公钥的所有者）后，RA 将相关信息转发给 CA 进行认证。RA 和 CA 应共同执行公钥将使用的算法所需的任何验证或其他检查（例如，公钥验证），然后再颁发证书。CA 应指示将执行或已执行的检查或验证（例如，在证书、证书策略或认证实践声明中）。生成后，根据 CA 的认证实践声明，证书手动或使用自动化协议分发给 RA、公钥所有者或所有者的代表，或证书存储库（即，目录）。

7.1.5.1.1.3. 静态公钥的常规分发

静态公钥可以通过多种方式分发给 RA 或 CA 以外的实体，例如：

1. 公钥本身由公钥所有者或所有者的代表手动分发（例如，面对面传输或由担保快递员）：第 7.1.5.1.1 节中列出的强制性保证应在公钥操作使用之前提供给接收者。
2. 公钥证书由公钥所有者、所有者的代表、CA 或证书存储库（即，目录）手动或自动化分发：第 7.1.5.1.1 节中列出的 CA 未提供的强制性保证（例如，公钥验证）应在密钥操作使用之前提供给公钥的接收者或由接收者执行。
3. 公钥的自动化分发（例如，使用具有身份验证和内容完整性的通信协议）：第 7.1.5.1.1 节中列出的强制性保证应在公钥操作使用之前提供给接收实体。

7.1.5.1.2. 临时公钥的分发

使用时，临时公钥作为安全密钥建立协议的一部分分发。密钥建立过程（即，密钥建立方案、协议、密钥确认、任何关联的协商和/或本地处理）应为接收者提供第 7.1.5.1.1 节中列出的保证。临时公钥的接收者应在使用该密钥进行密钥建立过程中的后续步骤之前，按照 [SP 800-56A] 或 [SP 800-227] 中的规定获得该密钥有效性的保证。

7.1.5.1.3. 集中生成密钥对的分发

当静态密钥对集中生成时，密钥对应在 [FIPS 140-3] 验证的密码模块内生成，或从美国政府批准的其他来源获取，用于保护国家安全信息，以便后续递送给密钥对的预期所有者。中央密钥生成设施为其订阅者生成的签名密钥对不会为这些个人订阅者提供强有力的不可否认性支持。因此，当需要不可否认性时，订阅者应生成自己的签名密钥对。但是，如果中央密钥生成设施为其自己的组织生成签名密钥对并将其分发给组织成员，则可以在组织级别（但不是个人级别）提供不可否认性支持。

在中央设施生成的密钥对的私钥只能分发给密钥对的预期所有者，或提供给所有者的代表进行后续安装。应保护集中生成的私钥的机密性，分发程序应包括在实体注册期间建立的对接收者身份和授权的认证（见第 7.1.1 节）。

密钥对可以使用适当的 manual 方法（例如，快递员、邮件或密钥生成设施指定的其他方法）或安全自动化方法（例如，安全通信协议）分发给预期所有者或所有者的代表。私钥的分发方式应与对称密钥相同（见第 7.1.5.2.2 节）。密钥对的公钥分发在第 7.1.5.1.1.3 节中讨论。在分发过程中，密钥对的每个密钥都应提供该密钥的适当保护（见第 5.1 节）。

收到密钥对后，所有者应获得公钥有效性的保证（见 [SP 800-56A]、[SP 800-56B]、[SP 800-89] 和 [SP 800-227]）。所有者应获得密钥对的公钥和私钥是一致对的保证（例如，通过检查在公钥传输密钥下加密的密钥或由公封装密钥封装的密钥可以由相应的私钥解密）。

7.1.5.2. 对称密钥的生成和分发

用于数据或其他密钥的加密和解密以及 MAC 计算的对称密钥应由批准的方法确定，并应提供与第 5 节一致的保护。

对称密钥应：

1. 生成并随后分发（见第 7.1.5.2.1 和 7.1.5.2.2 节）手动（见第 7.1.5.2.2.1 节）、使用公钥传输机制（见第 7.1.5.2.2.2 节），或使用先前分发或商定的密钥封装密钥或 KEM（见第 7.1.5.2.2.2 节）；
2. 使用密钥协商方案或 KEM 建立（即，生成和分发通过一个过程完成）（见第 7.1.5.2.3 节）；或
3. 从密钥派生密钥派生（见第 7.2.4 节）。

7.1.5.2.1. 密钥生成

对称密钥应 1) 由批准的方法生成（例如，使用批准的随机数生成器；见 [SP 800-133]）或 2) 使用批准的密钥派生函数从密钥派生密钥派生（见 [SP 800-108]）。对称密钥也可以使用密钥协商或密钥封装技术生成（见第 7.1.5.2.3 节），在这种情况下，不需要单独的密钥分发过程（例如，见 [SP 800-56A]、[SP 800-56B] 和 [SP 800-227]）。

当使用分割知识程序时，密钥只能以多个密钥份额的形式存在于 [FIPS 140-3] 密码模块之外。密钥可以在密码模块内创建，然后分割成份额以便从模块导出，或者密钥可以作为单独的份额创建。每个密钥份额应不提供密钥值的知识（即，每个密钥份额必须看起来是随机生成的）。如果需要 k 个份额的知识来构造原始密钥，则任何 $k-1$ 个密钥份额的知识应不提供有关原始密钥的信息，除了可能的长度。简单的连接不提供合适的组合函数（例如，通过连接两个 64 位密钥份额来形成 128 位密钥是不可接受的）。

所有密钥和密钥份额应在 [FIPS 140-3] 验证的密码模块内生成，或从美国政府批准的其他来源获取，用于保护国家安全信息。

7.1.5.2.2. 密钥分发

根据第 7.1.5.2.1 节生成的作为密钥封装密钥（即，密钥加密密钥）、用于密钥派生的密钥派生密钥，或用于保护通信信息的密钥，手动分发（即，使用手动密钥传输程序）或使用自动化密钥传输或 KEM 协议分发。

仅用于保护存储信息（即，数据或密钥材料）的密钥不得分发，除非用于备份或需要访问受密钥保护的存储信息的其他授权实体。

7.1.5.2.2.1. 手动密钥分发

手动分发的密钥和密钥份额（例如，通过自动化密钥传输协议以外的方式）应在整个分发过程中受到保护。在手动分发期间，秘密密钥、私钥和密钥份额应封装（即，加密并带有完整性保护）、封装，或使用适当的物理安全程序分发。

如果密钥分发使用分割知识程序（即，密钥作为密钥份额分发；见第 7.1.5.2.1 节），则每个密钥份额应单独分发给其预期接收者。

秘密密钥、私钥和密钥份额（即，秘密密钥材料）的手动分发过程应确保：

1. 密钥材料由授权来源分发，
2. 分发明文密钥材料的任何实体受到生成密钥材料的实体和接收密钥材料的任何实体的信任，
3. 密钥材料根据第 5 节进行保护，以及
4. 密钥材料由授权接收者接收。

当以加密形式分发时，密钥或密钥份额应 1) 使用批准的 KEM 和预期接收者拥有的公封装密钥封装，2) 使用批准的密钥封装方案和与预期接收者共享的密钥封装密钥加密，或 3) 使用批准的密钥传输方案和预期接收者拥有的公钥传输密钥传输。公钥或密钥封装密钥应按照本建议中的规定进行分发。

物理安全程序可用于所有形式的手动密钥分发。但是，当秘密密钥材料以明文形式分发时，这些程序尤其关键。除了上面列出的保证外，还应使用分发过程的责任和审计（见第 8.3 节和 8.4 节）。

7.1.5.2.2.2. 自动化密钥分发、密钥传输、密钥封装和密钥封装

自动化密钥分发可用于通过通信渠道（例如，互联网）分发秘密密钥、私钥和密钥份额。这需要分发或建立密钥封装密钥（即，密钥加密密钥）、公钥传输密钥或公封装密钥，如下所示：

- 密钥封装密钥应根据第 7.1.5.2.1 和 7.1.5.2.2 节生成和分发，或使用第 7.1.5.2.3 节中定义的密钥建立方案建立。
- 公钥传输密钥或公静态/临时封装密钥应根据第 7.1.5.1 节的规定生成和分发。

只能使用批准的密钥封装、公钥传输或密钥封装方案。批准的方案提供以下保证：

- 对于对称密钥封装方案：密钥封装密钥和分发的密钥材料不被泄露或修改。[SP 800-38F] 中提供或引用了提供机密性和完整性保护的批准密钥封装方法。
- 对于非对称密钥传输方案：私钥传输密钥和分发的密钥材料不被泄露或修改，并维护私钥和公钥传输密钥之间的正常确关联。[SP 800-56A] 和 [SP 800-56B] 中讨论了使用非对称技术的批准密钥传输方案。
- 对于密钥封装方案：私解封装密钥和分发的密文不被泄露和/或修改，并维护私钥和公钥之间的正常确关联。[SP 800-227] 中讨论了使用非对称技术的批准密钥封装方案。
- 密钥材料根据第 5 节进行保护。

此外，批准的方案和相关密钥建立协议应提供以下所有保证：

- 密钥分发过程中的每个实体都知道与其他实体关联的标识符；
- 密钥材料与密钥分发过程中涉及的实体正常确关联；以及
- 密钥材料已正常确接收（例如，使用密钥确认方法）。

7.1.5.2.3. 密钥协商和密钥封装

使用密钥协商和/或密钥封装方案的密钥建立用于通信环境中，以建立具有通信中所有实体贡献的信息的密钥材料（最常见的是仅由两个实体）。只能使用批准的方案。[SP 800-56A]、[SP 800-56B] 和 [FIPS 203] 中提供了使用非对称技术的批准密钥协商和密钥封装方案。密钥协商方案使用非对称密钥对计算共享秘密，然后用于派生对称密钥和其他密钥材料（例如，IV），而无需实际传输密钥材料。密钥封装使用预期接收者的公钥和发送实体生成的随机值来生成密文，接收者可以从中派生密钥材料。

密钥协商或密钥封装方案使用静态或临时非对称密钥对，或两者兼有。非对称密钥对的生成和分发应在第 7.1.5.1 节中讨论。使用这些方案派生的密钥材料应根据第 5 节进行保护。

密钥协商或密钥封装方案及其相关密钥建立协议应提供以下保证：

- 密钥建立协议中涉及的实体的标识符与这些实体正常确关联。标识符与实体关联的保证可以通过执行该方案的方案或协议实现。标识符可以是"伪标识符"（假名），而不是例如出现在实体出生证明上的标识符。

  通常，与密钥建立协议中涉及的每个实体关联一个标识符，并且每个实体必须能够将所有其他实体与其适当的标识符关联。在特殊情况下，例如在网站上安全分发公共信息，可能只需要与实体子集关联标识符（例如，仅服务器）。
- 密钥协商或密钥封装方案中使用的密钥与密钥建立过程中涉及的实体正常确关联。
- 生成的密钥材料是正常确的（例如，使用密钥确认方法确定）。

在获得上述三个保证之前，不得使用密钥协商或密钥封装方案及其启用协议生成的密钥材料来保护或发送信息。

7.1.5.3. 其他密钥材料的生成和分发

密钥通常与其他密钥材料一起生成或与其他密钥材料一起使用。此其他密钥材料应根据第 5.2 节进行保护。表 8 指定了密钥以外的密钥材料所需的保护类型。

7.1.5.3.1. 算法参数

算法参数由某些非对称密钥算法用于生成密钥对并在执行其基本功能时使用。算法参数可以在算法规范中提供，以与其关联的公钥相同的方式分发，或在某个可访问的位置提供。在使用之前应获得算法参数有效性的保证，要么由保证参数的可信实体（例如，CA）提供，要么由使用它们的实体提供。算法参数有效性保证在 [SP 800-56A]、[SP 800-56B]、[FIPS 203]（用于密钥协商和密钥封装方案）和 [SP 800-89]（用于数字签名）中解决。应在 CA 的认证实践声明或组织的安全计划中解决获得此保证的问题。

7.1.5.3.2. 初始化向量 (IV)

初始化向量 (IV) 由对称密钥算法在几种操作模式下用于加密和解密、身份验证，或两者兼有。IV 的生成和使用标准在 SP 800-38 系列出版物中提供。IV 应根据第 5.1.2 节的规定进行保护。IV 可以以与其关联密钥相同的方式分发，或者可以与使用 IV 的信息一起作为密码机制的一部分分发。

7.1.5.3.3. 密钥协商期间生成的共享秘密

共享秘密在非对称密钥协商方案的执行期间计算，并随后用于派生密钥材料。共享秘密按照适当的密钥协商方案生成（见 [SP 800-56A] 和 [SP 800-56B]），不得分发或直接用作密钥材料。

7.1.5.3.4. 种子

种子用于初始化 RBG 内的确定性算法，或从 RBG 提供的值生成密钥材料。批准的 RBG 在 SP 800-90 系列出版物中指定，每个 RBG 包括一个称为确定性随机位生成器 (DRBG) 的确定性组件。RBG 依赖于引入真正常的随机位，这些随机位用于生成种子，用于：

初始化 DRBG。这些种子必须保密。初始化的 DRBG 通常用于生成密钥和其他需要不可预测性的值。种子本身不得用于除 DRBG 输入以外的任何目的。

7.1.5.3.5. 其他公开和秘密信息

公开和秘密信息可在 RBG 内 DRBG 的种子化期间使用（见第 7.1.5.3.4 节）或在密钥材料的生成或建立期间使用（见 [SP 800-56A]、[SP 800-56B]、[SP 800-108] 和 [SP 800-227]）。公开信息可以分发，但秘密信息在分发期间应以与私钥或秘密密钥相同的方式进行保护。

7.1.5.3.6. 中间结果

中间结果在使用密码算法的计算过程中产生。这些结果不得作为或与密钥材料一起分发。

7.1.5.3.7. 随机比特/数字

随机比特（或数字）用于多种目的，包括密钥生成、nonce、生成其他值的种子，以及在通信协议执行期间发出挑战。随机比特可以分发，但是否需要机密性保护取决于使用随机比特的上下文。

7.1.5.3.8. 密码

密码用于身份身份认证、授权，在某些情况下还用于派生密钥材料（见 [SP 800-132]）。密码可以分发，但其在分发期间的保护应与其使用所需的保护一致。例如，如果密码将用于访问在保护数据时提供 128 比特安全强度的密码密钥，则密码也需要提供至少 128 比特的保护。选择不当的密码可能无法为密钥访问提供所需的保护量，并且可能是过程中的弱点（即，猜测密码可能比尝试"破解"密码上使用的密码保护要容易得多）。用户和组织有责任选择为其保护的密钥提供所需保护量的密码。

密钥建立涉及密钥材料的生成和分发或实体之间通信的协商。所有密钥应在 [FIPS 140-3] 验证的加密模块内生成，或从另一个批准保护国家安全信息的来源获取。长期密钥应列入清单（参见第 8.2 节）。在密钥建立过程中，一些密钥材料可能在传输中（即密钥材料正常在手动分发或使用自动化协议分发）。其他密钥材料可能本地保留而不是分发。在任何一种情况下，密钥材料应根据第 5 节进行保护。

实体可以是个人（人类）、组织、设备或进程。当密钥材料由实体为其自己用途生成时，应使用第 5.2.2 节中存储信息的一个或多个适当保护机制。密钥的"所有者"是授权使用该密钥的实体。当所有者不是人类时（即所有者是组织、设备或进程），所有者通常由授权人类代表或赞助者协助获取和管理密钥材料（例如获取和安装密钥和证书）。

在实体之间或实体与其子实体之间（例如组织内的各种个人、设备或进程）分发的密钥材料应在分发期间使用第 5.2.1 节中规定的一个或多个适当保护机制进行保护。任何未分发的密钥材料（例如密钥对的私钥或对称密钥自己的副本）或接收后随后存储的密钥材料应使用第 5.2.2 节中规定的一个或多个适当保护机制进行保护。

第 7.1.5.1 和 7.1.5.2 节分别讨论非对称和对称密钥的生成和分发。[SP 800-133] 讨论密钥材料的生成。

7.1.6. 密钥注册功能

密钥注册导致将密钥材料绑定到与特定实体相关联的信息。将注册的密钥包括非对称密钥对的公钥和用于将实体引导到系统中的对称密钥。通常在通信期间生成的密钥（例如使用密钥协商方案、密钥封装或密钥导出函数）不会注册。注册期间提供的信息通常包括与密钥材料相关联的实体的标识符（即所有者）和密钥材料的预期用途（例如作为签名密钥或数据加密密钥）。附加信息可能包括授权信息、指定信任级别，或指示密钥存储在哪里（例如其物理位置、互联网地址、设备身份）。

绑定在实体的身份通过符合系统政策的方式身份认证后执行（参见第 7.1.1 节）。绑定向整个社区保证密钥材料由正常确实体在正常确应用中使用。绑定通常是加密的，以在密钥材料和实体之间创建强关联。受信任的第三方（例如 Kerberos 领域服务器或 PKI CA）执行绑定。受信任的第三方颁发的标识符对该方应是唯一的。

当 Kerberos 领域服务器执行绑定时，对称密钥与相应元数据一起存储在服务器上。在这种情况下，注册的密钥材料在安全存储中维护（即密钥在存储期间提供机密性和完整性保护）。当 CA 执行绑定时，公钥和相关信息（例如算法参数和一些元数据，通常称为属性）放在由 CA 数字签名的公钥证书中。在这种情况下，注册的密钥材料可以公开提供。

当 CA 为公钥提供证书时，应验证公钥以确保其与公钥声称所有者已知的私钥相关联。这提供占有保证（即 POP）。当 POP 用于获得占有保证时，保证应按照第 7.1.5.1.1.2 节中规定完成。

注册的密钥和证书应包含在清单中（参见第 8.2 节）。

7.2. 运行阶段

密钥密码周期期间使用的密钥材料通常存储以便根据需要访问。在存储期间，密钥材料和其他密钥信息应根据第 5.2.2 节进行保护。在正常常使用期间，密钥信息存储在使用该信息的设备或模块中，或在立即可访问的存储介质上。当密钥材料需要运行使用但不在设备或模块的活动内存中时，从存储中获取密钥材料。

为了在密钥材料在密码周期期间无法从正常常运行存储中使用时提供操作连续性（例如因为材料丢失或损坏），密钥材料可能需要可恢复。如果系统操作分析表明密钥材料需要可恢复，则密钥材料应备份（参见第 7.2.2.1 节）或归档（参见第 7.3.1 节），或者系统应设计为允许重建（例如重新导出）密钥材料。从归档或备份存储中检索或重建密钥材料通常称为密钥恢复（参见第 7.2.2.2 节）。

在密钥密码周期结束时，如果操作要继续，则需要新密钥来替换旧密钥。这可以通过重新密钥（参见第 7.2.3.1 节）或密钥导出（参见第 7.2.4 节）来完成。密钥一旦不再需要就应销毁，以减少暴露风险；销毁时，密钥应根据第 7.3.4 节销毁。

7.2.1. 正常常运行存储功能

密钥管理的目标之一是促进密钥材料用于标准加密目的的运行可用性。通常，密钥保持运行直到密钥密码周期结束（即到期日）。在正常常运行使用期间，密钥材料在设备或模块中可用（例如在 RAM 中）或在立即可访问的存储介质上（例如在本地硬盘上）。

7.2.1.1. 加密模块存储

密钥材料可以存储在加密模块中，该模块添加、检查或移除信息上的加密保护。密钥材料的存储应与第 5.2.2 节和 [FIPS 140-3] 一致。第 5.2.2.7 节中提供附加存储介质讨论。

7.2.1.2. 立即可访问存储介质

密钥材料可能需要在密钥密码周期期间存储在立即可访问的存储介质（例如本地硬盘）上以进行正常常加密操作。第 5.2.2 节的存储要求应适用于此密钥材料。

7.2.2. 操作连续性功能

由于硬件损坏、损坏、程序或数据文件丢失、系统策略或配置更改，密钥材料可能丢失或无法使用。为了保持连续性，用户和/或管理员通常需要能够从备份存储中恢复密钥材料。然而，如果可以在不备份密钥材料的情况下继续操作（例如通过重新密钥），或者可以恢复或重建密钥材料而无需保存，则可能最好不保存密钥材料，以减少密钥材料或其他加密相关信息泄露的可能性。

密钥材料的泄露影响操作连续性（参见第 8.5 节）。当密钥材料泄露时，操作连续性需要在评估受影响的密钥材料后建立全新的密钥材料（参见第 7.1.5 节）。所有受影响的密钥材料都需要替换。

7.2.2.1. 备份存储

在独立安全存储介质上备份密钥材料提供密钥恢复的来源（参见第 7.2.2.2 节）。备份存储用于存储在密钥密码周期期间当前也可在正常常运行存储中使用的密钥信息副本（即在加密模块中或在立即可访问的存储介质上；参见第 7.2.1.1 节）。并非所有密钥都需要备份，其他密钥需要附加保护。例如，由于与重用一次性私钥相关的高风险，需要为状态哈希基于签名的密钥备份提供附加保护。第 5.2.2 节的存储要求适用于备份的密钥材料。

备份存储中维护的密钥材料应至少在相同密钥材料为正常常运行使用维护的时间内保留在存储中（参见第 7.2.1 节）。当不再需要正常常运行使用时，密钥材料和其他相关信息应从备份存储中移除。从备份存储中移除时，备份存储中信息的所有痕迹应根据第 7.3.4 节销毁。[41]

表 10 和表 11 为备份每种类型的密钥材料和其他相关信息提供指南。"OK"表示存储是允许的，但不一定需要。备份的最终确定应基于使用密钥材料的应用。附录 B.1.3 中提供关于备份每种类型密钥和其他密钥信息的详细讨论。

表 10. 密钥备份

密钥类型	备份
数字签名	
1. 私签名密钥	否（一般来说）；不可否认性支持将受到质疑。然而，在某些情况下可能需要备份，例如 CA 的私签名密钥。需要时，任何备份的密钥应在所有者控制下存储。
2. 公签名验证密钥	OK；其在其他地方可用的公钥证书中的存在可能足够。
身份认证	
3. 对称身份认证密钥	OK
4. 私身份认证密钥	如果应用需要则 OK。
5. 公身份认证密钥	如果应用需要则 OK。
随机比特生成	
6. 随机数生成密钥	不必要且可能不可取，取决于应用。
密钥导出	
7. 对称密钥导出	OK
密钥建立（自动化）	
8. 对称密钥包装/拆封密钥	OK
9. 公密钥传输密钥	OK；其在其他地方可用的公钥证书中的存在可能足够。
10. 私密钥传输密钥	OK
11. 对称密钥协商密钥	OK
12. 公静态密钥协商密钥	OK；其在其他地方可用的公钥证书中的存在可能足够。
13. 私密态密钥协商密钥	OK
14. 公临时密钥协商密钥	OK
15. 私临时密钥协商密钥	OK
16. 公静态封装密钥	OK；其在其他地方可用的公钥证书中的存在可能足够。
17. 私静态解封密钥	OK

18. 公临时封装密钥	否；仅用于单个密钥封装过程。
19. 私临时解封密钥	OK 直到不再需要解封（唯一）封装的密钥。
数据加密/解密	
20. 对称数据加密/解密密钥（传输中的数据）	OK
21. 对称数据加密/解密密钥（静态数据）	OK
密钥存储（用于运行、备份和归档存储）	
22. 对称密钥包装/拆封密钥	OK
23. 公密钥包装密钥	OK
24. 私密钥拆封密钥	OK
25. 公封装密钥	OK
26. 私解封密钥	OK
授权	
27. 对称授权密钥	OK
28. 私授权密钥	OK
29. 公授权密钥	OK；其在其他地方可用的公钥证书中的存在可能足够。

表 11. 其他相关信息的备份

密钥材料类型	备份？
算法参数	OK
初始化向量	如有必要则 OK
共享密钥	否
种子	DRBG 初始化则否；否则 OK
其他公开信息	OK
其他秘密信息	OK
中间结果	否
密钥控制信息/元数据（例如 ID 或用途）	OK
随机数	取决于应用或随机数的使用。
密码	当用于导出密钥或检测密码重用时 OK；否则否。
审计信息	OK

7.2.2.2. 密钥恢复功能

活动内存中或存储在正常常运行存储中的密钥材料有时会丢失或损坏（例如由于系统崩溃或电源波动）。一些密钥材料需要继续操作且不易替换。需要评估哪些密钥材料需要保留以便以后可能恢复。

是否需要密钥恢复的决定应逐案做出。决定应基于：

• 密钥类型（例如私签名密钥或对称数据加密密钥），
• 密钥将使用的应用（例如交互式通信或文件存储），
• 密钥是否由本地实体"拥有"（例如私钥）、由另一个实体拥有（例如实体的公钥）或共享（例如由两个实体共享的对称数据加密密钥），
• 实体在通信中的角色（例如发送者或接收者），以及
• 密钥将使用的算法或计算（例如实体的密钥如果恢复是否具有执行给定计算所需的信息）。[42]

支持或反对密钥恢复决定涉及的因素应仔细评估。权衡涉及操作连续性与如果失去密钥材料控制可能暴露密钥材料及其保护信息的风险之间的权衡。如果确定需要恢复密钥，且密钥仍然活跃（例如密钥的密码周期未过期，且密钥未泄露），则可以替换密钥而不是恢复密钥，以限制丢失密钥保护的数据的暴露（参见第 7.2.3 节）。

附录 B 中提供与密钥恢复相关的问题以及关于不同类型加密材料是否需要可恢复的讨论。

7.2.3. 密钥更改功能

密钥更改是用执行与原始密钥相同功能的另一个密钥替换密钥。更改密钥有几个原因，例如：

1. 密钥可能已泄露。
2. 密钥的密码周期可能接近到期。
3. 可能需要限制任何给定密钥保护的数据量。

7.2.3.1. 重新密钥

如果以完全独立于旧密钥"值"的方式生成新密钥，则该过程称为重新密钥。替换应使用第 7.1.5 节中讨论的密钥建立方法之一完成。当密钥泄露时使用重新密钥（前提是重新密钥方案本身未泄露），或者当密码周期到期或接近到期时。

7.2.3.2. 密钥更新功能

如果新密钥的"值"取决于旧密钥的值，则该过程称为密钥更新（例如以某种方式修改当前密钥以创建新密钥）。密钥更新是密钥导出的特殊情况（参见第 7.2.4 节），其中导出密钥替换用于导出它的密钥。例如，假设 K_1 用作加密密钥。当需要替换 K_1 时，它用于导出 K_2。然后 K_2 用作新加密密钥，直到被 K_3 替换，K_3 从 K_2 导出。

如果对手获得导出密钥链中的密钥并知道使用的更新过程，密钥更新可能导致安全暴露。然后可以轻松确定从链中泄露密钥导出的密钥。

联邦应用不得使用密钥更新（另见 [SP 800-152]）。

7.2.4. 密钥导出方法

加密密钥可以从秘密值导出。秘密值和其他信息输入到密钥导出方法（例如密钥导出函数）中，输出所需密钥）。密钥导出方法应不可逆（即单向函数），以便无法从导出密钥确定秘密值。此外，应无法从其他导出密钥确定导出密钥。应注意，导出密钥的强度不大于导出算法和从中导出密钥的秘密值的强度。

下面讨论三种常用的密钥导出情况。

1. 两方从公共共享密钥导出公共密钥。此方法用于 [SP 800-56A] 和 [SP 800-56B] 中规定的密钥协商技术。此过程的安全性取决于共享密钥的安全性和所用特定密钥导出方法。如果知道共享密钥，则可以确定导出密钥。[SP 800-56C] 中规定或允许的密钥导出方法应为此目的使用。这些导出密钥可用于提供与随机生成密钥相同的机密性、身份身份认证和源身份认证服务。导出密钥的安全强度由用于生成共享密钥的方案和密钥对决定。
2. 从密钥导出密钥（主密钥）导出的密钥。这通常通过使用秘密密钥导出密钥和其他已知秘密或公开信息作为生成密钥函数的输入来完成。[SP 800-108] 或 [SP 800-135] 中定义的密钥导出函数之一应为此目的使用。此过程的安全性取决于密钥导出密钥和密钥导出方法的安全性。如果对手知道密钥导出密钥，则可以生成任何导出密钥。因此，从密钥导出密钥导出的密钥仅与密钥导出密钥本身一样安全。如果密钥导出密钥保密，则导出密钥可以以与随机生成密钥相同的方式使用。
3. 从密码导出的密钥。用户生成的密码本质上随机性较低（即熵较低），低于加密密钥所需。也就是说，可能用于导出密钥的密码数量明显小于给定密钥大小可能的密钥数量。为了增加穷举搜索可能密码的难度，密钥导出函数迭代大量次数。密钥使用密码和其他已知秘密或公开信息作为密钥导出函数的输入导出。导出密钥的安全性取决于密码和密钥导出过程的安全性。如果密码已知或可以猜测，则可以生成相应导出密钥。因此，以此方式导出的密钥可能比随机生成的密钥或从共享密钥或秘密密钥导出密钥导出的密钥安全性低。对于存储应用，[SP 800-132] 中规定的密钥导出函数之一应用于从密码导出密钥。对于非存储应用，以此方式导出的密钥不得用于一般加密，但有时可用于身份和源身份认证目的。

7.3. 运行后阶段

在运行后阶段，密钥材料不再处于运行使用，但仍可能访问所需密钥材料以处理已受保护的信息。

7.3.1. 密钥归档和密钥恢复功能

密钥归档是包含密钥及其相关信息（即密钥信息）以供密钥密码周期后恢复的存储库。并非所有密钥都需要归档。组织的安全计划应讨论密钥归档（参见 [SP 800-57p2]）。

密钥归档应继续为归档中的每个密钥和任何其他相关信息提供适当保护，如第 5.2.2 节中规定。归档将需要强大的访问控制机制，以将归档信息的访问限制为仅授权实体。当密钥信息输入归档时，通常加上时间戳，以便可以确定输入日期。此日期本身可以加密保护，以便无法在不被检测的情况下更改。

如果密钥必须可恢复（例如在其密码周期结束后），则密钥应归档，或者系统应设计为允许从归档信息重建（例如重新导出）密钥。从归档存储中检索或通过重建检索密钥通常称为密钥恢复。归档应由受信任方维护（例如与密钥相关联的组织或受信任的第三方）。

归档密钥信息应与运行数据分开存储，并应在物理上分开的位置提供归档密钥信息的多个副本（即密钥归档应备份）。对于在归档密钥下保护（即加密、包装或封装）的关键信息，可能需要备份归档密钥并在分开的位置存储这些归档密钥的多个副本。

归档时，密钥应在密钥密码周期结束前归档。例如，在密钥激活时归档密钥可能是谨慎的。当不再需要时，密钥应根据第 7.3.4 节销毁。

归档密钥信息的机密性由归档机密性密钥（即一个或多个专门用于保护归档密钥信息机密性的加密、包装或封装密钥）、另一个已归档密钥或可以从归档密钥导出的密钥提供。使用归档机密性密钥的算法还可以为归档信息提供完整性保护。

当归档机密性密钥及其相关算法不为归档信息提供完整性保护时，完整性保护应由单独的归档完整性密钥（即一个或多个专门用于归档的身份认证或数字签名密钥）或另一个已归档密钥提供。

当使用单独过程提供归档密钥信息的机密性和完整性保护时，归档机密性密钥和归档完整性密钥应彼此不同（例如独立生成），并应以其密钥类型相同的方式保护（参见第 5.1.1 节）。这两项服务也可以使用单个加密算法和单个密钥提供。

表 12 和表 13 指示归档密钥和其他加密相关信息的适当性。第 2 列（归档？）中的"OK"表示归档是允许的，但不一定需要。第 3 列（保留期）指示密钥应保留在归档中的最短时间。附录 B.1.3 中提供关于在归档存储中存储密钥材料的附加建议。

表 12. 密钥归档

密钥类型	归档？	保留期（最短）
数字签名		
1. 私签名密钥	否	
2. 公签名验证密钥	OK	直到不再需要验证使用相应私签名密钥签名的数据
身份认证		
3. 对称身份认证密钥	OK	直到不再需要身份认证数据或身份
4. 私身份认证密钥	否	
5. 公身份认证密钥	OK	
随机比特生成		
6. 对称随机数生成器密钥	否	
密钥导出		
7. 对称密钥导出/主密钥	OK，如果需要为归档数据导出其他密钥	直到不再需要导出其他密钥
密钥建立（自动化）		
8. 对称密钥包装/拆封密钥	OK	直到不再需要拆包由此密钥包装的密钥
9. 公密钥传输密钥	OK	密码周期后无实际用途
10. 私密钥传输密钥	OK	直到不再需要解密由相应公密钥传输密钥加密的密钥
11. 对称密钥协商密钥	OK	直到不再有助于确定协商的密钥
12. 公静态密钥协商密钥	OK	直到不再需要重建密钥材料
13. 私密态密钥协商密钥	OK	直到不再有助于确定协商的密钥
14. 公临时密钥协商密钥	OK	直到不再有助于确定协商的密钥
15. 私临时密钥协商密钥	否	
16. 公静态封装密钥	OK	密码周期后无实际用途
17. 私静态解封密钥	OK	直到不再需要解封由相应公静态封装密钥封装的密钥
18. 公临时封装密钥	否	
19. 私临时解封密钥	OK	直到不再需要解封由相应公临时封装密钥封装的密钥
数据加密/解密		

20. 对称数据加密/解密密钥：（传输中的数据）	OK	直到不再需要解密由此密钥加密的数据
21. 对称数据加密/解密密钥：（静态数据）		
密钥存储（用于运行、备份和归档存储）		
22. 对称密钥包装/拆封密钥	OK	直到不再需要拆包由此密钥包装的密钥
23. 公密钥包装密钥	OK	密码周期后无实际用途
24. 私密钥拆封密钥	OK	直到不再需要拆包由相应公密钥包装密钥包装的密钥
25. 公封装密钥	OK	密码周期后无实际用途
26. 私解封密钥	OK	直到不再需要解封由相应公封装密钥封装的密钥
授权		
对称授权密钥	否	
私授权密钥	否	
公授权密钥	OK	相应私授权密钥密码周期后无实际用途

表 13. 其他相关信息的归档

密钥类型	归档？	保留期（最短）
算法参数	OK	直到所有使用算法参数的密钥材料、签名和签名数据从归档中移除
初始化向量	OK；通常与受保护信息一起存储	直到不再需要处理受保护数据
共享密钥	否	
种子	否	
其他公开信息	OK	直到不再需要使用公开信息处理数据
其他秘密信息	OK	直到不再需要使用秘密信息处理数据
中间结果	否	
密钥控制信息/元数据（例如 ID、用途）	OK	直到相关密钥从归档中移除
随机数		取决于应用或随机数的使用
密码	当用于导出密钥或检测密码重用时 OK；否则否	直到不再需要导出或重新导出密钥或检测密码重用
审计信息	OK	直到不再需要

可能需要恢复归档密钥材料以移除（例如解密）或检查（例如验证数字签名或 MAC）其他归档数据上的加密保护。如果这些密钥的密码周期（或发起者使用周期）已过期，恢复的密钥不得用于应用加密保护。密钥恢复过程导致从归档存储中检索或重建所需密钥材料以执行所需加密操作。完成此操作后，应立即从恢复的加密过程中擦除密钥材料[43]（即不得用于正常常运行活动）。然而，密钥应保留在归档中（参见第 7.3.4 节），只要需要。附录 B 中提供有关密钥恢复问题的进一步指南。

7.3.2. 实体注销功能

实体注销功能移除实体参与安全域的授权。当实体不再是安全域成员时，实体应注销。注销旨在防止其他实体依赖或使用注销实体的密钥材料（例如与注销实体共享的对称密钥）。

实体和实体关联的所有记录应标记为指示实体不再是安全域成员，但记录不应删除，即使密钥本身已销毁。为了减少混淆和不可避免的人为错误，与注销实体相关联的身份信息不应重用（至少一段时间）。例如，如果"John Wilson"退休并于周五注销，则下周一雇用的其子"John Wilson"分配的身份信息应不同。

7.3.3. 密钥注销功能

注册的密钥材料可以与密钥所有者的身份、所有者信息（例如电子邮件地址）、角色或授权信息相关联。当不再需要密钥材料或相关信息变为无效时，密钥材料应由适当的受信任第三方注销（即密钥材料及其关联的所有记录应标记为指示密钥不再使用）。一般来说，这将是注册密钥的受信任第三方（参见第 7.1.6 节）。

当与实体相关联的信息修改时，密钥材料应注销。例如，如果实体的电子邮件地址与公钥相关联，且实体的地址更改，则密钥材料应注销以指示相关信息已变为无效。与密钥泄露的情况不同，如果密钥的密码周期未过期，实体可以在通过实体注册过程修改实体信息后安全地重新注册公钥（参见第 7.1.1 节）。

当注册的加密密钥泄露时，该密钥和任何相关密钥材料应注销。当泄露的密钥是密钥对的私钥时，公钥也应撤销（第 7.3.5 节）。注销的密钥不得重新注册。

如果与密钥对相关联的注册信息更改但私钥未泄露，则公钥应使用适当的原因代码撤销（参见第 7.3.5 节）。在这种情况下，如果密码周期未过期，密钥可以重新注册。

7.3.4. 密钥销毁功能

当制作加密密钥的副本时，应注意为其最终销毁提供保障（例如共享方的身份可以记录在密钥的元数据中）。私钥或秘密（对称）密钥的所有副本一旦不再需要（例如用于归档或重建活动）就应销毁，以最小化泄露风险。秘密和私钥应以移除密钥所有痕迹的方式销毁，以便无法通过物理或电子手段恢复。[44] 公钥可以根据需要保留或销毁。

7.3.5. 密钥撤销功能

如果 1) 需要在密钥既定密码周期结束前终止密钥的授权使用，或 2) 使用周期或密码周期已到期的密钥已泄露，则使用密钥撤销。密钥可能因行政原因撤销（例如密钥所有者已离开组织或包含密钥的设备已停止使用），或者如果有理由相信密钥可能已泄露给未经授权的实体或以其他方式被其访问，则可能在紧急基础上撤销。在任何一种情况下，确定需要撤销后应尽快撤销加密密钥。

已使用、正常在使用或将使用密钥的实体（例如依赖方）需要通知密钥已撤销。

当（秘密）对称密钥撤销时，所有共享密钥的实体需要通知（例如使用泄露密钥列表 [CKL] 或向每个共享密钥的实体提供特定通知）。
在非对称密钥对的情况下，撤销指私钥。然而，当使用公钥证书时，包含与私钥相对应的公钥的证书被撤销，并使用例如证书撤销列表 (CRL) 或在线证书状态协议 (OCSP) 通知依赖方。

通知可以通过主动向可能使用撤销密钥的所有实体发送通知提供，或允许实体请求密钥状态（即状态信息的"推送"或"拉取"）。通知应包括密钥的完整标识（不包括密钥本身）、撤销日期和时间，以及适当时的撤销原因（例如密钥泄露）。根据提供的撤销信息，其他实体可以确定他们将如何处理受撤销密钥保护的信息。

例如，如果公签名验证密钥因实体离开组织而撤销，则可能适合承认撤销日期前创建的所有签名（即继续验证这些签名并在验证成功时接受它们为有效）。如果签名私钥泄露，导致相应公钥撤销，则需要评估撤销通知中日期之前签名的信息是否被视为有效。作为另一个示例，用于生成 MAC 的对称密钥可以撤销，以便不用于在新信息上生成 MAC。然而，可以保留密钥以便可以验证归档文档上的 MAC。

密钥撤销的细节应反映每个特定密钥的生命周期。如果密钥在成对情况下使用（例如两个实体使用相同对称加密密钥通信），撤销密钥的实体应通知另一个实体撤销。如果密钥已在基础设施中注册（例如特定 PKI），撤销密钥的实体不能总是直接通知可能依赖该密钥的其他实体。相反，撤销密钥的实体应通知基础设施需要撤销密钥（例如使用证书撤销请求）。基础设施应通过撤销和注销密钥响应（参见第 7.3.3 节）。

在 PKI 中，密钥撤销通常通过将证书包含在撤销证书列表（即在 CRL 中）实现。如果 PKI 使用在线状态机制（例如 RFC 2560 [RFC 2560] 中的在线证书状态协议），撤销通过通知适当的证书状态服务器实现。例如，当私钥泄露时，相应公钥证书应尽快撤销。因密钥泄露导致的证书撤销指示所有者和密钥之间的绑定不再可信。依赖方不应接受证书，而不认真考虑风险并咨询组织关于此情况的政策。其他撤销原因指示即使原始绑定可能仍然有效，且密钥未泄露，也应终止证书中公钥的使用。同样，依赖方应咨询组织关于此问题的政策。

在对称密钥系统中，密钥撤销理论上可以通过简单地从服务器存储中删除密钥实现。对称密钥的密钥撤销更通常通过将密钥添加到泄露密钥列表实现，这有助于满足审计和管理要求。

7.4. 销毁阶段

密钥不再可用。其存在的所有记录可能已删除，尽管这不是必需的。一些组织可能要求保留某些元数据元素用于审计目的。例如，如果在不受控制的环境中发现明显销毁密钥的副本，或后来确定已泄露，密钥标识符、其类型和其密码周期的记录可能有助于确定什么信息在密钥下保护以及如何最好地从泄露中恢复。

此外，通过保留销毁和泄露密钥的元数据记录，可以确定哪些密钥通过正常常生命周期转换，哪些在其生命周期期间的某个时间泄露。因此，与通过正常常生命周期的密钥名称链接的受保护信息可能仍被视为安全，前提是算法的安全强度保持足够。然而，与已泄露密钥名称链接的任何受保护信息本身可能已泄露。

8. 附加考虑因素

密钥管理的许多方面可以由设计为管理加密密钥及其元数据的密钥管理系统处理。自动化密钥管理系统可用于监督、自动化和保护密钥管理过程。然而，在设计和运行此类系统时还有附加考虑因素。其中包括通过身份认证请求访问的个人并验证其执行此操作的授权来控制对系统的访问（参见第 8.1 节），创建和维护密钥和证书清单以监控何时需要替换密钥或证书以及谁负责密钥和证书替换（参见第 8.2 节），分配责任和监控系统活动（参见第 8.3 节），审计系统的实施和性能并检查审计日志中的异常（参见第 8.4 节），以及确保系统生存能力（参见第 8.5 节）。

8.1. 访问控制和身份身份认证

需要访问控制系统来确保每个密钥和元数据管理功能只能响应授权实体的请求启动。当实体启动密钥管理功能时，访问控制系统必须确保实体已身份认证且仅执行该实体授权的请求功能，并满足所有适用约束。

访问控制系统应控制对其所有密钥和元数据管理服务及功能的访问和启动，包括仅在验证实体的身份和授权以执行请求的服务或功能后授予访问和权限以启动请求的服务或功能。

提供访问控制需要识别访问密钥的实体的方法。常用方法包括使用双因素身份认证和数字签名证书。这些方法需要实体的身份证明。[SP 800-63]、[SP 800-130] 和 [SP 800-152] 提供访问控制和身份身份认证的进一步讨论和要求。

所有密钥访问应记录在审计日志中，用于定期和紧急检查，包括成功和失败的访问尝试。参见第 8.4 节讨论审计这些日志。

8.2. 清单管理

当使用采用密钥的加密机制时，所有长期密钥应列入清单。在对称密钥的情况下，这包括用于保护传输中和存储中信息的密钥。对于非对称密钥对，这包括组织实体拥有的密钥对（即组织内授权使用密钥对私钥的实体）。当为密钥对的公钥颁发证书时，应维护这些证书的记录。这些记录需要由清单管理系统维护。

清单管理涉及建立和维护使用中密钥和/或证书的记录，分配和跟踪其所有者或赞助者[45]（例如他们是谁或什么、他们位于哪里以及如何联系他们），监控密钥和证书状态（例如到期日和密钥是否泄露），并在需要时向适当官员报告状态以采取补救行动。

8.2.1. 密钥清单

密钥清单应包括关于每个长期密钥的信息（例如与密钥相关联的元数据的全部或部分）。除非清单也用于密钥备份或归档，否则清单不应包括秘密或私钥，但应包括密钥的引用（例如密钥标识符或密钥位置指针）。清单中的信息应指示谁/什么拥有或共享密钥、密钥类型、密钥将使用的算法、密钥长度、如何使用（例如应用）及其到期日。

密钥清单应维护在中央存储库或相互信任的存储库网络中，并根据密钥清单政策操作。[46] 如果密钥泄露，需要通知与泄露密钥相关联的所有者或赞助者，以便可以采取补救行动，包括撤销密钥、分析泄露的影响，并在适当时替换密钥。清单中的信息可用于识别需要通知谁以及如何联系他们。

如果所有者不再授权使用密钥（例如所有者是离开组织的人类或从系统中移除的设备），则需要通知其他实体，以便终止使用该密钥的进一步交互。如果密钥是对称密钥，清单中的信息可用于识别需要通知的其他实体以及如何联系他们。如果密钥是非对称密钥且使用 PKI 证书，通知通常使用 CRL 完成。

如果密钥的密码周期到期或即将到期，且使用该密钥的实体之间的交互要继续（即使用替换密钥），则需要替换密钥。密钥清单管理系统可用于监控密码周期并提醒密钥所有者或赞助者密钥即将到期。清单管理系统还可用于查找不再被视为安全的算法和密钥长度的密钥，以便安排算法和/或密钥替换。

8.2.2. 证书清单

证书由通信服务器（例如 TLS、SSH）使用，以提供网络应用和服务（例如政府服务、网上银行、航班操作、组织内的任务关键服务）、设备（例如路由器）以及使用这些通信和服务的人类使用的客户端应用（例如浏览器）。证书用于建立身份、提供公钥以验证文档上的签名和通信信息的完整性，并建立密钥以保护通信。

在许多情况下，已创建和安装证书，但未记录与其相关联的详细信息（例如谁或什么设备或进程与证书相关联、什么设备或进程拥有私钥、设备或进程的位置，或证书的有效期）。因此，当 1) 证书到期且需要在业务操作继续之前替换，或 2) 私钥泄露且需要在安全操作得到保证之前撤销和替换证书时，会发生重大中断。为了促进恢复操作并避免在证书到期情况下中断，证书应在创建时列入清单。

证书清单包括每个实体的最新证书和关于每个证书的信息，包括证书所有者的身份和所有者的联系信息。与证书中公钥相关联的私钥不应包含在清单中，除非清单也用于密钥备份或归档，且允许私钥备份或归档（参见第 7.2.2.1 和 7.3.1 节）。证书清单应维护在中央存储库或相互信任的存储库网络中，并根据证书政策操作。参见 [SP 800-57p2] 获取附加信息。

证书清单应用应用于将证书输入清单、监控证书有效期以进行主动证书替换、检测不再安全的算法和密钥长度的使用、响应加密事件（例如 CA 泄露），以及修改谁应联系进行证书维护。

8.3. 问责制

关于密钥管理，问责制有两个不同方面：责任和可追溯性。

参与密钥管理的每个人都必须清楚了解其密钥管理责任，并负责履行这些责任。这包括分配给人们的角色、这些角色的密钥管理责任，以及监控分配给这些角色的个人的绩效。参见 [SP 800-130] 讨论与密钥管理相关的不同角色和责任。

可追溯性涉及识别授权生成、访问、销毁或以其他方式使用密钥的实体；记录谁或什么实际执行这些操作；以及审计日志以查找安全违规（参见第 8.4 节）。可追溯性可以是帮助防止密钥泄露并在检测到泄露时减少泄露影响的有效工具。为系统提供可追溯性需要识别访问系统的实体并采用访问控制机制（参见第 8.1 节）。

虽然最好没有人能够查看密钥，但作为最低要求，对明文加密密钥的任何访问应可追溯到访问它们的实体，无论实体是人类、设备、应用还是进程。对密文密钥和密钥份额的访问也应可追溯到访问实体。例如，复杂的可追溯性系统可能能够确定在其整个生命周期内控制任何给定密钥的每个实体。这将包括生成密钥的实体、使用密钥加密保护数据的实体、已知访问密钥的任何其他实体，以及负责在不再需要时销毁密钥的实体。即使这些其他实体可能从未实际以明文形式访问密钥，他们对密钥执行或与其密钥相关的任何操作应可追溯到他们。

可追溯性提供三个显著优势：

1. 它有助于确定何时可能发生泄露以及哪些实体可能涉及。
2. 它倾向于阻止泄露尝试，因为有权访问密钥的个人知道他们对密钥的访问已知，访问密钥的设备、应用和进程的开发人员知道访问将追溯到这些实体。
3. 从检测到的密钥泄露中恢复时，了解密钥在哪里使用以及什么数据或其他密钥受泄露密钥保护非常有用。

某些原则在强制执行加密密钥使用的可追溯性时有用，尽管这些原则可能不适用于所有系统或所有密钥类型。原则包括：

• 唯一标识密钥
• 识别由对称或私钥保护的其他密钥
记录（即记录）与密钥或相关元数据相关的任何活动，包括其生成、访问、修改、撤销、销毁或对其的任何其他访问。[SP 800-152] 第 7.2.4 节列出应为密钥管理事件记录的适当信息（例如密钥生成和销毁）。

8.4. 审计

需要审计与密钥管理相关的活动。应对密钥管理系统执行三种类型的审计：

1. 应进行初始和定期合规性审计，以确定密钥管理系统是否准备运行或继续运行符合其密钥管理政策和实践要求。这包括 1) 检查安全计划和支持计划开发的程序，以确定它们是否支持政策（参见 [SP 800-57p2]），以及 2) 确认角色和职责已定义，所有参与者已受教育并了解其角色，系统已到位以维护所有密钥的准确清单，所用过程适用于应用和风险，正常确实施访问控制，并在人员重新分配时移除访问。
2. 应定期重新评估所用的保护机制（例如访问控制机制），涉及它们提供和预期未来提供的安全级别，以及机制是否正常确有效地支持适当政策。应考虑新技术发展和攻击。
3. 更频繁地，应审查使用、操作和维护系统的实体的操作，以验证他们继续遵循既定安全程序，且仅访问他们授权的密钥和元数据。这通常通过检查创建以记录安全相关事件的日志完成。宽松的和不适当的操作可能破坏强大的加密系统。应注明并审查非常不寻常的事件作为对系统尝试攻击的可能指示。

审计报告应按照密钥管理政策中规定提供（例如向系统当局）。

8.5. 密钥管理系统生存能力

密钥管理系统或其环境中的故障可能妨碍或阻止访问组织的存储信息。灾难恢复需要程序和足够的备份能力，以从设施损坏、公用事业服务中断、通信和计算中断、硬件和软件故障以及其他导致存储密钥信息或密钥管理系统本身损坏或丢失的故障中恢复。

[OMB 11-01] 指出加密是保护委托给机构护理的披露敏感信息机密性的重要工具，但机构数据的加密也对任务绩效所需信息的可用性构成风险。提醒机构在实施加密时需要保护其信息技术操作和机构服务的连续性。指南特别指出，如果没有访问解密信息所需的加密密钥，组织冒着失去访问该信息的风险。指南特别强调，机构必须通过适当的数据恢复机制（例如加密密钥恢复）解决信息可用性和保证要求。因此，保留备份或归档的解密密钥副本是谨慎的，包括主密钥、密钥包装密钥和解密加密信息所需的相关密钥材料，直到不再需要访问底层明文信息（参见第 8.5.2 节、表 10 和表 11）。

8.5.1. 备份和归档密钥

[OMB 11-01] 侧重于需要恢复解密密钥以解密加密信息（参见第 8.5 节）。然而，如第 7.2.2.1 节中的表所示，组织可能需要备份或归档的其他运行密钥（例如公签名验证密钥和授权密钥）。备份或归档的密钥材料副本应根据第 5 节的规定存储，以保护加密信息的机密性以及源身份认证、身份身份认证、完整性身份认证和授权过程的完整性。

8.5.2. 密钥恢复

密钥恢复是从密钥备份或归档中检索或重建密钥以处理加密保护信息的过程（例如解密加密信息或验证签名信息上的签名）。密钥恢复有几个相关问题，包括：

1. 哪些密钥信息（如果有）需要备份或归档以供以后恢复？
2. 备份或归档的密钥信息将存储在哪里？
3. 何时进行归档（例如在密钥激活期间或在密钥密码周期结束时）？
4. 谁将负责保护备份或归档的密钥信息？
5. 需要哪些程序来存储和恢复密钥信息？
6. 谁可以请求恢复密钥信息以及在什么条件下？
7. 何时以及在什么条件下通知密钥恢复已发生？
8. 需要执行哪些审计或会计功能以确保密钥信息仅提供给授权实体？

密钥恢复本身不会导致从备份或归档中删除密钥信息。

恢复后密钥的允许使用可能取决于其密码周期（参见第 4.3.4 和 4.3.5 节）。是否应恢复和使用密钥以及从哪里恢复取决于几个因素，包括其密码周期、类别（即对称或非对称）、用途或目的，以及是否已泄露或怀疑泄露。

当密钥已备份或归档时，密钥可以恢复和使用如下：

1. 如果密钥未知或怀疑泄露：

• 秘密（对称）密钥：

仅当密钥的发起者使用周期未超过时，恢复的密钥可用于应用保护（例如加密）。恢复的密钥应尽快撤销，从而结束其发起者使用周期。如果撤销后需要继续功能以应用保护，则应生成新密钥以替换恢复的密钥以应用加密保护。

如果密钥的接收者使用周期未超过或密钥从归档存储中恢复，则恢复的密钥可用于处理受保护数据（例如用于解密密文数据）。

• 非对称密钥对的私钥：

如果密钥的密码周期未超过，恢复的私签名密钥可用于签名生成。回想一下，在大多数情况下不鼓励备份私签名密钥（参见第 7.2.2.1 节），且不允许归档私签名密钥（参见第 7.3.1 节）。恢复的私签名密钥应尽快撤销[47]。如果撤销后需要继续功能，则应生成新签名密钥对。

如果密码周期未超过，恢复的私密钥传输密钥可用于解密密钥。

如果密码周期未超过，恢复的私密钥协商密钥可用于建立新密钥。恢复的私密钥协商密钥应尽快撤销[48]。如果撤销后需要继续功能，则应生成新密钥对。

如果密码周期未超过，恢复的私解封密钥可用于解封密钥。

• 非对称密钥对的公钥：

如果密码周期未超过，恢复的公签名验证密钥、公密钥传输密钥和公封装密钥可用于其指定用途（即分别为签名验证、加密或封装）。

如果密钥的密码周期未超过，恢复的公密钥协商密钥可以使用。

2. 如果密钥信息已泄露，恢复的密钥应撤销（参见第 8.5.4 节）。仅当用户和/或用户的组织确定风险水平可接受时，才应使用恢复的密钥。

• 秘密对称密钥：

恢复的密钥不得用于应用保护（例如加密）。如果需要继续功能以应用保护，则应生成新密钥。

恢复的密钥可用于处理受保护数据（例如用于解密）。

• 非对称密钥对的私钥：

恢复的私签名密钥不得使用。

如果这样做的风险可接受，恢复的私密钥传输密钥或私解封密钥可用于其指定用途（即分别为密钥解密或解封）。

恢复的私密钥协商密钥不得用于建立新密钥，尽管它可用于重建已建立的密钥。

• 非对称密钥对的公钥：

恢复的公签名验证密钥可用于签名验证。

恢复的公密钥传输密钥或公封装密钥不得使用。

恢复的公密钥协商密钥不得用于建立新密钥，尽管它可用于重建已建立的密钥。

8.5.3. 系统冗余/应急计划

加密是防止未经授权访问数据和/或资源的有用工具，但当机制失败时，加密的使用可以阻止有效实体访问关键信息和过程。例如，丢失或损坏解密密钥的唯一副本可以拒绝访问加密信息。组织的操作连续性可以严重依赖于密钥管理系统的应急计划，包括关键逻辑过程和元素的冗余，包括密钥管理和加密密钥。

8.5.3.1. 一般原则

计划从系统故障中恢复是基本管理功能。应预期关键基础设施服务的中断，并应制定计划以维护支持组织主要任务要求的操作连续性。关于密钥管理，以下情况是计划必要的典型情况：

• 丢失密钥卡或令牌
• 忘记控制密钥访问的身份验证器（例如令牌或密码）

• 密钥输入设备故障（例如读卡器、PIV 卡）
• 存储密钥和/或证书的内存介质丢失或损坏
• 密钥泄露
• 证书终止而未安装替换证书
• CRL 或 CKL 损坏
• 密钥或证书生成、注册和/或分发系统、子系统或组件的硬件故障
• 需要重新初始化密钥或证书生成、注册、密钥建立系统、子系统或组件的电源丢失
• 密钥或证书生成、注册、密钥建立系统、子系统或组件所需的内存介质损坏

• 密钥或证书分发记录和/或审计日志丢失或损坏
• 密钥与密钥所有者关联丢失或损坏
• 访问密钥信息或处理受保护信息所需的旧软件或硬件不可用

虽然恢复讨论最常见地侧重于加密数据的恢复和加密通信能力的恢复，但计划还应解决 1) 当加密用于访问控制机制时恢复访问而不造成访问保护的临时丢失，2) 当加密用于授权机制时恢复关键过程而不造成授权限制的临时丢失，以及 3) 在数字签名和消息身份认证应用中维护/恢复完整性保护。

应急计划应包括 1) 提供手段并分配责任以快速识别和报告关键故障；2) 分配责任并提供资源以绕过或替换故障系统、子系统和组件；以及 3) 建立详细的绕过和/或恢复程序。

应急计划包括全方位的集成后勤支持功能。备件（例如关键设备副本、软件程序、手册、数据文件）应可用（要么获取要么安排）并预先定位或交付准备。应急维护、替换和/或绕过指令应准备并分发给指定个人，并在可访问和公布的访问点。指定个人应接受其分配的恢复程序培训，所有人员应接受报告和恢复程序培训。

8.5.3.2. 加密和密钥管理特定恢复问题

密钥恢复能力通常涉及某种冗余或多份密钥信息副本。如果关键密钥信息的一份副本丢失或损坏，通常需要另一份副本来恢复数据和/或恢复能力。然而，存在的密钥副本越多且分发到不同位置，密钥越容易受到存储位置渗透或保管人（例如用户、服务代理或密钥生产/分发设施）颠覆的泄露。在这个意义上，密钥机密性要求与操作连续性要求冲突。需要特别小心保护所有密钥信息副本，特别是关于对称密钥和私（非对称）密钥的信息。[SP 800-57p2] 中提供关于应急计划和计划要求的更多细节。

8.5.4. 泄露恢复

当用于保护敏感信息或关键过程的秘密或私钥泄露给未经授权的实体时，由该密钥保护的所有信息和/或过程立即受到披露、修改、颠覆和/或拒绝服务的影响。所有泄露的密钥应撤销；所有受影响的密钥应在需要时替换；并且，当敏感或关键信息或过程受影响时，应立即进行损害评估。应采取措施减轻疑似未经授权访问受保护数据或过程的后果，并减少未来泄露的可能性或频率。

当秘密（对称）密钥或私（非对称）密钥仅用于保护单个实体的本地信息或单对实体之间的通信时，泄露恢复过程可以相对简单且成本低廉。损害评估和缓解措施通常是本地事务。

然而，当密钥由大量实体共享或影响大量实体时，损害可能广泛，恢复既复杂又昂贵。一些泄露可能特别难以或昂贵恢复的密钥示例包括以下内容：

CA 的私签名密钥，特别是如果它用于签名公钥基础设施中的根证书
• 由大量实体共享的对称密钥包装密钥
• 由大量实体用于导出密钥的密钥导出密钥/主密钥
• 用于加密大型分布式数据库中数据的对称数据加密密钥
• 由大量通信网络参与者共享的对称密钥
• 用于保护大量存储密钥的密钥

在所有这些情况下，需要立即通知大量密钥所有者和依赖方（例如所有授权使用对称密钥算法的私钥或非对称密钥算法的公钥的方）。稍后发布的 CKL 上的密钥标识符或 CRL 上的证书序列号可能不足。这意味着可能需要维护最可能受影响实体的列表，并且需要传达泄露新闻的手段。特别是在对称密钥泄露的情况下，泄露新闻和密钥替换应仅发送给受影响实体，以免鼓励其他人利用这种情况。

需要安全路径来替换泄露的密钥。为了允许快速恢复服务，首选自动化（例如空中或基于网络）替换路径（参见第 7.2.3 节）。然而，在某些情况下，可能没有手动分发的实际替代方案（例如根 CA 私钥的泄露）。在某些情况下，替代密钥的应急分发可能有助于快速恢复服务（例如广泛持有的对称密钥的泄露），但需要考虑运行和应急密钥同时泄露的可能性。

损害评估可能非常复杂，特别是对于 CA 私钥、广泛使用的密钥传输或封装密钥以及大型分布式数据库的许多用户使用的密钥的泄露和替换。

参考文献

1. FIPS 201-3 美国国家标准与技术研究院 (2022) 联邦员工和承包商的个人身份验证 (PIV)，(美国商务部，华盛顿特区)，联邦信息处理标准出版物 (FIPS) FIPS 201-3。
2. FIPS 202 美国国家标准与技术研究院 (2015) SHA-3 标准：基于置换的哈希和可扩展输出函数。(美国商务部，华盛顿特区)，联邦信息处理标准出版物 (FIPS) FIPS 202。
3. FIPS 203 美国国家标准与技术研究院 (2024)。基于模块格的密钥封装机制标准。(美国商务部，华盛顿特区)，联邦信息处理标准出版物 (FIPS) FIPS 203。
4. FIPS 204 美国国家标准与技术研究院 (2024)。基于模块格的数字签名标准。(美国商务部，华盛顿特区)，联邦信息处理标准出版物 (FIPS) FIPS 204。
5. FIPS 205 美国国家标准与技术研究院 (2024) 无状态基于哈希的数字签名标准。(美国商务部，华盛顿特区)，联邦信息处理标准出版物 (FIPS) FIPS 205。
6. FPKI-KRP 联邦公钥基础设施政策管理局 (2017) 联邦公钥基础设施密钥恢复政策，版本 1.0。
7. IGD_B 美国国家标准与技术研究院，加拿大网络安全中心 (2024) FIPS 140-3 和加密模块验证计划的实施指南，[修订]。
8. ISO/IEC 19790 ISO/IEC 19790，信息技术 — 安全技术 — 加密模块的安全要求 2025。
9. ITLBulletin Burr WE, Hash JS (2002) 系统和数据恢复技术。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，ITL 公告，2002 年 4 月。04.pdf
10. Jones Jones NC, Van Meter R, Fowler AG, McMahon PL, Kim J, Ladd TD, Yamamoto Y (2012) 量子计算的分层架构。美国物理学会，Phys. Rev. X 2, 031007。
11. Mariantoni Mariantoni M, (2014) 构建超导量子计算机，PQCrypto 2014 邀请演讲，加拿大滑铁卢。
12. NIST IR 7977 加密技术组 (2016) NIST 加密标准和指南开发过程。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 内部报告 (IR) NIST IR 7977。
13. NIST PQC eval 美国国家标准与技术研究院 (2016) 后量子密码标准化过程的 NIST 提交要求和评估标准。
14. OMB 11-01 管理与预算办公室 (2001) OMB 给联邦机构关于数据可用性和加密的指南。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，[2001 年 11 月 26 日]。
15. RFC 2560 Santesson S, Myers M, Ankney R, Malpani A, Galperin S, Adams C (2013) X.509 互联网公钥基础设施，在线证书状态协议 – OCSP。(互联网工程任务组 (IETF) 网络工作组)，IETF 请求评论 (RFC) 6960。
16. RFC 3647 Chokhani S, Ford W, Sabett R, Merrill C, Wu S (2003) 互联网 X.509 公钥基础设施证书政策和认证实践框架 (互联网工程任务组 (IETF) 网络工作组)，IETF 请求评论 (RFC) 3647。
17. RFC 8032 Josefsson S, Liusvaara I (2017) 爱德华兹曲线数字签名算法 (EdDSA)。(互联网研究任务组 (IRTF))，IRTF 请求评论 (RFC) 8032。
18. SP 800-37 联合任务组 (2018) 信息系统和组织的风险管理框架：安全和隐私的系统生命周期方法。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-37r2。
19. SP 800-38 Dworkin M (2001) 分组密码操作模式建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38。
20. SP 800-38A Dworkin MJ (2001) 分组密码操作模式建议：方法和技术。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38A。
21. SP 800-38B Dworkin MJ (2005) 分组密码操作模式建议：用于身份认证的 CMAC 模式。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38B，包括截至 2016 年 10 月 6 日的更新。
22. SP 800-38C Dworkin MJ (2004) 分组密码操作模式建议：用于身份认证和机密性的 CCM 模式。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38C，包括截至 2007 年 7 月 20 日的更新。
23. SP 800-38D Dworkin MJ (2007) 分组密码操作模式建议：Galois/计数器模式 (GCM) 和 GMAC。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38D。
24. SP 800-38F Dworkin MJ (2012) 分组密码操作模式建议：密钥包装方法。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-38F。

25. SP 800-52 Polk T, McKay KG, Chokhani S (2019) 传输层安全 (TLS) 实施的选择、配置和使用指南。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-52r2。
26. SP 800-56A Barker EB, Chen L, Roginsky A, Vassilev A, Davis R (2018) 使用离散对数密码的成对密钥建立方案建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-56Ar3。
27. SP 800-56B Barker EB, Chen L, Roginsky A, Vassilev A, Davis R, Simon S (2019) 使用整数分解密码的成对密钥建立建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-56Br2。
28. SP 800-56C Barker EB, Chen L, Davis R (2018) 密钥建立方案中的密钥导出方法建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-56Cr1。已撤回。
29. SP 800-57p2 Barker EB, Barker WC (2019) 密钥管理建议：第 2 部分 — 密钥管理组织的最佳实践。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-57pt2r1。
30. SP 800-57p3 Barker EB, Dang QH (2015) 密钥管理建议，第 3 部分：特定应用的密钥管理指南。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-57pt3r1。
31. SP 800-63 Temoshok D, Madruga DP, Choong YY, Galluzzo R, Gupta S, LaSalle C, Lefkovitz N, Regenscheid A (2024) 数字身份指南。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-63-4 2pd. 63-4.2pd
32. SP 800-63A Temoshok D, Abruzzi C, Choong YY, Fenton JL, Galluzzo R, LaSalle C, Lefkovitz NB, Regenscheid A (2024) 数字身份指南：注册和身份证明。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-63A-4 2pd。
33. SP 800-67 Barker EB, Mouha N (2017) 三重数据加密算法 (TDEA) 分组密码建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-67r2。已撤回。
34. SP 800-88 Chandramouli R,,Hibbard E (2025) 媒体清理指南。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-88r2. 0.6028/NIST.SP.800%2D88r2
35. SP 800-89 Barker EB (2006) 获取数字签名应用保证的建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-89。
36. SP 800-90A Barker EB, Kelsey JM (2015) 使用确定性随机比特生成器的随机数生成建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-90Ar1。
37. SP 800-90B Sönmez Turan M, Barker EB, Kelsey JM, McKay KA, Baish ML, Boyle M (2018) 用于随机比特生成的熵源建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-90B。
38. SP 800-90C Barker EB, Kelsey JM, McKay K, Roginsky A, Sönmez Turan M (2025) 随机比特生成器 (RBG) 结构建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-90C。
39. SP 800-108 Chen L (2024) 使用伪随机函数的密钥导出建议（修订版）。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-108r1。
40. SP 800-130 Barker EB, Smid ME, Branstad DK, Chokhani S (2013) 设计加密密钥管理系统框架。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-130。
41. SP 800-131A Barker EB, Roginsky A (2024) 过渡加密算法和密钥长度的使用。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-131Ar3 ipd。
42. SP 800-132 Sönmez Turan M, Barker EB, Burr WE, Chen L (2010) 基于密码的密钥导出建议：第 1 部分：存储应用。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-132。
43. SP 800-133 Barker EB, Roginsky AL (2019) 加密密钥生成建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-133r1。已撤回。
44. SP 800-135 Dang QH (2011) 现有特定应用密钥导出函数建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-135r1。
45. SP 800-140 Schaeffer K (2020) FIPS 140-3 衍生测试要求 (DTR)：CMVP 验证机构对 ISO/IEC 24759 的更新。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-140。

46. SP 800-152 Barker EB, Branstad DK, Smid ME (2015) 美国联邦加密密钥管理系统 (CKMS) 配置文件。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-152。
47. SP 800-175B Barker EB (2020) 联邦政府使用加密标准指南：加密机制。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-175Br1。
48. SP 800-185 Kelsey JM, Chang S-jH, Perlner RA (2016) SHA-3 衍生函数：cSHAKE、KMAC、TupleHash 和 ParallelHash。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-185。
49. SP 800-208 Cooper D, Apon D, Dang Q, Davidson M, Dworkin M, Miller C (2020) 状态哈希基于签名方案的建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-208。
50. SP 800-224 Sönmez Turan M, Brandão (2024) 密钥哈希消息身份认证码 (HMAC)：HMAC 规范和消息身份认证建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-224 ipd。
51. SP 800-227 Alagic G, Barker E, Chen L, Moody D, Robinson A Silberg H, Waller N (2025) 密钥封装机制建议。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-227。
52. SP 800-232 Sönmez Turan M, McKay K, Chang D, Kang J, Kelsey J (2025) 受限设备的 Ascon 基于轻量级加密标准：认证加密、哈希和可扩展输出函数。(美国国家标准与技术研究院，马里兰州盖瑟斯堡)，NIST 特别出版物 (SP) NIST SP 800-232。
53. X995 美国国家标准 (ANS) X9.31-2022，受信任时间戳管理和安全。
54. ISO/IEC18014 时间戳：ISO/IEC 18014-1:2008 信息技术 – 安全技术 – 时间戳服务 – 第 1 部分：框架 ISO/IEC 18014-2:2021 信息安全 – 时间戳服务 – 第 2 部分：生成独立令牌的机制 ISO/IEC 18014-3:2009 信息技术 – 安全技术 – 时间戳服务 – 第 3 部分：生成链接令牌的机制 ISO/IEC 18014-4:2015 信息技术 – 安全技术 – 时间戳服务 – 第 4 部分：时间源的可追溯性
55. Zalka Zalka C (1999) Grover 的量子搜索算法是最优的，美国物理学会，Phys. Rev. A 60, 2746。

附录 A. 加密和非加密完整性和源身份认证机制

完整性和源身份认证服务在包括密钥管理的协议中特别重要。当本建议中讨论完整性或源身份认证服务时，假设使用"强"加密完整性或源身份认证机制。安全通信和密钥管理通常使用提供某些服务（例如完整性保护或"可靠"传输服务）的通信协议提供。[49] 然而，通信协议的完整性保护或可靠传输服务不一定足以满足加密应用，特别是密钥管理，并且可能对诸如"完整性"等术语的含义存在混淆。

所有通信信道都有一些噪声（即传输介质插入的无意错误），其他因素（例如网络拥塞）可能导致网络数据包[50] 丢失。因此，通信协议的完整性保护和可靠传输服务设计为在具有某些最坏情况噪声特性的信道上运行。检测损坏数据包（即包含比特错误的数据包）或丢失数据包的实体可以要求发送者重新传输它们。传输比特错误通常使用 1) 非加密校验和[51] 检测数据包中的传输错误和 2) 数据包计数器检测丢失的数据包来检测。非加密校验和通常在检测传输噪声方面有效。例如，局域网应用中常用的 CRC-32 校验和算法检测所有跨度小于 32 比特的错误突发，并以 2^{-32} 失败概率检测更长的随机突发。然而，非加密 CRC-32 校验和不检测 32 比特消息字的交换，特定消息比特中的特定错误导致 CRC-32 校验和的可预测变化。复杂的攻击者可以利用这一点来创建通过 CRC-32 完整性检查的篡改消息，甚至（在某些情况下）当消息加密时。

前向纠错码是非加密校验和的子集，可用于纠正常有限数量的错误而无需重新传输。这些码可用作校验和，取决于应用和通信信道的噪声特性。

然而，加密完整性身份认证机制（例如 MAC、数字签名）保护免受主动、智能攻击者的攻击，他们可能尝试将攻击伪装成噪声。通常，攻击者改变的比特不是随机的，而是针对系统属性和漏洞。加密完整性身份认证机制在检测随机噪声事件方面有效，但它们也检测更系统的故意攻击。

加密哈希函数（例如 SHA-256）设计为使哈希值的每个比特成为消息文本每个比特的复杂非线性函数，并使找到哈希到相同值的两个消息不切实际。平均而言，需要执行 2^{128} SHA-256 哈希操作来找到哈希到相同值的两个消息，找到另一个消息其 SHA-256 哈希与任何给定消息的哈希相同要困难得多。加密 MAC 算法使用哈希函数或对称加密算法和密钥来身份认证消息的源并保护其完整性（即检测错误）。数字签名使用公钥算法和哈希函数或 XOF 来提供完整性和源身份认证服务。与非加密完整性或源身份认证机制相比，这些加密服务通常计算成本更高。这似乎是不可避免的，因为加密保护还必须抵御拥有大量资源的知识渊博的对手的故意攻击。

加密和非加密完整性身份认证机制可以一起使用。例如，在 TLS 协议中（参见 [SP 800-52]），客户端和服务器可以相互身份认证身份，建立共享"主密钥"，并传输加密负载数据。整个 TLS 协议运行的每一步都受到加密完整性和源身份认证机制的保护，负载通常加密。像大多数加密协议一样，TLS 将（以给定概率）检测改变协议运行任何部分的任何攻击或噪声事件。然而，TLS 没有错误恢复协议。如果检测到错误，协议运行简单地终止。启动新的 TLS 协议运行非常昂贵。因此，TLS 需要"可靠"传输服务，通常是互联网传输控制协议 (TCP)，以处理和恢复普通网络传输错误。TLS 将检测由攻击或噪声事件引起的错误，但没有机制从中恢复。TCP 通常将在逐个数据包的基础上检测此类错误，并通过在将数据传递给 TLS 之前重新传输单个数据包从中恢复。TLS 和 TCP 都有完整性身份认证机制，但复杂的攻击者可以轻松欺骗 TCP 的较弱非加密校验和。然而，由于 TLS 中提供的加密完整性身份认证机制，攻击被挫败。

用户和协议设计者必须考虑加密和非加密完整性或错误纠正常机制之间的一些交互。例如，许多加密模式扩展密文错误，密文中的单个比特错误可以改变结果明文的整个块或更多。如果在加密前应用前向纠错[52]（例如使用 MAC 算法，如 HMAC），并且在传输期间在密文中插入错误，则解密期间的错误扩展可能"压倒"错误纠正常机制，使错误无法纠正常。因此，最好在加密过程后应用前向错误纠正常机制（例如在加密数据上计算 MAC，而不是在明文数据上计算 MAC 然后执行加密）。这将允许接收实体的系统在密文解密前纠正常错误，产生"正常确"明文。

加密和非加密机制之间的交互也可能导致安全漏洞。一种经典发生方式是使用流密码[53] 和非加密校验和（例如 CRC-32）的协议，这些校验和在明文数据上计算并确认良好数据包。攻击者可以复制加密数据包，选择性修改单个密文比特，选择性更改 CRC 中的比特，然后发送数据包。使用协议的确认机制，攻击者可以确定 CRC 何时正常确，从而确定底层明文的某些比特。至少一个广泛使用的无线加密协议已被此类攻击破解。

附录 B. 密钥恢复

B.1. 一般性讨论

联邦机构有责任保护其信息技术系统中包含、处理和传输的信息。加密技术通常用作此过程的一部分。这些技术用于提供机密性、完整性身份认证、身份身份认证、源身份认证、不可否认性和/或访问控制。应建立政策以解决加密保护信息的保护和持续可访问性，并应到位程序以确保信息在其生命周期内保持有效。当使用加密密钥材料保护信息时，可能需要相同的密钥材料来移除（例如解密）或验证这些保护（例如验证 MAC）。

在许多情况下，用于加密过程的密钥材料可能不易获得。这可能是由于几个原因，包括：

1. 密钥的密码周期已到期，密钥材料不再在运行存储中。
2. 密钥材料已损坏（例如系统崩溃，或病毒修改了运行存储中保存的密钥材料）。
3. 密钥的所有者不可用，所有者的组织需要获取明文信息。

为了在需要时获得此密钥材料，密钥材料需要保存在某处或可从其他可用密钥材料构建（例如可导出）。重新获取密钥材料的过程称为密钥恢复。密钥恢复通常用作当需要从加密信息恢复明文信息时的信息恢复方法之一。然而，密钥材料或其他相关信息可能需要出于其他原因恢复，例如正常常运行存储中密钥材料的损坏（例如用于归档文档的 MAC 验证；参见第 7.2.1 节）。密钥恢复也可能适用于恢复密钥材料比生成和分发新密钥材料更容易或更快的情况。

然而，有些应用可能不需要长时间保存密钥材料，因为当密钥材料或密钥材料保护的信息变得不可访问时，有其他程序恢复运行能力。此类类型的应用可能包括电信，其中传输的信息可以重新发送，或者可以快速导出或获取新密钥材料进行分发的应用。

组织有责任确定其应用是否需要恢复密钥材料。拥有密钥恢复能力的决定应逐案做出，此决定应反映在密钥管理政策和密钥管理实践声明中（参见 [SP 800-57p2]）。如果决定提供密钥恢复，则应根据要恢复的密钥材料类型选择、设计和实施适当的密钥恢复方法。需要选择适当的实体来维护备份或归档数据库并管理密钥恢复过程。如果决定提供密钥恢复，则与该密钥相关的所有信息（例如元数据）也应可恢复。

B.1.1. 从存储密钥材料恢复

备份或归档密钥和其他密钥信息的主要目的是在它们不可用时能够恢复它们。例如，如果解密密钥丢失或修改，加密信息无法转换回明文信息；如果用于验证数据完整性的密钥不可用，则无法身份认证数据的完整性。密钥恢复过程从备份或归档存储中检索密钥材料，并将其放置在设备、模块或其他立即可访问的存储中，通常在某些人类的协助下（参见第 7.3.1 节）。

B.1.2. 通过重建密钥材料恢复

一些密钥材料可以通过从其他可用密钥材料重建或重新导出密钥材料来恢复 — 即"基础"密钥材料（例如密钥导出方法的密钥导出密钥或种子）。基础密钥材料应在正常常运行存储中可用（参见第 7.2.1 节）、备份存储（参见第 7.2.2.1 节）或归档存储（参见第 7.3.1 节）。

B.1.3. 需要可恢复密钥材料的条件

备份或归档密钥材料以进行可能密钥恢复的决定应逐案做出，并应基于第 7.2.2.2 节中提供的列表。

当密钥所有者请求密钥恢复操作时，应采取以下行动：

1. 如果丢失的密钥可能已泄露，则应在恢复后尽快替换密钥，以限制恢复的密钥及其保护的数据的暴露（参见第 7.2.3.1 节）。这可能包括使用新密钥在受保护数据上重新应用保护。
2. 如果密钥变得不可访问或已修改但未怀疑泄露，则可以恢复和使用密钥，如第 8.5.2 节中讨论。

附录 B.2 至 B.10 提供确定是否需要密钥恢复能力的指南以及可能与密钥相关联的其他信息（例如与密钥相关联的元数据）。

B.1.4. 密钥恢复系统

密钥恢复是一个广义术语，可应用于恢复加密密钥和与该密钥相关联的信息（例如密钥的元数据）的几种不同技术。恢复密钥所需的信息对于每个应用或每个密钥恢复技术可能不同。术语"密钥恢复信息" (KRI) 指恢复或验证加密保护数据所需的密钥信息聚合。可视为 KRI 的信息包括要恢复的密钥材料或足以重建密钥材料的足够信息、其他相关密钥信息、密钥创建的时间、与密钥所有者相关联的标识符（即创建密钥或拥有由该密钥保护的数据的个人、应用或组织），以及请求者必须满足的任何条件才能恢复密钥材料。

当组织确定其全部或部分密钥材料需要密钥恢复时，需要根据明确定义的密钥恢复政策建立安全密钥恢复系统 (KRS)（参见附录 B.1.5）。KRS 应支持密钥恢复政策，由保存和恢复密钥材料的技术和设施、管理系统程序以及系统相关人员组成。

当确定密钥恢复必要时，KRI 可以存储在组织内（例如在备份或归档存储中）或由受信任实体在远程站点存储。有许多可接受的启用密钥恢复的方法。KRS 1) 可以使用保险箱存储密钥材料建立；2) 可能使用提供明文数据初始保护、相关密钥材料存储和该密钥材料恢复的单台计算机；3) 可能包括具有中央密钥恢复中心的计算机网络；或 4) 可以使用其他配置设计。由于 KRS 提供恢复加密密钥的手段，应执行风险评估以确保 KRS 充分保护组织的信息并在需要时可靠提供 KRI。需要提供密钥恢复的组织有责任确保密钥恢复政策、密钥恢复方法和 KRS 充分保护 KRI。

联邦政府使用的 KRS 应：

1. 生成或提供足够的 KRI 以允许恢复或验证受保护信息
2. 确保保存的密钥和其他 KRI 的有效性
3. 确保 KRI 以与相应加密保护数据相称的持久性和可用性存储
4. 使用符合 [FIPS 140-3] 的加密模块
5. 使用加密时使用批准的算法
6. 使用提供与 KRI 相关信息敏感性相称的安全强度的算法和密钥长度
7. 设计为执行密钥恢复政策（参见附录 B.1.5）
8. 保护 KRI 免受未经授权披露或销毁，验证请求的源，并确保仅向请求者提供请求和授权的信息
9. 保护 KRI 免受修改
10. 具有提供审计跟踪的能力，审计跟踪不应包含恢复的密钥或系统可能使用的任何密码，并应包括被审计事件的标识、事件时间、导致事件的实体相关联的标识符，以及事件的成功或失败
11. 限制对 KRI、审计跟踪和身份认证数据的访问仅限于授权个人
12. 禁止修改审计跟踪

B.1.5. 密钥恢复政策

对于每个系统、应用和使用的加密技术，必须确定是否需要保存密钥材料以供以后恢复，以允许随后解密或验证由密钥材料保护的信息。确定其部分或全部密钥材料需要密钥恢复的组织应制定密钥恢复政策，解决该信息的保护和持续可访问性[54]（参见 [FPKI-KRP]）。政策应回答以下问题（至少）：

1. 给定应用需要保存哪些密钥材料？例如，用于解密存储信息的密钥和 IV 可能需要保存。用于身份认证存储或传输信息的密钥也可能需要保存。
2. 密钥材料将如何以及在哪里保存？例如，密钥材料可以由启动数据保护（例如加密数据）的个人保存在保险箱中，或在传输、接收或存储受保护数据时自动保存。密钥材料可以本地保存或在某个远程站点保存。
3. 谁将负责保护 KRI？例如，每个个人、组织或子组织可以负责其自己的密钥材料，或者外部组织可以执行此功能。
4. 谁有权在请求时接收 KRI 以及在什么条件下？例如，保护信息的个人（即使用和存储 KRI 的个人）或分配给个人的组织可以恢复密钥材料。可能需要考虑法律要求。当存储 KRI 的个人不可用时，组织可以请求信息。
5. 在什么条件下可以修改政策以及由谁修改？
6. KRS 中将包括哪些审计能力和程序？政策应识别要审计的事件。可审计事件可能包括 KRI 请求及其相关响应；谁提出请求以及何时；审计功能的启动和关闭；执行读取、修改或销毁审计数据的操作；请求访问实体身份认证数据；以及身份认证机制的使用。
7. KRS 将如何处理安全强度已降低到可接受水平以下的旧密钥材料？
8. 何时以及在什么条件下通知密钥材料已恢复？例如，当组织恢复解密密钥因为个人缺席时，可以通知加密数据并存储 KRI 的个人，但当组织监控该个人的活动时，可能不通知个人。
9. 当 KRS 或 KRS 内的部分数据泄露时需要遵循哪些程序？

B.2. 数字签名密钥对

数字签名密钥对的私钥（即私签名密钥）由密钥对的所有者用于对信息应用数字签名。相应公钥（即公签名验证密钥）由依赖实体用于验证数字签名。

B.2.1. 私签名密钥

一般来说，私签名密钥不应归档（参见表 12）。签名密钥对的私钥通常不需要密钥备份，因为签名的不可否认性受到质疑。然而，可能存在例外。例如，在某些情况下，可能无法根据第 7.1.5.1 节及时替换私签名密钥并分发其相应公签名验证密钥，因此从备份存储中恢复私签名密钥可能是合理的。例如，这可能是 CA 的私签名密钥的情况。

如果考虑备份私签名密钥，则应评估其重要性和恢复密钥所需时间与生成新密钥对并认证和分发新公签名验证密钥所需时间的比较。如果备份私签名密钥，则应使用高度安全的方法恢复私签名密钥。根据情况，密钥应仅恢复立即使用，然后应在恢复过程后尽快替换。

代替备份私签名密钥，可以生成第二个私签名密钥和相应公钥，并根据第 7.1.5.1 节分发公签名验证密钥，以便在主私签名密钥不可用时使用。

B.2.2. 公签名验证密钥

只要需要验证由相应私签名密钥签名的信息，备份或归档公签名验证密钥是适当的。在公钥已认证（例如由 CA）的情况下，保存公钥证书将是存储公钥的适当形式。基础设施可以提供备份或归档存储（例如由证书存储库）。公钥应存储在备份存储中直到私钥密码周期结束，并应存储在归档存储中只要需要验证签名数据。

B.3. 身份认证密钥

身份认证密钥用于提供信息完整性和源的保证。

B.3.1. 对称身份认证密钥

对称身份认证密钥用于提供信息完整性和源的保证。对称身份认证密钥可用于：

1. 由发起者创建 MAC，可以验证以确定身份认证信息的完整性和可能的源。然后可以存储身份认证信息及其 MAC 以供以后检索，或传输给另一个实体。

如果发起者可以在计算 MAC 之前建立新身份认证密钥，使密钥可用于任何需要验证使用此新密钥身份认证的信息的实体，则不需要备份或归档对称身份认证密钥。如果不能及时建立新身份认证密钥，则应备份或归档身份认证密钥。

2. 由接收实体在收到身份认证消息时立即确定接收信息的完整性和该信息的源。接收的 MAC 和相关身份认证信息可能或可能不随后存储。

如果可以向接收者安全提供身份认证密钥并保证发送实体身份的保证，则不需要备份或归档对称身份认证密钥。或者，建立新对称身份认证密钥而不是重用"丢失"密钥也是可接受的。然而，需要使用新身份认证密钥在信息上计算新 MAC。如果两个替代方案都不可接受，则应备份对称身份认证密钥。

如果随后存储 MAC 和成功身份认证的信息，则只要需要确定信息的完整性和源，就应备份或归档对称身份认证密钥。

3. 由从存储中检索身份认证信息和 MAC 的实体确定存储信息的完整性。

只要需要确定信息的完整性和源，就应备份或归档对称身份认证密钥。

对称身份认证密钥可以存储在备份存储中用于密钥的密码周期，并存储在归档存储中直到不再需要。如果通过重建恢复身份认证密钥，则"基础"密钥（例如密钥导出方法的主/密钥导出密钥或种子）可以存储在正常常运行存储或备份存储中用于基础密钥的密码周期，并存储在归档存储中直到不再需要。

B.3.2. 身份认证（非对称）密钥对

公身份认证密钥由接收实体用于获得参与身份认证通信会话的密钥对所有者（即密钥对的所有者）身份的保证。相应私身份认证密钥由发起实体用于通过对信息计算数字签名向接收实体提供此保证。此密钥对可能不支持不可否认性。

B.3.2.1. 私身份认证密钥

私身份认证密钥用于建立参与身份认证通信会话的实体（即密钥对的所有者）的身份。如果可以根据第 7.1.5.1 节及时生成和分发新密钥对，则不需要备份私身份认证密钥。然而，如果不能快速生成新密钥对，则应在私钥密码周期期间将私钥存储在备份存储中。私钥不得存储在归档存储中。

B.3.2.2. 公身份认证密钥

只要需要验证参与身份认证通信会话的密钥对所有者的身份，将公身份认证密钥存储在备份或归档存储中是适当的。

在公身份认证密钥已认证（例如由 CA）的情况下，保存公钥证书将是存储公钥的适当形式；基础设施可以提供备份或归档存储（例如由证书存储库）。公钥可以存储在备份存储中直到私身份认证密钥的密码周期结束，并可以存储在归档存储中只要需要。

B.4. 随机数生成密钥

用于随机比特生成的密钥不得备份或归档。如果此密钥丢失或修改，则应替换为新密钥。

B.5. 密钥导出/主密钥

对称密钥导出/主密钥通常用于导出一个或多个密钥或其他密钥材料。不得用于任何其他目的。

确定是否需要备份或归档对称密钥导出/主密钥取决于几个因素：

1. 建立新对称密钥导出/主密钥有多容易？如果密钥手动分发（例如在智能卡中或通过回执邮件以硬拷贝形式），则应备份或归档密钥。如果使用自动化密钥建立协议可以轻松快速地建立新密钥，则根据应用，备份或归档密钥可能不必要或不可取。
2. 导出密钥可以在不使用对称密钥导出/主密钥的情况下恢复吗？如果导出密钥不需要备份或归档（例如由于其用途）或导出密钥的恢复不依赖于从密钥导出/主密钥重建（例如导出密钥以加密形式存储），则备份或归档密钥可能不可取。如果需要备份或归档导出密钥，且密钥恢复方法需要从密钥导出/主密钥重建造出密钥，则应备份或归档密钥导出/主密钥。

B.6. 密钥建立（自动化）

B.6.1. 对称密钥包装密钥

对称密钥包装密钥用于包装（即加密和完整性保护）密钥材料以便在一个或多个消息中传输。

如果无法 readily 安全地建立新对称密钥包装密钥并保证共享实体的身份，则应考虑备份对称密钥包装密钥。

仅用于传输密钥材料的对称密钥包装密钥的归档可能不必要。

B.6.2. 密钥传输密钥对

密钥传输密钥对用于在通信期间将密钥材料从发送实体传输到接收实体。发送实体使用公密钥传输密钥加密密钥材料；接收实体使用私钥解密接收的加密密钥材料。

B.6.2.1. 公密钥传输密钥

公密钥传输密钥的备份或归档可以完成但可能不必要。如果发送实体丢失另一方的公密钥传输密钥或确定密钥已损坏，如果发送实体保证实际提供公钥的方的身份，或通过获取包含公钥的公钥证书（如果公钥已认证），则可以从密钥对所有者（即另一方）重新获取密钥。

B.6.2.2. 私密钥传输密钥

私密钥传输密钥应备份或归档，除非 1) 可以快速生成新密钥对并将公钥提供给发送实体（并保证提供新公钥的密钥对所有者身份）或 2) 已生成替代密钥对并使公钥可用（例如在证书中）。

如果接收的加密密钥材料存储以供以后解密，则应备份或归档私密钥传输密钥。参见附录 B.8.2 讨论存储密钥。

B.6.3. 对称密钥协商密钥

对称密钥协商密钥在通信期间用于建立密钥材料（例如对称密钥包装密钥、对称数据加密密钥、对称身份认证密钥或 IV）。每个密钥协商密钥由两个或多个实体共享。

如果这些密钥手动分发（例如在密钥加载设备中或通过回执邮件），则应备份对称密钥协商密钥。

如果有可用自动化手段快速建立新密钥（例如可以使用密钥传输或密钥封装机制建立新对称密钥协商密钥），则不需要备份对称密钥协商密钥。

对称密钥协商密钥可以归档。

B.6.4. 静态密钥协商密钥对

静态密钥协商密钥对用于在两个实体之间建立对称密钥材料（参见 [SP 800-56A] 和 [SP 800-56B]），有时与临时密钥对结合使用（参见附录 B.6.5 和 [SP 800-56A]）。在某些密钥协商方案中，一个实体（在 [SP 800-56A] 中指定为发起实体）仅使用临时密钥对而不是静态密钥协商密钥对。

在这些方案中，每个实体使用另一方的公钥、自己的私钥，以及（在某些方案中）自己的公钥来生成共享密钥材料。

B.6.4.1. 公静态密钥协商密钥

如果以下情况，则不需要备份公静态密钥协商密钥：

1. 公钥已认证并可以按请求获取；
2. 可以从另一个实体获取公钥（例如与公静态密钥协商密钥相关联的密钥对的所有者）并保证所有者身份；
3. 打算在密钥协商计算中使用公钥的实体是静态密钥协商密钥对的所有者，并且可以重新计算公钥（例如使用私密态密钥协商密钥）；或
4. 打算在密钥协商计算中使用公钥的实体是密钥对的所有者，并且可以及时生成和安全建立新密钥对（即保证所有者身份）。然后可以将新生成的公静态密钥协商密钥提供给参与密钥协商过程的另一个实体。

否则，应备份公静态密钥协商密钥。

公钥可以归档。

B.6.4.2. 私密态密钥协商密钥

如果不能及时替换私密态密钥协商密钥，或者需要保留它以恢复先前协商的密钥材料，则应备份私钥以继续操作。

私钥可以归档。

B.6.5. 临时密钥协商密钥对

临时密钥协商密钥对在单个密钥协商事务期间生成并分发公钥（例如在通信会话开始时），不得重用。此密钥对用于建立共享密钥材料（通常与静态密钥对组合使用）。并非所有密钥协商方案都使用临时密钥对，当使用时，并非所有实体都使用临时密钥对（参见 [SP 800-56A]）。

B.6.5.1. 公临时密钥协商密钥

公临时密钥协商密钥可以备份或归档。只要重建计算中不需要相应私临时密钥，这可能允许在以后时间重建造立的密钥材料。

B.6.5.2. 私临时密钥协商密钥

私临时密钥协商密钥不得备份或归档。[55] 如果私临时密钥丢失或损坏，则可以生成新密钥对，并可以将新公临时密钥提供给密钥协商过程中的其他参与实体。

B.6.6. 静态封装/解封密钥对

发送实体使用公静态封装密钥生成和封装对称密钥以提供给封装/解封密钥对的所有者。密钥对的所有者使用相应私密态解封密钥解封接收的封装密钥。

B.6.6.1. 公静态封装密钥

如果可以从密钥对所有者重新获取密钥或通过获取包含公静态封装密钥的公钥证书（假设公钥已认证），则备份或归档公静态封装密钥可能不必要。否则，可以从预期接收实体请求新公静态密钥封装密钥。

B.6.6.2. 私密态解封密钥

私密态解封密钥应备份或归档直到不再需要。

B.6.7. 临时封装/解封密钥对

临时封装/解封密钥对在单个密钥建立事务期间生成和使用，不得重用（参见 [SP 800-227]）。发送实体使用公临时封装密钥生成和封装对称密钥以提供给封装/解封密钥对的所有者。密钥对的所有者使用相应私临时解封密钥解封接收的封装密钥。

B.6.7.1. 公临时封装密钥

公临时封装密钥不需要备份或归档，因为它仅用于单个密钥建立事务然后销毁。如果不可用，可以要求临时封装/解封密钥对的所有者重新发送公钥或生成另一个密钥对并提供新公临时封装密钥（两种情况下都保证来自所有者的身份）。

B.6.7.2. 私临时解封密钥

如果私临时解封密钥旨在在收到使用相应公临时封装密钥封装的密钥后立即使用，则所有者不需要备份它。如果此时私钥不可用，则可以生成新临时密钥对并将公钥提供给另一个实体。

如果收到封装密钥时未解封接收的密钥，或者解封密钥可能在以后时间用于解封接收的密钥，则应备份或归档私临时解封密钥（参见附录 B.8 讨论存储中的密钥）。

B.7. 对称数据加密/解密密钥

对称数据加密密钥用于保护传输或存储数据的机密性。相同的密钥用于加密要保护的明文数据，然后用于解密加密数据（即密文），从而获得原始明文。

只要使用密钥加密的任何数据可能需要解密，密钥就需要可用。

B.7.1. 传输中数据的加密/解密

仅用于传输的对称数据加密密钥由发送实体用于加密数据，由接收实体用于解密密文数据。

• 情况 1：发送实体不再拥有与预期接收者共享的加密密钥。如果可以 readily 生成和分发新加密/解密密钥，则这些密钥不需要备份或归档。否则，密钥应备份或归档直到不再需要。
• 情况 2：接收实体总是在收到时立即解密数据。加密/解密密钥应备份或归档直到不再需要（参见附录 B.7.2 和 B.8），除非可以 readily 生成和分发新加密/解密密钥。
• 情况 3：接收实体存储接收的密文以供以后解密。加密/解密密钥应备份或归档直到不再需要（参见附录 B.7.2 和 B.8）。

B.7.2. 静态数据的加密/解密

对称数据加密密钥应在密钥密码周期期间存储在备份存储中，如果需要在密钥发起者使用周期之外，则应存储在归档存储中。在许多情况下，密钥受保护并与加密数据一起存储（参见附录 B.8）。

B.8. 密钥材料存储

密钥和其他相关信息（即 KRI）可以存储在计算机内的运行存储中（例如 RAM）、设计为保护密钥的硬件中，或在外存储介质上（例如备份或归档以在远程位置存储）（参见第 5.2.2.7 节）。当存储介质本身不提供保护时，需要使用备份或归档机密性密钥加密、包装或封装存储的密钥，并在加密、包装或封装过程不提供完整性保护时使用完整性保护密钥，以确保存储密钥的机密性和完整性。密钥存储介质可以组织为具有多层密钥的树结构（参见图 6）。

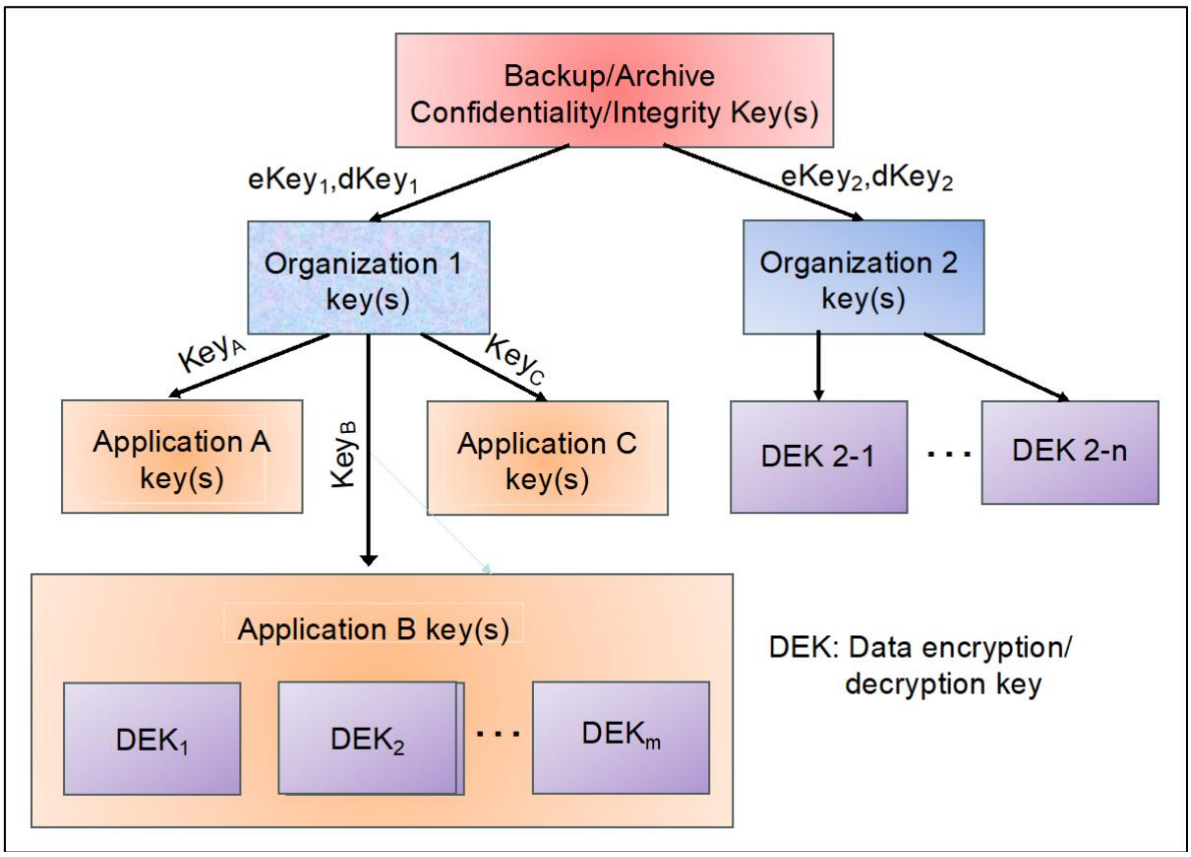

图 6. 存储中密钥树示例

据推测，最低层密钥用于加密密钥以外的数据。每一层的安全性部分取决于其上层的安全性。

使用图 6 中描绘的示例，最高层密钥可以是非对称密钥包装密钥对（例如 RSA 密钥对），用于下一层密钥的机密性保护。每个组织可能使用不同的密钥对。在图 6 中，组织 1 的公包装密钥可能是 $eKey_1$，相应私拆封密钥可能是 $dKey_1$。组织 1 有几个应用，并对每个应用使用不同的密钥包装密钥（显示为 Key_A、Key_B 和 Key_C）使用对称密钥包装算法（例如 AES-CCM）来保护数据密钥（即分别为应用 A、B 和 C）。应用 B 已生成多个数据密钥以使用 AES-CCM 和其包装密钥 Key_B 保护其数据 (DEK_1、DEK_2、...)。在此示例中，数据密钥 DEK_1 已用于使用 AES-CCM 加密明文数据：

$$EncryptedData = ENCRYPT_{AES-CCM}(DEK_1, PlaintextData). \tag{1}$$

DEK_1 使用 AES-CCM 和 Key_B 包装：

$$WrappedDEK_1 = WRAP_{AES-CCM}(Key_B, DEK_1), \tag{2}$$

Key_B 使用 RSA 和 $eKey_1$ 包装：

$$WrappedKey_B = WRAP_{RSA}(eKey_1, Key_B). \tag{3}$$

存储 $Wrapped Key_B$、$Wrapped DEK_1$ 和 $EncryptedData$。树中的最高层密钥 ($dKey_1$) 在不受存储系统保护时应安全离线存储（例如在具有双重访问控制的保险箱中）。

为了访问由 DEK_1 保护的数据（即明文数据），私拆封密钥 ($dKey_1$) 用于拆封组织 1 的对称拆封密钥 Key_B：

$$Key_B = UNWRAP_{RSA}(dkey_1, WrappedKey_B), \tag{4}$$

然后对称拆封密钥 (Key_B) 用于拆封 DEK_1：

$$DEK_1 = UNWRAP_{AES-CCM}(Key_B, EncryptedDEK_1), \tag{5}$$

DEK_1 用于解密其保护的数据。

$$PlaintextData = DECRYPT_{AES-CCM}(DEK_1, EncryptedData). \tag{6}$$

B.8.1. 对称密钥包装/拆封密钥

对称密钥包装密钥用于包装（即加密和完整性保护）密钥材料以进行存储，并可用于保护多组密钥材料（例如参见附录 B.8 中的公式 2）。对称密钥包装密钥应归档或离线存储（例如在具有双重访问控制的保险箱中），直到不再需要拆包以前使用该密钥包装的密钥材料。

B.8.2. 非对称密钥加密/解密密钥对

非对称公钥加密密钥可用于加密密钥材料以进行存储（例如参见附录 B.8 中的公式 3）。相应私解密密钥用于在需要时解密密钥材料（例如参见附录 B.8 中的公式 6）。

B.8.2.1. 公密钥包装密钥

假设可以 readily 生成另一个密钥加密/解密密钥对，则备份或归档公密钥包装密钥不必要。

B.8.2.2. 私密钥拆封密钥

只要需要访问由相应公钥加密密钥加密的密钥材料，私密钥拆封密钥应备份或归档。

B.8.3. 封装/解封密钥对

封装密钥可用于封装对称密钥以保护存储中的密钥或数据。相应解封密钥将用于解封封装的密钥。

B.8.3.1. 公封装密钥

假设可以 readily 生成另一个封装/解封密钥对，则备份或归档公封装密钥不必要。

B.8.3.2. 私解封密钥

只要可能需要访问封装的密钥材料，私解封密钥应备份、归档或离线存储。

B.9. 授权

B.9.1. 对称授权密钥

对称授权密钥用于向实体提供特权（例如访问某些数据或授权执行某些功能）。丢失此密钥将拒绝特权（例如禁止访问和不允许执行这些功能）。如果授权密钥丢失或损坏且可以及时替换，则不需要备份授权密钥。对称授权密钥不得归档。

B.9.2. 授权密钥对

授权密钥对用于确定实体可以承担的特权。私钥用于建立特权的"权利"。相应公钥用于确定实体拥有特权权利。

B.9.2.1. 私授权密钥

丢失私授权密钥将拒绝特权（例如禁止访问和不允许执行需要授权的某些功能）。如果私钥丢失或损坏且可以及时替换，则不需要备份私钥。否则，应备份私钥。私钥不得归档。

B.9.2.2. 公授权密钥

如果可以及时替换授权密钥对（即通过重新生成密钥对并将私钥安全分发给寻求授权的实体），则不需要备份公授权密钥。否则，应备份公授权密钥。不需要归档公授权密钥，因为仅使用相应私授权密钥授予授权，而私授权密钥不归档（参见附录 B.9.2.1）。

B.10. 其他相关信息

像密钥一样，其他相关信息可能需要备份或归档，取决于其用途。

B.10.1. 算法参数

算法参数与某些公钥算法结合使用以生成密钥对或执行基本算法功能。如果无法从另一个受信任来源（例如 PKI 证书）获取，或者如果任何新算法参数无法及时安全分发，则应备份或归档算法参数。

B.10.2. 初始化向量 (IV)

IV 在使用分组密码算法加密或身份认证数据期间在几种操作模式中使用。IV 通常与其保护的数据一起存储。如果不与数据一起存储，则只要需要处理使用 IV 保护的数据（例如解密或身份认证），就应备份或归档 IV。

B.10.3. 共享密钥

共享密钥由参与密钥协商过程的每个实体生成。然后使用共享密钥导出要在后续加密操作中使用的共享密钥材料。共享密钥可以在交互式通信期间生成（例如两个实体都在线）或在非交互式通信期间生成（例如在存储转发应用中）。

共享密钥不得备份或归档。

B.10.4. 种子

种子用于生成随机比特或密钥材料。当用于生成随机比特时，种子不得备份或归档，但可以替换。当用于重新生成（即重建）密钥材料时，种子可以备份或归档。

B.10.5. 其他公开和秘密信息

公开和秘密信息通常在密钥建立期间使用。信息可能需要可用于识别处理加密保护数据所需的密钥（例如解密或身份认证）。在这种情况下，信息应备份或归档直到不再需要处理受保护数据。

B.10.6. 中间结果

除种子的生成和使用外（参见附录 B.10.4），加密操作的中间结果不得备份或归档。

B.10.7. 密钥控制信息/元数据

密钥控制信息可用于确定用于处理加密保护数据（例如解密或身份认证）的密钥和其他信息、识别密钥的用途，或识别共享密钥的实体（参见第 5.2.3 节）。此信息可以包含在密钥的元数据中。

只要相关密钥需要可用，密钥控制信息应备份或归档。

B.10.8. 随机数

随机数由随机数生成器生成。随机数的备份或归档取决于其使用方式。

B.10.9. 密码

密码由实体用于获取访问特权、导出密钥，或检测密码重用。

如果密码仅用于获取访问特权且可以及时替换，则不需要备份密码。在这种情况下，密码不得归档。

如果密码用于导出加密密钥或防止密码重用，则应备份和归档密码。

B.10.10. 审计信息

包含密钥管理事件的审计信息应备份和归档。

附录 C. 后量子算法的安全强度类别

估计后量子加密系统的安全强度可能存在显著不确定性。可能发现新量子算法，导致新密码分析攻击，并且预测未来量子计算机性能特征（例如其成本、速度和内存大小）的能力有限。

为了解决这些不确定性，NIST 开发了一系列广泛的安全强度类别[56] 以评估后量子算法候选者 [NIST PQC eval]。每个类别由相对易于分析的参考原语定义，其安全性作为各种可能与实践安全相关的指标的底线。给定加密系统可以使用不同参数集实例化以适应不同类别。此分类的目标是：

1. 通过努力确保比较的参数集提供可比安全性来促进提交算法之间的有意义性能比较
2. 使组织能够就何时过渡到更长密钥做出谨慎的未来决策
3. 允许关于在填充机制或需要对称密码的方案其他组件中使用哪些对称原语的一致和明智选择
4. 更好地理解给定设计方法中涉及的安全性和性能权衡

根据上述第二和第三个目标，分类方法基于现有 NIST 标准在对称密码中提供的安全强度范围，已确定为对量子密码分析提供显著抵抗。该方法还考虑各种可能反映量子和经典计算技术未来发展不同预测的指标。

分类方法考虑各种可能指标，反映量子和经典计算技术未来发展的不同预测。

在 NIST PQC 标准化过程期间测量量子攻击复杂性的指标之一指定为 MAXDEPTH，其动机是运行极长串行计算的难度。MAXDEPTH 的合理值范围从 2^{40} 逻辑门（即量子计算架构预计一年内串行执行的近似门数）通过 2^{64} 逻辑门（即经典计算架构十年内串行执行的近似门数）到不超过 2^{96} 逻辑门（即具有光速传播时间的原子级量子比特千年内可执行的近似门数）[Jones]。

量子攻击的复杂性可以根据电路大小测量（参见 [Grassl]）。这些数字可以与破解 AES 和 SHA3 所需的资源进行比较。NIST 对 AES 和 SHA3 的最优密钥恢复和碰撞攻击的经典和量子门计数给出以下估计，其中电路深度限制为 MAXDEPTH：

• AES 128 2^{170}/MAXDEPTH 量子门或 2^{143} 经典门
• SHA3-256 2^{146} 经典门
• AES 192 2^{233}/MAXDEPTH 量子门或 2^{207} 经典门
• SHA3-384 2^{210} 经典门

• AES 256 2^{298}/MAXDEPTH 量子门或 2^{272} 经典门
• SHA3-512 2^{274} 经典门

NIST 相信这些估计对于与后量子算法安全分析相关的大多数 MAXDEPTH 值是准确的，但估计可能低估非常小 MAXDEPTH 值的 SHA 安全性，并可能低估非常大 MAXDEPTH 值的 AES 量子安全性。

附录 D. 缩写和首字母缩写词列表

2TDEA

双密钥三重数据加密算法

3TDEA

三密钥三重数据加密算法

AEAD

带关联数据的认证加密

AES

高级加密标准

ANS

美国国家标准

ANSI

美国国家标准协会

CA

认证机构

CAVP

加密算法验证计划

CKL

泄露密钥列表

CRC

循环冗余校验

CRL

证书撤销列表

CMAC

基于密码的消息身份认证码

CMVP

加密模块验证计划

DES

数据加密标准

DH

Diffie-Hellman

DRBG

确定性随机比特生成器

DSA

数字签名算法

ECC

椭圆曲线密码

ECDH

椭圆曲线 Diffie-Hellman

ECDSA

椭圆曲线数字签名算法

EdDSA

爱德华兹曲线数字签名算法

FFC

有限域密码

FIPS

联邦信息处理标准

HMAC

密钥哈希消息身份认证码

HSM

硬件安全模块

IC

集成电路

IFC

整数分解密码

IP

互联网协议

ISO/ITU-T

国际标准化组织/国际电信联盟 – 电信

ITL

信息技术实验室

IV

初始化向量

KMAC

基于 Keccak 的消息身份认证码

KRI

密钥恢复信息

KRS

密钥恢复系统

MAC

消息身份认证码

ML-DSA

基于模块格的数字签名标准

ML-KEM

基于模块格的密钥封装机制

NIST SP 800-57pt1r6 ipd（初始公开草案）

2025 年 12 月

密钥管理建议

第 1 部分 — 总则

MQV

Menezes-Qu-Vanstone

NIST

美国国家标准与技术研究院

PKI

公钥基础设施

POP

占有证明

PQC

后量子密码

RA

注册机构

RAM

随机存取存储器

RBG

随机比特生成器

RNG

随机数生成器

RSA

Rivest–Shamir–Adleman

S/MIME

安全多用途互联网邮件扩展

SHA-2

安全哈希算法 2

SHA-3

安全哈希算法 3

SHAKE

安全哈希算法 KECCAK

SLH-DSA

无状态基于哈希的数字签名算法

SSH

安全外壳协议

TDEA

三重数据加密算法

TLS

传输层安全

TPM

受信任平台模块

XOF

可扩展输出函数

USB

通用串行总线

附录 E. 术语表

访问控制

将资源访问限制为仅授权实体。

问责制

1. 分配密钥管理责任给个人并让他们对这些活动负责。
2. 确保实体行为可以唯一追溯到该实体的属性。

激活状态

密钥状态，其中密钥可用于加密保护信息（例如加密明文或生成数字签名）、加密处理先前受保护的信息（例如解密密文或验证数字签名），或两者。

算法发起者使用周期

特定对称密钥算法可由发起者用于对数据应用保护（例如加密或生成 MAC）的时间段。

算法参数

与某些公钥算法结合使用以生成密钥对或执行加密操作（例如创建数字签名或建立密钥材料）的参数。

算法安全寿命

在密钥未泄露的情况下，受特定加密算法保护的数据估计保持安全的估计时间段。

批准

FIPS 批准和/或 NIST 推荐。在 FIPS 或 NIST 建议中指定的算法或技术，或在其他地方指定并在 FIPS 或 NIST 建议中通过引用采用的算法或技术。

归档

1. 将信息放入长期存储。
2. 用于长期存储的位置或介质。

关联

特定目的的关系，例如与将使用它的应用或进程相关联的密钥。

（私钥）占有保证

实体拥有私钥及其相关密钥信息且私钥对应于给定公钥的信心。

有效性保证

公钥或域参数正常确的信心。

非对称密钥算法

参见公钥加密算法。

身份认证

提供通信会话、消息、文档或存储数据中信息源和完整性保证的过程，或提供与系统交互实体身份保证的过程。参见源身份认证、身份身份认证和完整性身份认证。

身份认证码

基于批准安全功能的密钥加密校验和。也称为消息身份认证码。

授权

授予实体的访问特权，传达执行安全功能或活动的"官方"许可。

可用性

授权实体及时、可靠地访问信息。

备份

密钥信息的副本，以便在密钥密码周期期间必要时促进恢复。

分组密码（算法）

使用加密密钥一次转换一个信息块的对称密钥加密算法。对于分组密码算法，输入块的长度与输出块的长度相同。

证书

参见公钥证书。

证书清单管理

参见密钥清单管理。

认证机构

公钥基础设施 (PKI) 中的受信任方，向证书主体颁发公钥证书。

证书主体

授权使用公钥证书中公钥相关联私钥的实体。

密文

加密形式的数据。

碰撞

两个或多个不同输入产生相同输出。另见哈希函数。

泄露

敏感密钥信息（例如秘密密钥、私钥或秘密元数据）的未经授权披露、修改、替换或使用。

泄露状态

当怀疑或确认密钥泄露时密钥转换到的密钥状态。

机密性

敏感信息不向未经授权的实体披露的属性（例如保持密钥信息的秘密性）。

应急计划

为灾难响应、备份操作和/或灾后恢复维护的计划，以确保关键资源的可用性并在紧急情况下促进操作连续性。

应急计划

应急计划的开发。

密码分析

1. 在没有初始知识的情况下执行以击败加密保护的操作，该密钥用于提供保护。
2. 研究数学技术以尝试击败加密技术和信息系统安全。这包括寻找算法实施中的错误或弱点或算法本身设计的过程。

加密算法

明确定义的计算过程，采用可变输入，通常包括加密密钥，并产生输出。

加密边界

明确定义的连续周长，建立加密模块的物理边界并包含加密模块的所有硬件、软件和/或固件组件。

加密元素

加密服务使用的特定类型、长度或强度的加密算法、方案、参数选择和/或密钥。

加密哈希函数

参见哈希函数。

加密密钥（密钥）

与加密算法结合使用的参数，以决定其操作方式，使得知道密钥的实体可以重现、反转或验证操作，而不知道密钥的实体则不能。

加密模块

实现批准安全功能并包含在加密边界内的硬件、软件和/或固件集。另见安全功能。

密码周期

特定密钥授权使用的时间跨度，或给定系统或应用的密钥保持有效的时间。

数据加密密钥

用于加密和解密密钥以外数据的密钥。

数据完整性

数据自创建、传输或存储以来未以未经授权方式改变的属性。

解封

使用私解封密钥和密钥封装机制 (KEM) 从密文产生对称密钥的密钥建立过程。参见封装和密钥封装机制。

解密

使用加密算法和密钥将密文更改为明文的过程。

销毁（密钥或其他数据）

应用于密钥或其他数据的行为，之后无法恢复关于其值的任何信息。其他常用术语是删除、销毁、清零和清理。

销毁状态

密钥销毁时转换到的密钥状态。虽然密钥不再存在，但其先前存在可以记录（例如在元数据或审计日志中）。

销毁（密钥或其他数据）

参见销毁。

确定性随机比特生成器 (DRBG)

包括 DRBG 算法并（至少最初）可访问随机源的随机比特生成器。DRBG 从称为种子的秘密初始值产生比特序列。加密 DRBG 具有附加属性，即在种子未知的情况下输出不可预测。DRBG 有时也称为伪随机数生成器 (PRNG) 或确定性随机数生成器。

数字签名

数据加密转换的结果，当与支持基础设施和政策正常确实施时，提供源或身份身份认证、数据完整性身份认证和/或支持签名者不可否认性。

封装

使用公封装密钥和密钥封装机制 (KEM) 生成随机对称密钥和相应密文值的密钥建立过程。参见密钥封装机制和解封。

加密密钥

使用批准的加密算法加密的加密密钥，以伪装底层明文密钥的值。

加密

使用加密算法和密钥将明文更改为密文的过程。

实体

个人（人）、组织、设备或进程。

实体注册

加密密钥生命周期中的功能。实体成为安全域成员的过程。

临时密钥

为加密过程的每次执行（例如密钥建立）生成的加密密钥，并满足密钥类型的其他要求（例如对每条消息或会话唯一）。

可扩展输出函数 (XOF)

比特串上的函数，其输出长度可以扩展到任何长度。批准的 XOF（例如 [FIPS 202] 和 [SP 800-232] 中规定的 XOF）设计为满足以下属性，只要指定输出长度足够长以防止简单攻击：

1. （单向）在计算上不可行找到映射到任何新预指定输出的任何输入。
2. （碰撞抗性）在计算上不可行找到映射到相同输出的任何两个不同输入。

基于哈希的消息身份认证码 (HMAC)

使用批准的哈希函数和密钥的消息身份认证码（即参见 [SP 800-224]）。

哈希函数

将任意（虽然有界）长度的比特串映射到固定长度比特串的函数。批准的哈希函数满足以下属性：

1. （单向）在计算上不可行找到映射到任何预指定输出的任何输入。
2. （碰撞抗性）在计算上不可行找到映射到相同输出的任何两个不同输入。

哈希方法

采用任意长度输入比特串并产生给定长度输出的算法。哈希方法不需要加密密钥。已批准两种哈希方法：（加密）哈希函数和可扩展输出函数。

哈希值

将哈希方法应用于信息的结果。

标识符

与人、设备或组织相关联的比特串。它可以是识别名称或更抽象的东西（例如由 IP 地址和时间戳组成的字符串），取决于应用。

身份

实体的区别特征或个性。

身份身份认证

提供与系统交互实体身份保证的过程（例如访问资源）。有时称为实体身份认证。

初始化向量 (IV)

用于定义加密过程起点的向量。

完整性

参见数据完整性。

完整性身份认证

获得保证数据自为该数据创建身份认证码或数字签名以来未被修改的过程。

完整性保护

使用在该数据上计算的身份认证码（例如 MAC）或数字签名获得传输或存储数据的保护。参见完整性身份认证。

密钥

参见加密密钥。

密钥协商

密钥建立过程，其中密钥材料从两个或多个参与者贡献的信息生成，以便任何一方都不能独立于任何其他方的贡献预先确定密钥材料的值。

密钥确认

用于向一方提供另一方实际拥有相同密钥材料和/或共享密钥的保证的过程。

密钥注销

加密密钥生命周期中的功能，涉及标记密钥或与其相关联的信息（例如元数据）以指示密钥不再使用。

密钥导出

从预共享密钥或共享密钥（来自密钥协商方案）以及其他信息导出密钥材料的过程。

密钥导出函数

使用加密密钥或共享密钥以及可能其他数据的输入生成称为密钥材料的二进制串的函数。

密钥导出密钥

与密钥导出方法一起使用以导出附加密钥的密钥。有时称为"主密钥"。

密钥导出方法

密钥导出函数或其他批准的导出密钥材料的过程。

密钥销毁

移除加密密钥的所有痕迹，以便无法通过物理或电子手段恢复。

密钥分发

将密钥和其他密钥材料从拥有、生成或以其他方式获取密钥的实体传输到打算使用密钥的另一个实体。

密钥封装机制 (KEM)

三个加密算法集 — KeyGen、Encaps 和 Decaps — 可由两方用于在公共信道上建立共享密钥。参见封装和解封。

密钥加密密钥

用于加密或解密其他密钥以提供这些密钥机密性保护的加密密钥。另见密钥包装密钥。

密钥建立

加密密钥生命周期中的功能。使用手动传输方法（例如密钥加载器）、自动化方法（例如密钥传输、密钥协商或密钥封装方案）或自动化和手动方法的组合在实体之间安全建立加密密钥的过程。

密钥信息

关于密钥的信息，包括密钥材料和与该密钥相关的元数据。参见密钥材料和元数据。

密钥清单

关于每个密钥的信息，不包括密钥本身（例如密钥所有者、密钥类型、算法、应用或到期日）。

密钥（或证书）清单管理

建立和维护使用中密钥和/或证书的记录，分配和跟踪其所有者或赞助者，监控密钥和证书状态，并在需要时向适当官员报告状态以采取补救行动。

密钥长度

密钥的比特长度。与"密钥大小"互换使用。

密钥管理

在密钥整个生命周期期间处理加密密钥和其他相关密钥信息的活动，包括其生成、存储、建立、输入、输出、使用和销毁。

密钥管理政策

高级文档，识别高级结构、责任、管理标准和指南、组织依赖关系和其他关系，以及安全政策。

密钥管理系统

管理加密密钥及其元数据的系统，包括其生成、分发、存储、备份、归档、恢复、使用、撤销和销毁。自动化密钥管理系统可用于监督、自动化和保护密钥管理过程。

密钥管理实践声明

提供组织结构、负责角色和密钥管理政策中识别功能规则的详细描述的文档或文档集。

密钥所有者

授权使用对称密钥或公钥（非对称）密钥对的私钥且其标识符与密钥或密钥对相关联的实体。

密钥对

与非对称密钥（公钥）算法一起使用的公钥及其相应私钥。

密钥恢复

加密密钥生命周期中的可能功能。允许授权实体检索或重建密钥的机制和过程。

密钥注册

加密密钥生命周期中的功能。注册机构用于创建密钥材料官方记录的过程。

密钥撤销

加密密钥生命周期中的可能功能。向受影响实体提供通知的过程，即密钥应在既定密码周期结束前从运行使用中移除。

密钥份额

n 个参数之一（其中 $n \geq 2$），使得在 n 个密钥份额中，任何 k 个密钥份额（其中 $k \geq n$）可用于构造密钥值。拥有任何 $k-1$ 个或更少密钥份额不提供关于（构造的）密钥值的知识。有时称为"加密密钥组件"或"密钥分割"。

密钥大小

密钥的比特长度。与密钥长度互换使用。

密钥状态

密钥在其生成和销毁之间转换的状态。参见预激活状态、激活状态、暂停状态、泄露状态和销毁状态。

密钥传输

密钥建立过程，其中一方（即发送者）选择并加密（或包装）密钥，然后将其分发给另一方（即预期接收者）。

当与公钥（非对称）算法结合使用时，密钥使用接收者的公钥加密，然后使用接收者的私钥解密。

当与对称算法结合使用时，密钥使用发送和接收方共享的密钥包装密钥加密，并使用相同密钥解密。

密钥更新

对加密密钥执行的功能，以计算与旧密钥相关并用于替换该密钥的新密钥。

注意：本建议不允许此替换密钥的方法。

密钥包装

加密保护密钥的方法，提供机密性和完整性保护。

密钥包装密钥

用于为其他密钥提供机密性和完整性保护的密钥。另见密钥加密密钥。

密钥材料

加密密钥和与加密算法一起使用的其他参数（例如 IV 或算法参数）。

手动密钥传输

通过物理移动包含密钥或密钥份额的设备或文档手动（即非自动化）传输加密密钥的手段。

主密钥

参见密钥导出密钥。

消息身份认证码 (MAC)

数据上的加密校验和，使用批准的安全功能和对称密钥来检测数据的意外和故意修改。

元数据

与密钥相关联的信息，描述其特定特征、约束、可接受用途和所有权。有时称为密钥的"属性"。

NIST 标准

联邦信息处理标准 (FIPS) 出版物和 NIST 建议。

不可否认性

使用数字签名提供的服务，以支持第三方确定消息是否实际由给定实体签名。

运行阶段

加密密钥生命周期中的阶段，其中密钥用于标准加密目的。

运行存储

密钥密码周期期间运行密钥材料的正常常存储。

（证书）所有者

在公钥证书中识别为主体的个人实体，或是识别为证书主体的非人类实体（例如设备、应用或进程）的赞助者。

（密钥或密钥对）所有者

对于静态密钥对，与公钥相关联并授权使用私钥的实体。对于临时密钥对，生成公/私密钥对的实体。对于对称密钥，任何授权使用密钥的实体。

发起者

启动信息交换或存储事件的实体。

发起者使用周期

对称密钥密码周期中可以使用该密钥对数据应用加密保护的时间段。

密码

用于身份认证身份、验证访问授权或导出加密密钥的字符（即字母、数字和其他符号）串。

保护周期

需要维护密钥完整性或机密性的时间段。

明文

具有含义且无需应用解密即可理解的智能数据。

预激活状态

密钥已生成但尚未授权使用密钥状态。

私钥

与公钥加密算法一起使用的加密密钥，与实体唯一相关联且不公开。在非对称密钥（公钥）密码系统中，私钥具有相应公钥。

占有证明 (POP)

获得保证密钥对的所有者实际拥有与公钥相关联的私钥的验证过程。

伪随机数生成器

参见确定性随机比特生成器 (DRBG)。

公钥

与公钥加密算法一起使用的加密密钥，与实体唯一相关联且可以公开。在非对称密钥（公钥）密码系统中，公钥具有相应私钥。

公钥证书

提供证书所有者唯一标识符的数据集，包含该实体的公钥和可能其他信息，并由受信任方（例如 CA）数字签名，从而将公钥绑定到实体的标识符。证书中的附加信息可以指定如何使用密钥及其有效期。

公钥（非对称密钥）加密算法

使用两个相关密钥的加密算法：公钥和私钥。两个密钥具有从公钥确定私钥在计算上不可行的属性。

公钥基础设施 (PKI)

建立颁发、维护和撤销公钥证书的框架。

随机比特生成器 (RBG)

输出看起来统计独立和无偏的比特序列的设备或算法。另见随机数生成器。

随机数生成器 (RNG)

用于生成不可预测数字序列的过程。也称为随机比特生成器 (RBG)。

接收者使用周期

可以使用对称算法和对称密钥处理（例如解密）受保护信息的时间段。

注册机构 (RA)

建立并担保用户身份的受信任实体。

依赖方

依赖密钥或密钥对的安全性和真实性来应用加密保护和/或移除或验证已应用保护的方。这包括依赖公钥证书中公钥的方和共享对称密钥的方。

（密钥所有者的）代表

参见（密钥的）赞助者。

保留期

密钥或其他加密相关信息应保留的最短时间量。

RBG 种子

用于初始化 DRBG 的比特串。也称为种子。

秘密密钥

与对称密钥加密算法一起使用的单个加密密钥，与一个或多个实体唯一相关联且不公开（即密钥保密）。秘密密钥也称为对称密钥。

注意：在此上下文中使用术语"秘密"不暗示分类级别，而是暗示需要保护密钥免受披露。

秘密密钥算法

参见对称密钥算法。

秘密密钥信息

需要保密的密钥信息（例如对称密钥、私钥、密钥份额和秘密元数据）。

安全类别

根据破解分组密码算法或哈希函数所需的计算资源评估算法安全强度的评估标准。

安全通信协议

提供适当机密性、源身份认证和完整性保护的通信协议。

安全域

在单一受信任机构权威下的系统或子系统。安全域可以组织（例如分层）以形成更大域。

安全功能

加密算法，以及操作模式（如适当）；例如分组密码、数字签名算法、非对称密钥建立算法、消息身份认证码、哈希方法或随机比特生成器。参见 [FIPS 140-3]。

数据的安全寿命

需要保护数据安全性的时间段（即其机密性、完整性或可用性）。

安全服务

用于提供机密性、身份身份认证、完整性身份认证、源身份认证和/或不可否认性的机制。

安全强度

与破解加密算法或系统所需工作量（即操作次数）相关联的数字。在本建议中，安全强度以比特指定，是来自集合 {112, 128, 192, 256} 的特定值。也称为"安全比特"。

种子

用于初始化过程（例如初始化 DRBG）或生成密钥材料的秘密值。另见 RBG 种子。

自签名证书

其数字签名可以由证书内包含的公钥验证的公钥证书。自签名证书上的签名保护证书内信息的完整性，但不保证该信息的真实性。自签名证书的信任基于用于分发它们的安全程序。

shall（应）

此术语用于表示联邦信息处理标准 (FIPS) 出版物的要求或必须履行才能声称符合本建议的要求。

注意：Shall 可以与 not 结合成为 shall not（不应）。

共享密钥

使用密钥协商方案计算的秘密值，用作密钥导出方法的输入。来自密钥协商方案的共享密钥不能直接用作密钥。

共享秘密密钥

可以直接用作对称密码中加密密钥的共享密钥。它不需要附加密钥导出。

should（应该）

此术语用于表示非常重要的建议。忽视该建议可能导致不良结果。

注意：Should 可以与 not 结合成为 should not（不应该）。

签名生成

使用数字签名算法和私钥在数据上生成数字签名。

签名验证

使用数字签名算法和公钥验证数据上的数字签名。数字签名使用相应私钥生成。

源身份认证

提供信息来源保证的过程。有时称为"来源身份认证"。与身份身份认证比较。

分割知识程序

从多个密钥份额建立密钥的程序，每个份额仅由单个实体知晓。密钥份额使用批准方法组合。参见密钥份额。

（证书的）赞助者

负责管理证书的非人类实体（例如设备、应用、进程）的人类实体，该实体在证书中识别为主体。证书管理包括申请证书、生成密钥对、在需要时替换证书，以及撤销证书。证书赞助者也是证书中公钥和相应私钥的赞助者。

（密钥的）赞助者

负责管理授权使用密钥的非人类实体（例如组织、设备、应用或进程）密钥的人类实体。

静态密钥

旨在在相对长时间内使用的密钥，通常旨在用于加密密钥建立方案的许多实例。与临时密钥对比。

暂停状态

密钥或密钥对的使用可能暂停一段时间的密钥状态。

对称密钥

与对称密钥加密算法一起使用的单个加密密钥，与一个或多个实体唯一相关联且不公开（即密钥保密）。对称密钥通常称为秘密密钥。参见秘密密钥。

对称密钥算法

对操作及其补码（例如加密和解密）使用相同秘密密钥的加密算法。也称为秘密密钥算法。

系统

为信息收集、处理、维护、使用、共享、传播或处置而组织的离散资源集。

系统初始化

加密密钥生命周期中的功能。设置和配置系统以安全运行。

信任锚

1. 假设信任的权威实体。在 PKI 中，信任锚是认证机构，由用于验证由该信任锚颁发的证书上签名的证书表示。验证过程的安全性取决于信任锚证书的真实性和完整性。信任锚证书通常作为自签名证书分发。
2. 受信任 CA 的自签名公钥证书。

受信任信道

在加密模块和发送者或接收者之间建立的受信任和安全通信链路，以安全通信未受保护的明文、关键安全参数、密钥组件和身份认证数据。

未经授权披露

涉及将信息暴露给无权访问信息的实体的事件。

用户

个人（人）。另见实体。

X.509 证书

ISO/ITU-T X.509 标准定义的 X.509 公钥证书或 X.509 属性证书。

最常见（包括在本文档中），X.509 证书指 X.509 公钥证书。

附录 F. 变更日志

2025 年，对 SP 800-57 第 1 部分进行了以下更改：

1. 本出版物的 NIST 模板已更改，导致将缩写和定义（在修订版 5 中）从第 2 节移至附录。
2. 已纳入 SP 800-232 中规定的 Ascon 以及 FIPS 203、204 和 205 中规定的新抗量子算法。
3. 第 2.6 节：添加了关于销毁密钥材料的文本。
4. 第 2.7 节：密钥传输的描述已稍作修改，并添加了密钥封装的描述。
5. 第 3.1 节（原第 4.1 节）：已纳入 FIPS 202 中规定的可扩展输出函数 (XOF)，术语"哈希方法"用于指代两种哈希方法。
6. 第 3.3 节（原第 4.3 节）：扩展了关于非对称密钥算法的讨论。
7. 第 4.1.1 节（旧第 5.1.1 节）：现在分别讨论用于密钥建立和密钥存储的密钥。FIPS 203 中使用的封装和解封密钥已纳入自动化密钥建立和密钥存储应用。
8. 第 4.3.4 节（原第 5.3.4 节）：添加了封装/解封密钥的示例。
9. 第 4.3.6 节（原第 5.3.6 节）：现在分别讨论用于密钥建立和密钥存储的密钥。FIPS 203 中使用的封装和解封密钥已纳入自动化密钥建立和密钥存储应用。

10. 第 4.6.1 节（原第 5.6.1 节）：已纳入 PQC 竞赛中使用的安全类别，以及抗量子算法（在表 5 中）。TDEA 现在显示为不允许，Ascon-AEAD128 已添加（在表 3 中）。DSA 显示为不允许（在表 4 中）。ML-KEM、ML-DSA、SKH-DSA 和 SP 800-208 中基于哈希的签名算法已添加到表 5。表 6 现在包括 Ascon-hash256、Ascon-XOF128、Ascon-CXOF128、SHAKE128 和 SHAKE 256。
11. 第 4.6.2 节（原第 5.6.2 节）：示例已更改为使用 ML-KEM 和 ML-DSA。
12. 第 4.6.3 节（原第 5.6.3 节）：已删除时间框架并替换为对 SP 800-131A 的引用。
13. 第 4.6.4 节（原第 5.6.4 节）：本节已更新，包括在 PQC 过渡期间开发的附加指南以及对 NIST 加密敏捷性项目的引用。
14. 第 4.6.5 节（原第 5.6.5 节）：添加了关于在 SP 800-131A 中不允许算法时终止密码周期的新文本。
15. 第 5.1.1 节（原第 6.1.1 节）：已添加封装和解封密钥，并在表中分离了通信和存储应用（表的最后一列进行了一些更改）。
16. 第 5.1.2 节（原第 6.1.2 节）：表中最右列已更改，包括用于（重新）生成密钥的种子（例如 ML-KEM 密钥对）。
17. 第 5.2.2 节（原第 6.2.2 节）：已添加关于密钥存储介质（例如使用 HSM 和 TPM）的小节作为第 5.2.2.7 节。
18. 第 5.2.3 节（原第 6.2.2 节）：种子已添加到可能元数据列表中，用于（重新）生成密钥或密钥对。
19. 第 5.2.2.7 节（新）：已添加一节讨论密钥材料存储和机制。
20. 第 6 节（原第 7 节）：已添加封装和解封密钥。已移除停用状态。已添加表到激活状态以澄清到销毁状态的转换（第 6.2 节）。从泄露状态到销毁状态的转换已扩展以提高清晰度（第 6.3 节）。
21. 第 7 节（原第 8 节）：已移除关于每个密钥状态的特定密钥的讨论，留下密钥状态的基本描述。
22. 第 7.1.5.2.3 节（原第 8.1.5.2.3 节）：密钥封装的讨论现在与密钥协商的讨论一起包括。
23. 第 7.1.5.3.4 节（原第 8.1.5.3.4 节）：种子的讨论已扩展，包括用于（重新）生成密钥的种子（例如 ML-KEM 密钥）。
24. 参考文献已更新，包括添加对 FIPS 203、FIPS 204、FIPS 205、SP 800-208、ISO/IEC 19790、NIST IR 7977、SP 800-224、SP 800-227 和 SP 800-232 的引用。
25. 附录 B 已重新组织，将关于密钥类型的讨论放在附录末尾，并按与正常文中使用的相同顺序讨论密钥类型（例如在第 4.1.1 节中）。添加了关于封装/解封密钥对的指南，以及许多密钥类型的附加和/或澄清指南。
26. 添加了附录 C 以解决估计后量子加密系统安全强度的不确定性。分类方法基于现有 NIST 标准在对称密码中提供的安全强度范围。
27. 附录 D（原第 2.2 节）：添加了新术语，包括 ML-DSA、ML-KEM、PQC、SLH-DSA 和 XOF。
28. 附录 E（原第 2.1 节）：添加了新定义，包括"销毁（密钥或其他数据）"、"可扩展输出函数"、"哈希方法"、"安全类别"、"共享秘密密钥"、"分割知识程序"和"受信任信道"。修改的定义现在包括"有效性保证"、"解封"、"封装"、"应急计划"、"密钥封装机制"、"密钥包装"、"密钥包装密钥"、"私钥"、"公钥"、"公钥证书"、"接收者使用周期"、"安全强度"和"种子"。"域参数"的定义已更改为"算法参数"。